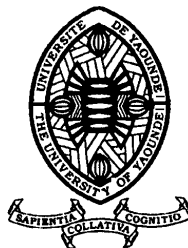


UNIVERSITÉ DE YAOUNDÉ I

ÉCOLE NATIONALE
SUPÉRIEURE POLYTECHNIQUE

DÉPARTEMENT DE GÉNIE
INFORMATIQUE
HUMANITÉS NUMÉRIQUES



UNIVERSITY OF YAOUNDE I

NATIONAL ADVANCED
SCHOOL OF ENGINEERING

DEPARTMENT OF COMPUTER
ENGINEERING
DIGITAL HUMANITIES

STANDARDISATION DE L'AUDIT DE SÉCURITÉ D'UNE APPLICATION BASÉE SUR LA DÉMARCHE DE L'ANTIC : CAS DE GIDOCEP

MÉMOIRE DE FIN D'ÉTUDES

Présenté et soutenu par :

TOMI OLAMA GABRIELLE SOLANGE

Matricule : 21P643

En vue de l'obtention du :

Diplôme d'Ingénieur de Conception en Humanités Numériques

Option :

Cybersécurité et Investigation Numériques

DEVANT LE JURY COMPOSÉ DE

Président	:
Rapporteur	:
Examineur	:
Encadreur académique	:
Encadreur professionnel	:

Année académique 2025-2026



STANDARDISATION DE L'AUDIT DE SÉCURITÉ D'UNE APPLICATION BASÉE SUR LA DÉMARCHE DE L'ANTIC : CAS DE GIDOCEP

MÉMOIRE DE FIN D'ÉTUDES

Présenté et soutenu par :

TOMI OLAMA GABRIELLE SOLANGE

En vue de l'obtention du :

Diplôme d'Ingénieur de Conception en Humanités Numériques

Option :

Cybersécurité et Investigation Numériques

Sous la supervision de:

Encadreur académique :

Encadreur professionnel :

Structure d'accueil :

SOLUTIONS TECHNIQUES (SOLTEC)

Année académique 2025-2026



DÉDICACE

À mes parents

Et à toute ma famille



REMERCIEMENTS

« *La reconnaissance est un devoir que l'on devrait rendre, mais que l'on ne peut exiger.* » -
Jean-Jacques Rousseau

C'est dans cet esprit que je prends un moment pour reconnaître ceux qui sont l'inspiration silencieuse derrière chaque page, chaque mot et chaque idée de ce mémoire.

- ◆ **Président du jury**, pour son accompagnement bienveillant, sa disponibilité constante et les encouragements qui ont guidé mon parcours.
- ◆ **Examineur**, pour l'attention portée à ce mémoire. Son regard critique constitue pour moi une source d'enrichissement scientifique.
- ◆ **Encadreur**, pour son accompagnement attentif, la pertinence de ses orientations et son soutien tout au long de ce travail.
- ◆ **Tout le personnel enseignant du Département de Génie Informatique** de l'ENSPY. Vos conseils et votre encadrement ont été essentiels.
- ◆ **M. Patrick MBOUL**, encadreur professionnel, pour sa disponibilité et son accompagnement au sein de SOLTEC.
- ◆ **Mes frères et sœurs**, Larissa, Frida, Christiane, Berthold, Essola, Archange et Raphaëlle ; les grandes familles TOMI FRANÇOIS et OLAMA APOLINAIRE : merci pour votre soutien sans faille.
- ◆ **M. Thierry Minka**, pour son exigence et son soutien. Un véritable modèle et source d'inspiration.
- ◆ **Mes aînés académiques**, pour le temps consacré à m'accompagner dans la rédaction de ce mémoire.
- ◆ **M. NJEI CHECK**, Directeur du Département d'Audit de Sécurité de l'ANTIC, pour m'avoir permis d'assister à la conférence du 29 avril 2026.

-
- ✦ **NZIE IHOUE Noëlle Lagrande**, amie de longue date, pour notre amitié exceptionnelle et les moments partagés à Polytechnique.
 - ✦ **La promotion AHN 2026**, famille choisie, qui a rythmé et marqué ces années à Polytechnique.
 - ✦ **À toute l'équipe de SOLTEC** : merci pour cet espace où la passion pour l'audit se vit pleinement.

Avec toute ma gratitude,

ABRÉVIATIONS

AC : Agent Comptable

AFD : Agence Française de Développement

AHN : Arts et Humanités Numériques

ANSSI : Agence Nationale de la Sécurité des Systèmes d'Information (France)

ANTIC : Agence Nationale des Technologies de l'Information et de la Communication

API : *Application Programming Interface*

ART : Agence de Régulation des Télécommunications

ASVS : *Application Security Verification Standard* / Norme de vérification de la sécurité applicative

AWP : *Active Web Pages*

BDD : Base de Données

CF : Contrôleur Financier

CIA : Confidentialité, Intégrité, Disponibilité / *Confidentiality, Integrity, Availability*

CMMI : *Capability Maturity Model Integration* / Intégration du modèle de maturité des capacités

COBAC : Commission Bancaire de l'Afrique Centrale

CORS : *Cross-Origin Resource Sharing*

CSP : *Content Security Policy*

CSRF : *Cross-Site Request Forgery*

CVE : *Common Vulnerabilities and Exposures*

CVSS : *Common Vulnerability Scoring System*

DAAF : Direction des Affaires Administratives et Financières

DAST : *Dynamic Application Security Testing* / Test dynamique de sécurité applicative

DevSecOps : *Development, Security and Operations* / Développement, Sécurité et Opérations

DG : Direction Générale

DGA : Directeur Général Adjoint

DGB : Direction Générale du Budget

DSI : Directeur des Systèmes d'Information

EBIOS : Expression des Besoins et Identification des Objectifs de Sécurité

ENSPY : École Nationale Supérieure Polytechnique de Yaoundé

EPA : Établissement Public Administratif

GIDOCEP : Gestion Informatisée des Opérations Comptables des Établissements Publics

HFSQL : *Hyper File SQL*

HSTS : *HTTP Strict Transport Security*

HTTP : *HyperText Transfer Protocol*

HTTPS : *HyperText Transfer Protocol Secure*

IDOR : *Insecure Direct Object Reference*

IIS : *Internet Information Server*

IIA : *Institute of Internal Auditors* / Institut des Auditeurs Internes

IPPF : *International Professional Practices Framework* / Cadre international des pratiques professionnelles

ISACA : *Information Systems Audit and Control Association*

ISO : Organisation Internationale de Normalisation

JWT : *JSON Web Token*

MFA : *Multi-Factor Authentication*

MINFI : Ministère des Finances (Cameroun)

MINPOSTEL : Ministère des Postes et Télécommunications

MUSA : Méthode Unifiée d'Audit de Sécurité Applicative

NA : Non Applicable

NAP : Net À Payer

NC : Non Conforme

NDA : *Non-Disclosure Agreement*

NIST : *National Institute of Standards and Technology* / Institut national des normes et de la technologie (É.-U.)

NTP : *Network Time Protocol*

OP : Ordre de Paiement

ORM : *Object-Relational Mapping*

OTP : *One-Time Password*

OWASP : *Open Web Application Security Project*

PC : Partiellement Conforme

PII : *Personally Identifiable Information*

PoC : *Proof of Concept*

PRA : Plan de Reprise d'Activité

PT : Papier de Travail (MUSA)

REST : *Representational State Transfer*

RSSI : Responsable de la Sécurité des Systèmes d'Information

SAST : *Static Application Security Testing* / Test statique de sécurité applicative

SCA : *Software Composition Analysis*

SDLC : *Software Development Life Cycle* / Cycle de vie du développement logiciel

SI : Système d'Information

SLA : *Service Level Agreement* / Accord sur les niveaux de service

SMSI : Système de Management de la Sécurité de l'Information

SOLTEC : Solutions Techniques

SP : *Special Publication* (NIST)

SQL : *Structured Query Language*

SSI : Sécurité des Systèmes d'Information

TIC : Technologies de l'Information et de la Communication

TLS : *Transport Layer Security*

UA : Unité Administrative

UI : *User Interface*

UPS : *Uninterruptible Power Supply*

URL : *Uniform Resource Locator*

USB : *Universal Serial Bus*

WWUSR : *World Wide Web User* (groupe Windows)

XSS : *Cross-Site Scripting*

ZG : Zone Grise

GLOSSAIRE

Artefact. Document ou outil produit lors d'un audit, standardisé et réutilisable. Dans MUSA, les artefacts incluent les checklists Excel, les papiers de travail (PT01 à PT06) et les modèles de rapport en 7 sections.

Audit de sécurité. Examen méthodique et indépendant visant à évaluer le niveau de sécurité d'un système d'information. Il vérifie la conformité, identifie les vulnérabilités, évalue les contrôles existants et formule des recommandations.

Authentification forte (2FA). Méthode combinant deux facteurs indépendants pour renforcer la sécurité d'accès (ex. : mot de passe + code envoyé sur mobile).

Boîte noire / Boîte grise / Boîte blanche. Types de tests d'intrusion : boîte noire (aucune connaissance), boîte grise (connaissance partielle), boîte blanche (accès complet).

Chiffrement. Transformation de données lisibles en données illisibles sans clé de déchiffrement appropriée.

Cloud computing. Modèle d'accès à la demande à des ressources informatiques partagées via un réseau.

Correctif (Patch). Mise à jour logicielle corrigeant une vulnérabilité ou un dysfonctionnement.

Cybersécurité. Ensemble des mesures techniques, organisationnelles et juridiques protégeant les systèmes d'information.

DAST. Test de sécurité d'une application en cours d'exécution.

DevSecOps. Intégration de la sécurité à toutes les phases du cycle de développement logiciel.

Entropie de Shannon. Mesure quantitative de l'incertitude dans un système d'information, appliquée dans MUSA pour quantifier l'accord inter-auditeurs.

Intranet. Réseau privé utilisant les technologies Internet, accessible uniquement aux membres d'une organisation.

Journalisation (Logging). Enregistrement chronologique des événements d'un système, essentiel pour la traçabilité.

Matrice des risques. Outil de visualisation et de priorisation des risques basé sur deux dimensions : la probabilité (P) et l'impact (I). Le score de risque est $R = P \times I$.

Maturité. Niveau de formalisation et de maîtrise des processus de sécurité d'une organisation. Dans MUSA, évaluée sur 5 niveaux (0%, 25%, 50%, 75%, 100%).

Modélisation des menaces. Identification et analyse des menaces potentielles pour anticiper les contre-mesures.

Papiers de travail (PT). Documents standardisés utilisés par les auditeurs pour consigner leurs observations, preuves et conclusions. Dans MUSA : PT01 à PT06.

Plan de reprise d'activité (PRA). Procédures de restauration des systèmes après sinistre.

Rançongiciel (Ransomware). Logiciel malveillant chiffrant les données et exigeant une rançon.

Reproductibilité. Capacité à obtenir des résultats identiques lorsqu'un même audit est répété par différents auditeurs. Dans MUSA, mesurée par l'entropie de Shannon.

RSSI. Responsable de la Sécurité des Systèmes d'Information. Personne chargée de la mise en œuvre et du pilotage de la politique de sécurité.

SAST. Analyse de sécurité du code source sans exécution.

Test d'intrusion (Pentest). Simulation d'attaques autorisées pour évaluer la sécurité.

Vulnérabilité. Faiblesse dans un système pouvant être exploitée par une menace.

Zone grise. Situation où les auditeurs ne s'accordent pas sur un constat. Dans MUSA, une zone grise est signalée par une entropie H supérieure ou égale à 0,5, déclenchant une discussion ou un arbitrage.

RÉSUMÉ

La digitalisation croissante des opérations comptables des établissements publics camerounais s'accompagne d'une exposition accrue aux risques de sécurité informatique. L'ANTIC, chargée de la régulation et des audits de sécurité, dispose d'une démarche d'audit qui, bien qu'ancrée localement, présente trois lacunes majeures : (1) un **manque de reproductibilité** : deux auditeurs peuvent obtenir des résultats différents sur la même application ; (2) une **séparation artificielle** entre l'audit de sécurité et l'audit fonctionnel ; (3) une **absence de mesure objective** de la qualité de l'audit.

Ce mémoire propose **MUSA** (*Méthode Unifiée d'Audit de Sécurité Applicative*), une démarche standardisée qui fusionne délibérément les deux dimensions de l'audit. Conçue pour l'audit interne chez un éditeur de logiciel, MUSA s'appuie sur quatre piliers :

- ◆ **Pilier 1 - Standards de contenu** : ISO 27001 (93 contrôles), OWASP ASVS (14 catégories, 3 niveaux), NIST SP 800-115.
- ◆ **Pilier 2 - Standards de conduite** : ISO 19011:2018 (5 phases) et normes IIA (indépendance, suivi, escalade).
- ◆ **Pilier 3 - Innovation mesurable** : l'entropie de Shannon H quantifie l'accord entre auditeurs, avec des seuils définis : $H < 0,5$ (accord fort), $0,5 \leq H < 1,0$ (incertitude modérée), $H \geq 1,0$ (zone grise critique).
- ◆ **Pilier 4 - Artefacts réutilisables** : checklists Excel, papiers de travail PT01 à PT06, modèles de rapport en 7 sections.

La méthode a été appliquée à **GIDOCEP**, l'application de gestion comptable des établissements publics développée par SOLTEC. L'audit, réalisé selon le niveau 2 (standard) de MUSA, a identifié **6 vulnérabilités confirmées**, dont 1 critique (injection SQL), et a évalué le score de maturité à **29,2%**. L'entropie globale de **0,317** confirme la fiabilité des constats et la bonne reproductibilité de la méthode. MUSA démontre qu'il est possible de passer d'une démarche empirique à une approche **standardisée, reproductible et mesurable**, tout en conservant les forces de l'ANTIC

Mots-clés : Audit de sécurité, Standardisation, Reproductibilité, Entropie de Shannon, ANTIC, GIDOCEP, ISO 19011, OWASP ASVS, ISO 27001, NIST SP 800-115, normes IIA, MUSA.

ABSTRACT

IN the context of increasing digitalisation of financial operations in Cameroonian public institutions, securing accounting applications has become a critical priority. The ANTIC, responsible for regulation and security audits, has an audit approach that, despite strong local anchoring, suffers from three major limitations : (1) a **lack of reproducibility** (different auditors may obtain different results on the same application) ; (2) an **artificial separation** between security and functional audits ; (3) a **lack of objective measurement** of audit quality.

This thesis proposes **MUSA** (*Unified Method for Application Security Auditing*), a standardised approach that deliberately merges both security and functional dimensions. Designed for internal auditing within a software vendor, MUSA rests on four pillars :

- ◆ **Pillar 1 - Content standards** : ISO 27001 (93 controls), OWASP ASVS (14 categories, 3 levels), NIST SP 800-115.
- ◆ **Pillar 2 - Conduct standards** : ISO 19011:2018 (5 phases) and IIA standards (independence, monitoring, escalation).
- ◆ **Pillar 3 - Measurable innovation** : Shannon entropy H quantifies inter-auditor agreement, with defined thresholds : $H < 0.5$ (strong agreement), $0.5 \leq H < 1.0$ (moderate uncertainty), $H \geq 1.0$ (critical grey zone).
- ◆ **Pillar 4 - Reusable artifacts** : Excel checklists, standardised work papers (PT01 to PT06), seven-section report templates.

The method was applied to **GIDOCEP**, the accounting management application for public institutions developed by SOLTEC. The audit, conducted at level 2 (standard) of MUSA, identified **6 confirmed vulnerabilities**, including 1 critical (SQL injection), and assessed the maturity score at **29.2%**. The global entropy of **0.317** confirms the reliability of the findings and the good reproducibility of the method. MUSA demonstrates that it is possible to move from an empirical approach to a **standardised, reproducible and measurable** one, while preserving ANTIC's strengths .

Keywords: Security auditing, Standardisation, Reproducibility, Shannon entropy, ANTIC, GIDOCEP, ISO 19011, OWASP ASVS, ISO 27001, NIST SP 800-115, IIA standards, MUSA.

Contents

Dédicace	i
Remerciements	ii
Liste des abréviations	iv
Glossaire	vii
Résumé	ix
Abstract	x
Table des matières	xi
Table des figures	xvii
Liste des tableaux	xviii
Introduction générale	1
1 Fondements théoriques, état de l’art et analyse de la démarche ANTIC	3
Introduction du chapitre	3
1.1 Concepts généraux de la sécurité applicative	3
1.1.1 Définitions fondamentales	3
1.1.2 Les piliers de la sécurité : la triade CIA	4
1.1.3 Typologie des audits et place dans le SDLC	4
1.1.4 Spécificités de GIDOCEP	5
1.1.5 Fondements de la standardisation en cybersécurité	5
1.2 Justification du choix méthodologique	5

1.2.1	Distinction classique entre audit de sécurité et audit applicatif . . .	5
1.2.2	Pourquoi fusionner dans le contexte SOLTEC	5
1.3	État de l'art	6
1.3.1	La démarche d'audit de l'ANTIC	6
1.3.2	Standards de contenu : ISO 27001, OWASP ASVS, NIST SP 800-115	7
1.3.3	L'ISO 19011:2018 : standard de management des audits	8
1.3.4	Les normes IIA : gouvernance et déontologie	8
1.3.5	L'entropie de Shannon : mesure de l'incertitude en audit	8
1.3.6	Travaux existants et grille d'analyse	10
1.4	Analyse de la démarche ANTIC	10
1.4.1	Analyse détaillée phase par phase	11
1.4.2	Synthèse des forces	11
1.4.3	Synthèse des neuf limites	12
1.5	Comparaison avec les standards internationaux	12
1.5.1	Tableau comparatif général	12
1.5.2	Positionnement de MUSA	13
	Conclusion du chapitre	13
	Références bibliographiques du chapitre 1	14
2	Proposition de MUSA : Méthode Unifiée d'Audit de Sécurité Applicative	18
	Introduction du chapitre	18
2.1	Principes directeurs de MUSA	18
2.1.1	Principe 1 - Reproductibilité mesurable	18
2.1.2	Principe 2 - Fusion délibérée sécurité + applicatif	19
2.1.3	Principe 3 - Formalisation complète des procédures	19
2.1.4	Principe 4 - Profondeur adaptable à la criticité	20
2.1.5	Principe 5 - Gouvernance rigoureuse	20
2.1.6	Principe 6 - Réutilisabilité systématique	20
2.1.7	Principe 7 - Ancrage local préservé	20
2.2	Structure globale de MUSA	20

2.2.1	Vue d'ensemble architecturale	21
2.2.2	Les niveaux d'audit MUSA	21
2.2.3	Les artefacts MUSA	22
2.2.4	Les métriques MUSA	22
2.3	Phase 1 : Initiation, cadrage et préparation	24
2.3.1	Vue d'ensemble de la phase	24
2.3.2	Étape 1.1 : Déclenchement et contact initial	24
2.3.3	Étape 1.2 : Définition du périmètre et du niveau d'audit	26
2.3.4	Étape 1.3 : Collecte documentaire préalable	27
2.3.5	Étape 1.4 : Réunion de lancement	28
2.4	Phase 2 : Audit sur le terrain	29
2.4.1	Vue d'ensemble	29
2.4.2	Réunion d'ouverture	30
2.4.3	Sous-phase 2a : Audit organisationnel et physique	30
2.4.4	Sous-phase 2b : Audit technique	32
2.4.5	Sous-phase 2c: Analyse des risques et évaluation de la maturité	34
2.4.6	Réunions de suivi quotidiennes	39
2.5	Phase 3: Analyse, métriques et rapport	40
2.5.1	Vue d'ensemble	40
2.5.2	Consolidation des constats	40
2.5.3	Calcul des métriques globales	41
2.5.4	Structure du rapport d'audit (Artefact A7)	41
2.5.5	Outil Excel PT05-Rapport.xlsx	42
2.5.6	Réunion technique pré-clôture	42
2.6	Phase 4: Clôture et diffusion	42
2.6.1	Vue d'ensemble	42
2.6.2	Réunion de clôture formelle	43
2.6.3	Procédure contradictoire	43
2.6.4	Diffusion contrôlée du rapport	43
2.7	Phase 5: Suivi post-audit	44

2.7.1	Vue d'ensemble	44
2.7.2	Jalons obligatoires	45
2.7.3	Procédure d'escalade	45
2.7.4	Archivage du dossier d'audit	45
2.7.5	Outil Excel PT06-Suivi.xlsx	46
2.8	Synthèse des apports de MUSA	46
2.8.1	Ce que MUSA conserve de l'ANTIC	46
2.8.2	Ce que MUSA apporte par rapport à l'ANTIC	47
2.8.3	Synthèse tableau MUSA complet (Tableau 3 de référence)	48
	Conclusion du chapitre	48
	Références bibliographiques du chapitre 2	49
3	Application de MUSA à GIDOCEP et Résultats	52
	Introduction du chapitre	52
3.1	Présentation de GIDOCEP	53
3.1.1	Description générale	53
3.1.2	Architecture technique	54
3.1.3	Données manipulées	55
3.1.4	Types de dépenses et recettes traitées	56
3.1.5	Chaîne d'exécution du budget	56
3.1.6	Interface utilisateur	60
3.1.7	Gestion des utilisateurs et des droits	60
3.1.8	Sécurité de GIDOCEP	61
3.1.9	Niveau de criticité et justification	62
3.1.10	Antécédents d'audit	62
3.1.11	Justification du cas d'étude	63
3.2	Déroulement de l'audit	64
3.2.1	Phase 1 : Initiation, cadrage et préparation	65
3.2.2	Phase 2 : Audit sur le terrain	69
3.2.3	Sous-phase 2c : Analyse des risques et évaluation de la maturité	86

3.2.4	Phase 3 : Analyse, métriques et rapport	91
3.2.5	Phase 4 : Clôture et diffusion	94
3.2.6	Phase 5 : Suivi post-audit	95
	Synthèse des résultats de l’audit	96
	Conclusion du chapitre	96
	Références bibliographiques du chapitre 3	97
	Conclusion générale	99
	Annexes	102
	A Points de contrôle ISO/IEC 27001:2022 (Annexe A)	103
	Annexe A : Points de contrôle ISO/IEC 27001:2022	103
	B Checklist OWASP ASVS v4.0.3 ; 14 catégories	110
	Annexe B : Checklist OWASP ASVS v4.0.3	110
	C Grille NIST SP 800-115 ; Méthodologie des tests de sécurité	118
	Annexe C : Grille NIST SP 800-115	118
	D Tableau de correspondance ISO 19011:2018 / Démarche ANTIC	121
	Annexe D : Correspondance ISO 19011:2018 / ANTIC	121
	E Normes IIA (IPPF) applicables à MUSA	123
	Annexe E : Normes IIA applicables à MUSA	123
	F Guide d’entretien Direction / Direction Générale	126
	Annexe F : Guide d’entretien Direction	126
	G Guide d’entretien ; Responsable technique / Développeurs	129
	Annexe G : Guide d’entretien Développeurs	129

H	Guide d’entretien Utilisateurs finaux	132
	Annexe H : Guide d’entretien Utilisateurs finaux	132
I	Modèle de rapport d’audit MUSA	134
	Annexe I : Modèle de rapport d’audit MUSA	134
J	Modèle de charte d’audit MUSA	139
	Annexe J : Modèle de charte d’audit MUSA	139
K	Formulaire de déclaration d’indépendance	142
	Annexe K : Formulaire de déclaration d’indépendance	142
L	Modèle de procès-verbal de réunion MUSA	144
	Annexe L : Modèle de PV de réunion MUSA	144

List of Figures

1.1	Positionnement de MUSA par rapport à la démarche ANTIC	13
2.1	Structure globale des cinq phases de MUSA	21
2.2	Matrice visuelle des risques $R = P \times I$ — MUSA	35
3.1	Page d'accueil et tableau de bord de GIDOCEP	53
3.2	Écran de connexion à GIDOCEP	54
3.3	Menu principal de GIDOCEP	56
3.4	Circuit long de traitement des dépenses budgétaires	58
3.5	Circuit court de traitement des dépenses budgétaires (dossiers urgents) . . .	58
3.6	Circuit de traitement des recettes budgétaires	59
3.7	Interface du module Ordonnateur	60
3.8	Journal des opérations (traçabilité des actions)	61
3.9	Planning détaillé de l'audit MUSA - GIDOCEP	64
3.10	Grille d'évaluation de la faisabilité (PT01)	65
3.11	Grille de compétences de l'équipe d'audit (PT01)	66
3.12	Déclarations d'indépendance des auditeurs (PT01)	66
3.13	Délimitation du périmètre d'audit (PT01)	67
3.14	Grille de détermination du niveau d'audit (PT01)	67
3.15	Collecte documentaire (PT01)	68
3.16	Documents reçus en Phase 1	68
3.17	Procès-verbal de la réunion de lancement (PT01)	69
3.18	Grille d'entretien Direction; Évaluations des 3 auditeurs (PT02)	70
3.19	Grille d'entretien Développeurs ; Évaluations des 3 auditeurs (PT02)	71
3.20	Grille d'entretien Utilisateurs ; Évaluations des 3 auditeurs (PT02)	72

3.21	Grille d’inspection physique (PT02)	73
3.22	Vérification de l’installation de Nmap	74
3.23	Vérification de l’installation de Nuclei	75
3.24	Lancement de l’interface OWASP ZAP	75
3.25	Résultat du scan réseau Nmap	76
3.26	Résultat du scan de vulnérabilités Nuclei	77
3.27	Tableau de bord des alertes OWASP ZAP	78
3.28	Export du rapport OWASP ZAP au format HTML	81
3.29	Changement de mot de passe dans GIDOCEP	82
3.30	Message d’expiration de session après 10 minutes d’inactivité	82
3.31	Résultat de la tentative de modification du paramètre d’accès	84
3.32	Tableau consolidé des constats (PT05)	91
3.33	Calcul des cinq métriques MUSA (PT05)	92
3.34	Plan d’actions correctives (PT05)	93
3.35	Plan de suivi post-audit (PT06)	95

List of Tables

1.1	Distinction entre vulnérabilité, menace et risque	3
1.2	Les quatre piliers de la sécurité appliqués à GIDOCEP	4
1.3	Typologie des audits de sécurité applicative	4
1.4	Justification du choix de GIDOCEP comme cas d'étude	5
1.5	Distinction classique entre les deux disciplines	5
1.6	Distinction entre mission d'audit et méthode MUSA	6
1.7	Les cinq phases de la démarche ANTIC (Conférence 29 avril 2026)	7
1.8	Les trois niveaux de l'OWASP ASVS	7
1.9	Les sept principes directeurs de l'ISO 19011:2018	8
1.10	Normes IIA intégrées dans MUSA	8
1.11	Seuils d'interprétation de l'entropie dans MUSA	9
1.12	Interprétation de l'entropie globale de l'audit	9
1.13	Travaux existants pertinents et positionnement de MUSA	10
1.14	Grille d'analyse comparative à neuf critères	10
1.15	Analyse critique : ce qui est clair / ce qui n'est pas précisé	11
1.16	Les six forces de la démarche ANTIC	11
1.17	Les neuf limites de la démarche ANTIC et réponses de MUSA	12
1.18	Comparaison ANTIC vs cinq standards (Fort / Partiel / —)	12
1.19	Positionnement de MUSA face aux trois lacunes majeures	13
2.1	Les trois niveaux d'audit MUSA	21
2.2	Les sept catégories d'artefacts MUSA	22
2.3	Les cinq métriques calculées par MUSA	22
2.4	Évaluations de l'assertion 1.1	23
2.5	Évaluations de l'assertion 1.3	23

2.6	Vue synthétique de la Phase 1	24
2.7	Grille de sélection de l'équipe d'audit MUSA	25
2.8	Structure du fichier PT01-Phase1.xlsx	26
2.9	Grille de détermination du niveau d'audit pour GIDOCEP	27
2.10	Documents demandés en Phase 1 avec critères d'acceptabilité	28
2.11	Vue synthétique de la Phase 2	30
2.12	Guides d'entretien par profil d'interlocuteur	31
2.13	Structure du fichier PT02-Audit-Orga.xlsx	32
2.14	Outils recommandés pour l'audit technique de GIDOCEP	33
2.15	Structure du fichier PT03-Audit-Technique.xlsx	34
2.16	Échelle de la probabilité P dans MUSA	35
2.17	Échelle de l'impact I dans MUSA	36
2.18	Classification du risque $R = P \times I$ et seuils de priorité	36
2.19	Grille d'évaluation de la maturité MUSA pour GIDOCEP	37
2.20	Protocole d'arbitrage MUSA	38
2.21	Structure du fichier PT04-Risques.xlsx	39
2.22	Vue synthétique de la Phase 3	40
2.23	Structure du rapport d'audit MUSA (7 sections)	41
2.24	Structure du fichier PT05-Rapport.xlsx	42
2.25	Vue synthétique de la Phase 4	42
2.26	Liste de diffusion du rapport d'audit MUSA	44
2.27	Vue synthétique de la Phase 5	44
2.28	Jalons et activités de la Phase 5	45
2.29	Structure du fichier PT06-Suivi.xlsx	46
2.30	Forces de l'ANTIC préservées dans MUSA	46
2.31	Apports de MUSA face aux neuf limites de l'ANTIC	47
2.32	Démarche MUSA complète , synthèse par phase	48
3.1	Informations générales sur GIDOCEP	54
3.2	Caractéristiques techniques de GIDOCEP	55

3.3	Types de dépenses et recettes traitées dans GIDOCEP	56
3.4	Acteurs de la chaîne d'exécution du budget	57
3.5	Grille de détermination du niveau d'audit pour GIDOCEP	62
3.6	Synthèse comparative des audits de GIDOCEP	63
3.7	Synthèse des résultats de la sous-phase 2a	74
3.8	Outils utilisés pour l'audit technique	75
3.9	Ports ouverts détectés par Nmap	76
3.10	Répartition des alertes OWASP ZAP par niveau de criticité	78
3.11	Détail des vulnérabilités identifiées par OWASP ZAP	79
3.12	Résultats du test de blocage de compte	81
3.13	Analyse de la gestion de session	83
3.14	Résultats des tests de contrôle d'accès	84
3.15	Vulnérabilités confirmées et scores de risque	86
3.16	Répartition des vulnérabilités par niveau de risque	87
3.17	Évaluation de la maturité de GIDOCEP par domaine	87
3.18	Calcul de l'entropie globale de l'audit GIDOCEP	88
3.19	Synthèse des indicateurs de la sous-phase 2c	88
3.20	Évaluations de l'assertion ASS-007	89
3.21	Métriques globales de l'audit	92
3.22	Fiche de vulnérabilité normalisée MUSA : DAST-001	93
3.23	Extrait du plan d'actions correctives	94
3.24	Diffusion du rapport d'audit	95
3.25	Jalons de la Phase 5	95
3.26	Checklist d'archivage du dossier d'audit	96
I.1	Fiche de vulnérabilité normalisée MUSA	137

Introduction Générale

LA transformation numérique des administrations publiques camerounaises s'accompagne d'une digitalisation croissante des opérations comptables. Si cette évolution améliore l'efficacité administrative, elle expose les applications à des risques de sécurité critiques.

Face à cette mutation, GIDOCEP, développée par SOLTEC, accompagne les établissements publics. L'ANTIC assure la régulation, mais sa démarche d'audit présente trois lacunes majeures :

- 1. Reproductibilité.** Deux auditeurs peuvent obtenir des résultats différents sur la même application.
- 2. Séparation artificielle.** Évaluer la sécurité sans comprendre la logique applicative produit une assurance incomplète.
- 3. Absence de mesure objective.** Aucun standard ne quantifie l'accord entre auditeurs.

Problématique de recherche

*Comment concevoir une méthode d'audit de sécurité applicative qui soit à la fois **reproductible, unifiée, mesurable et réutilisable** dans le contexte spécifique d'un éditeur de logiciel comme SOLTEC ?*

Ce mémoire propose **MUSA**, une méthode répondant à cette problématique par quatre apports originaux : la fusion des deux types d'audit, l'intégration des standards de contenu et de conduite, l'entropie de Shannon comme mesure de reproductibilité, et la production d'artefacts réutilisables.

Structure du mémoire : le Chapitre 1 pose les fondements théoriques et analyse la démarche ANTIC ; le Chapitre 2 propose la méthode MUSA ; le Chapitre 3 applique la méthode à GIDOCEP, présente les résultats de l'audit et formule les recommandations pour SOLTEC.



Techniques, État de l'Art

Démarche ANTIC



*Conceptuelles de la sécurité
de l'art des standards interna-
tionaux : analyse critique et comparative de*

Fondements théoriques, état de l'art et analyse de la démarche ANTIC

Introduction du chapitre

Ce chapitre poursuit quatre objectifs : définir les concepts clés de la sécurité applicative, justifier la fusion des deux types d'audit, dresser un état de l'art complet, et conduire une analyse détaillée de la démarche ANTIC confrontée aux standards internationaux selon une grille à neuf critères.

1.1 Concepts généraux de la sécurité applicative

1.1.1 Définitions fondamentales

La sécurité des systèmes d'information

La sécurité des systèmes d'information (SSI) désigne l'ensemble des mesures techniques, organisationnelles et humaines visant à protéger les systèmes informatiques [3]. La norme ISO/IEC 27000 énonce trois propriétés fondamentales : confidentialité, intégrité, disponibilité.

Vulnérabilité, menace et risque

Table 1.1. Distinction entre vulnérabilité, menace et risque

Concept	Définition	Exemple pour GIDOCEP
Vulnérabilité	Faiblesse ou faille	Mot de passe par défaut
Menace	Événement potentiel	Pirate, employé malveillant
Risque	Probabilité $\times$ impact	Perte estimée à 100 M FCFA

L'audit de sécurité

L'audit de sécurité est un examen méthodique et indépendant visant à évaluer le niveau de sécurité d'un système [11]. Il poursuit quatre objectifs : vérifier la conformité, identifier les vulnérabilités, évaluer les contrôles existants et formuler des recommandations.

1.1.2 Les piliers de la sécurité : la triade CIA

Table 1.2. Les quatre piliers de la sécurité appliqués à GIDOCEP

Pilier	Définition	Application à GIDOCEP
Confidentialité	Accès réservé aux autorisés	Agents habilités uniquement
Intégrité	Données non altérées	Toute modification tracée
Disponibilité	Système accessible	Fonctionnel en période de clôture
Traçabilité	Enregistrement des actions	Horodatage sur chaque opération

1.1.3 Typologie des audits et place dans le SDLC

Table 1.3. Typologie des audits de sécurité applicative

Type	Objectif	Outils	Ce qu'il détecte
SAST (statique)	Analyser le code sans exécution	SonarQube	Injections SQL, XSS
DAST (dynamique)	Tester en exécution	OWASP ZAP	Faillles runtime
Audit de config.	Vérifier les paramètres	Lynis	Ports ouverts
Audit orga.	Évaluer processus et politiques	Entretiens	Non-conformités
Audit physique	Inspecter les locaux	Grilles d'obs.	Accès non contrôlés

1.1.4 Spécificités de GIDOCEP

Table 1.4. Justification du choix de GIDOCEP comme cas d'étude

Caractéristique	Implication pour l'audit
Installation locale décentralisée	Sécurité dépendante de chaque établissement
Données sensibles (salaires, comptes)	Confidentialité et intégrité prioritaires
Mises à jour manuelles	Risque de correctifs non appliqués
Migration cloud envisagée	Audit préalable à la transition nécessaire

1.1.5 Fondements de la standardisation en cybersécurité

Selon Fenz et al. [12], la standardisation des processus d'audit poursuit cinq objectifs : reproductibilité, comparabilité, efficacité, transparence et professionnalisation. Elle opère sur quatre niveaux : processus, outils, livrables et métriques. MUSA opère simultanément sur ces quatre niveaux.

1.2 Justification du choix méthodologique

1.2.1 Distinction classique entre audit de sécurité et audit applicatif

Table 1.5. Distinction classique entre les deux disciplines

Dimension	Audit de sécurité	Audit applicatif
Question centrale	L'application est-elle protégée ?	Fait-elle ce qu'elle doit ?
Standards	ISO 27001, OWASP, NIST	ISACA, COBIT
Profil auditeur	Expert cybersécurité	Expert métier
Livrables	Rapport de vulnérabilités	Rapport de conformité fonctionnelle

1.2.2 Pourquoi fusionner dans le contexte SOLTEC

Trois raisons fondamentales justifient la fusion :

- ♦ **Inséparabilité technique.** La criticité d'une vulnérabilité dépend de la logique métier qu'elle affecte.
- ♦ **Assurance globale attendue.** Les établissements publics attendent une seule garantie : l'application gère et protège leurs données.

- ♦ **Contrainte de ressources.** Une PME ne peut financer deux missions d’audit séquentielles.

Définition Audit unifié

Un audit de sécurité applicative unifié est un examen méthodique et indépendant qui évalue simultanément la conformité fonctionnelle d’une application et l’adéquation de ses contrôles de sécurité, à partir d’artefacts standardisés et réutilisables.

Table 1.6. Distinction entre mission d’audit et méthode MUSA

Dimension	Mission d’audit	Méthode MUSA
Nature	Prestation ponctuelle	Ensemble d’artefacts et procédures
Durée de vie	Limitée à la mission	Réutilisable à chaque cycle
Généralisation	Spécifique à l’audit	Applicable à toute application
Valeur produite	Une évaluation	Un capital méthodologique durable

1.3 État de l’art

1.3.1 La démarche d’audit de l’ANTIC

Présentation de l’ANTIC

L’ANTIC a été créée par décret n°2002/092 du 27 mars 2002 [17]. Lors de la Conférence des cabinets agréés (Yaoundé, 29 avril 2026)¹, le responsable de la planification a présenté la démarche en **cinq phases**.

¹Source primaire non publiée , notes de terrain et enregistrements audio collectés par l’auteur.

Table 1.7. Les cinq phases de la démarche ANTIC (Conférence 29 avril 2026)

#	Phase	Activités clés	Livrables
1	Correspondence Follow-up	Notification, confirmation, équipe 2–4 membres	Lettre de mission
2	Mission Preparation	Collecte documentaire, recon- naissance passive	Charte d’audit
3	On-Site Audit	Audit orga, physique, tech- nologique, risques	Matrice des risques
4	Reporting & Closing	Pré-clôture, rapport transmis le jour même	Rapport + plan d’actions
5	Post-Audit	Suivi recommandations, statis- tiques	Rapports de suivi

L’ANTIC a explicitement cité l’ISO 19011 : “*We need a repeatable methodology [. . .] aligned to international standards. One of which is ISO 19011 that talks on audit methodology.*”²

1.3.2 Standards de contenu : ISO 27001, OWASP ASVS, NIST SP 800-115

ISO/IEC 27001:2022

93 contrôles répartis en 4 domaines : organisationnel (37), humain (8), physique (14) et technologique (34).

OWASP ASVS v4.0.3

Table 1.8. Les trois niveaux de l’OWASP ASVS

Niveau	Type d’application	Contrôles	Profondeur
1 - Basique	Applications internes	40	Tests automatiques
2 - Standard	Données sensibles	100	Tests manuels
3 - Approfondi	Applications critiques	150	Tests exhaustifs

NIST SP 800-115

Méthodologie en trois phases : planification, exécution et post-exploitation. Recommande l’usage d’au moins deux outils de scan , pratique reprise dans MUSA.

²29 avril 2026 , source primaire non publiée.

1.3.3 L'ISO 19011:2018 : standard de management des audits

Table 1.9. Les sept principes directeurs de l'ISO 19011:2018

#	Principe	Application dans MUSA
1	Intégrité	Déclaration d'indépendance signée
2	Présentation impartiale	Forces + non-conformités inclus
3	Conscience professionnelle	Grille de compétences pondérée
4	Confidentialité	Formalisée dès la réunion d'ouverture
5	Indépendance	Charte signée, conflits déclarés
6	Preuves	Papiers PTxx, archivage 5 ans
7	Risques	Cotation $P \times I$ guidant le programme

1.3.4 Les normes IIA : gouvernance et déontologie

Table 1.10. Normes IIA intégrées dans MUSA

Norme	Contenu	Intégration MUSA
1100 - Indépendance	Objectivité de l'auditeur	Déclaration signée avant mission
2200 - Planification	Objectifs SMART	Plan + programme obligatoires
2330 - Documentation	Papiers de travail tracés	PTxx, archivage 5 ans
2340 - Supervision	Revue lead auditor	Revue quotidienne
2500 - Suivi obligatoire	Recommandations suivies	Revue trimestrielles
2600 - Escalade	Risque résiduel	Procédure en 3 niveaux

1.3.5 L'entropie de Shannon : mesure de l'incertitude en audit

Origine et définition

L'entropie de Shannon [10], issue de la théorie de l'information, est l'innovation la plus originale de MUSA.

Entropie de Shannon

Soit n états possibles de probabilités p_i . L'entropie H est :

$$H = - \sum_{i=1}^n p_i \cdot \log_2(p_i)$$

H est maximale quand tous les états sont équiprobables, et nulle quand un seul état a une probabilité de 1.

Application dans MUSA

Plusieurs auditeurs évaluent chaque assertion : Conforme (C), Non conforme (NC) ou Zone Grise (ZG). L'entropie de l'assertion i est :

$$H_i = -(p_C \log_2 p_C + p_{NC} \log_2 p_{NC} + p_{ZG} \log_2 p_{ZG})$$

L'entropie globale de la mission est :

$$H_{\text{global}} = \frac{1}{N} \sum_{i=1}^N H_i$$

Table 1.11. Seuils d'interprétation de l'entropie dans MUSA

Valeur H_i	Interprétation	Action
$H_i < 0,5$	Accord total	Constat validé directement
$0,5 \leq H_i < 1,0$	Incertitude modérée	Discussion en équipe
$H_i \geq 1,0$	Zone grise critique	Réunion d'arbitrage

Table 1.12. Interprétation de l'entropie globale de l'audit

H_{global}	Interprétation
$< 0,5$	Audit fiable, bonne reproductibilité
$[0,5; 0,8]$	Audit acceptable, quelques points à clarifier
$> 0,8$	Audit à revoir, trop d'incertitudes

1.3.6 Travaux existants et grille d'analyse

Table 1.13. Travaux existants pertinents et positionnement de MUSA

Auteur(s)	Année	Contribution	Limite vs MUSA
Bitlisli Erdivan	2024	SecureVSE, petites entités	Pas de reproductibilité inter-auditeurs
Humphreys	2016	Guide ISO 27001	Pas de conduite (ISO 19011)
OWASP Foundation	2021	Standard ASVS	Contenu uniquement
CHAI	2014	Guide SI, 8 domaines	Non spécifique au Cameroun

Table 1.14. Grille d'analyse comparative à neuf critères

#	Critère	Description
C1	Ancrage local	Contexte réglementaire camerounais
C2	Couverture des axes	Orga, humain, physique, technologique
C3	Profondeur technique	Niveaux de détail des contrôles
C4	Formalisation	Guides, checklists, papiers de travail
C5	Reproductibilité	Mesure accord inter-auditeurs
C6	Métriques	Taux de conformité, score de risque
C7	Gouvernance	Indépendance, suivi, escalade
C8	Réutilisabilité	Artefacts généralisables
C9	Fusion séc.+applic.	Évaluation simultanée des deux dimensions

1.4 Analyse de la démarche ANTIC

1.4.1 Analyse détaillée phase par phase

Table 1.15. Analyse critique : ce qui est clair / ce qui n'est pas précisé

Phase	Ce qui est clair	Ce qui n'est pas précisé
1 Engagement	Notification, équipe, point focal	Grille compétences, déclaration indépendance
2 Préparation	Collecte doc., reconnaissance	Programme de travail formalisé
3a Organisationnel	Thèmes d'entretien	Guide d'entretien standardisé
3b Physique	Zones à inspecter	Grille d'inspection
3c Technologique	Deux outils minimum	Méthodologie, checklist technique
3d Risques	Matrice $P \times I$, maturité	Méthode reconnue, seuils, escalade
4 Rapport	Pré-clôture, 2 semaines	Modèle imposé, métriques, PV clôture
5 Suivi	Accompagnement prévu	Procédure formelle, archivage

1.4.2 Synthèse des forces

Table 1.16. Les six forces de la démarche ANTIC

Force	Importance et valeur
Ancrage local fort	Recommandations réalistes, connaissance du terrain camerounais
Intégration loi 2010/012	Recommandations juridiquement opposables
Vision globale (4 axes)	Aucun angle mort dans l'évaluation
Bonne acceptation	Collaboration active des administrations
Accompagnement post-audit	Transfert de compétences, vérification réelle
Approche par les risques	Concentration des ressources sur l'essentiel

1.4.3 Synthèse des neuf limites

Table 1.17. Les neuf limites de la démarche ANTIC et réponses de MUSA

#	Limite	Conséquence	Réponse MUSA
L1	Manque de formalisation	Qualité variable	Procédures détaillées
L2	Faible reproductibilité	Résultats non comparables	Entropie de Shannon
L3	Absence de métriques	Pilotage subjectif	Taux conformité, score risque
L4	Pas de standards intl	Non-reconnaissance externe	ISO, OWASP, NIST
L5	Profondeur variable	Inefficacité	3 niveaux OWASP ASVS
L6	Lacunes techniques	Dépendance compétences	Checklist 14 catégories
L7	Absence ISO 19011	Conduite non structurée	5 phases formalisées
L8	Absence gouvernance IIA	Audit potentiellement biaisé	Normes IIA 1100, 2500, 2600
L9	Pas de mesure reprod.	Incertitude non quantifiable	Entropie H par assertion

1.5 Comparaison avec les standards internationaux

1.5.1 Tableau comparatif général

Table 1.18. Comparaison ANTIC vs cinq standards (Fort / Partiel / —)

Critère	ANTIC	ISO 27001	OWASP ASVS	NIST 115	800-115	ISO 19011	IIA
C1 Ancrage local	Fort	—	—	—	—	—	—
C2 Couverture	Fort	Fort	Partiel	Partiel	—	—	—
C3 Profondeur	—	Partiel	Fort	Fort	—	—	—
C4 Formalisation	Partiel	Fort	Fort	Fort	Fort	Fort	Fort
C5 Reproductibilité	—	Partiel	Partiel	Partiel	Partiel	Partiel	Partiel
C6 Métriques	Partiel	Fort	Fort	Partiel	—	—	Partiel
C7 Gouvernance	Partiel	Partiel	—	—	Fort	Fort	Fort
C8 Réutilisabilité	—	Partiel	Partiel	Partiel	Partiel	Partiel	Partiel
C9 Fusion séc.+applic.	—	—	—	—	—	—	—

Trois constats : (1) seule l’ANTIC est forte sur C1 , ancrage irremplaçable ; (2) aucun standard ne couvre tous les critères ; MUSA est donc une méthode hybride justifiée ; (3) **C9 est absent de tous les référentiels** , c’est l’apport le plus original de MUSA.

1.5.2 Positionnement de MUSA

Table 1.19. Positionnement de MUSA face aux trois lacunes majeures

Lacune	Réponse de MUSA
Pas de méthode unifiée sécurité+applicatif	Fusion délibérée, justifiée par le contexte SOLTEC
Pas de mesure quantitative de reproductibilité	Entropie de Shannon H par assertion et H_{global}
Pas de méthode réutilisable	Checklists Excel, PTxx, modèles de rapport 7 sections

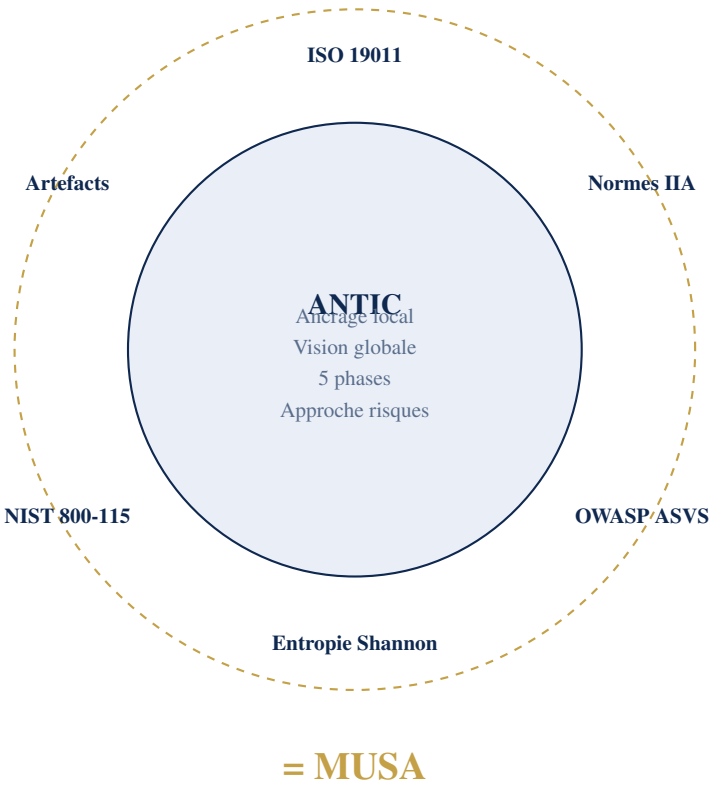


Figure 1.1. Positionnement de MUSA par rapport à la démarche ANTIC

Conclusion du chapitre

Ce chapitre a posé les fondements théoriques et conduit une analyse systématique de la démarche ANTIC. Trois apports originaux émergent : (1) la justification de la fusion audit

sécurité + applicatif dans le contexte d’audit interne chez un développeur ; (2) l’introduction de l’entropie de Shannon comme mesure quantitative inédite de la reproductibilité inter-auditeurs ; (3) l’identification de trois nouvelles limites de l’ANTIC non documentées dans la littérature , absence d’alignement ISO 19011, absence de gouvernance IIA, absence de mesure de la reproductibilité. Le chapitre 2 présentera la méthode MUSA dans sa version complète, en justifiant chaque choix par les écarts identifiés.

Références bibliographiques du chapitre 1

Bibliography

- [1] ANTIC. (2020). *Référentiel interne d'audit de sécurité des systèmes d'information*. Agence Nationale des Technologies de l'Information et de la Communication, Yaoundé.
- [2] ANTIC. (2026). *Méthodologie d'audit de sécurité des systèmes d'information ; Présentation aux cabinets agréés* [Source primaire non publiée]. Conférence ANTIC, Yaoundé, Cameroun, 29 avril 2026.
- [3] ISO/IEC 27000:2018. *Technologies de l'information , Techniques de sécurité , Vue d'ensemble et vocabulaire*. Organisation Internationale de Normalisation.
- [4] ISO/IEC 27001:2022. *Sécurité de l'information ; Exigences*. Organisation Internationale de Normalisation.
- [5] ISO 19011:2018. *Lignes directrices pour l'audit des systèmes de management*. Organisation Internationale de Normalisation.
- [6] Institute of Internal Auditors. (2017). *International Professional Practices Framework (IPPF)*. The IIA, Lake Mary, FL.
- [7] OWASP Foundation. (2021). *Application Security Verification Standard v4.0.3*. Open Web Application Security Project.
- [8] Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *NIST SP 800-115: Technical Guide to Information Security Testing and Assessment*. National Institute of Standards and Technology.
- [9] NIST. (2012). *SP 800-30 Rev.1: Guide for Conducting Risk Assessments*. National Institute of Standards and Technology.
- [10] Shannon, C. E. (1948). A Mathematical Theory of Communication. *Bell System Technical Journal*, 27(3), 379–423.
- [11] ISACA. (2020). *CISA Review Manual*. Information Systems Audit and Control Association.

-
- [12] Fenz, S., Heurix, J., Neubauer, T., & Pechstein, F. (2014). Current Challenges in Information Security Risk Management. *Information Management & Computer Security*, 22(5), 410–430.
- [13] Dhillon, G., & Backhouse, J. (2000). Information System Security Management in the New Millennium. *Communications of the ACM*, 43(7), 125–128.
- [14] Stallings, W. (2018). *Cryptography and Network Security* (7th ed.). Pearson Education.
- [15] Kim, G., Humble, J., Debois, P., & Willis, J. (2016). *The DevOps Handbook*. IT Revolution Press.
- [16] Microsoft. (2010). *Security Development Lifecycle ; Process Guidance*. Microsoft Corporation.
- [17] République du Cameroun. (2002). *Décret n°2002/092 du 27 mars 2002 portant création de l'ANTIC*. Présidence de la République.
- [18] Humphreys, E. (2016). *Implementing the ISO/IEC 27001 ISMS Standard*. Artech House.
- [19] Bitlisli Erdivan, P. (2024). *An Information Security Assessment Model for Very Small Entities*. Master thesis, Middle East Technical University.
- [20] CHAI. (2014). *Guide d'audit des systèmes d'information* (v1.0). Secrétariat général du CHAI, France.

MUSA : Méthode Unifiée de Sécurité Applicative

*détail la méthode MUSA :
ses cinq phases opérationnelles,
ses métriques et l'ensemble des*

Proposition de MUSA : Méthode Unifiée d'Audit de Sécurité Applicative

Introduction du chapitre

Le chapitre précédent a démontré, à travers une analyse systématique de la démarche ANTIC et une comparaison avec cinq standards internationaux, qu'aucun référentiel existant ne répond simultanément aux trois lacunes fondamentales identifiées : le manque de reproductibilité, la séparation artificielle entre sécurité et fonctionnement applicatif, et l'absence de mesure objective de la qualité de l'audit. Il a également montré que l'apport le plus original demandé, l'évaluation simultanée de la sécurité et du fonctionnement est absent de l'ensemble des référentiels analysés.

Ce chapitre présente **MUSA** (*Méthode Unifiée d'Audit de Sécurité Applicative*), la méthode qui répond point par point à ces lacunes. La présentation suit une progression logique : des principes fondateurs vers les détails opérationnels, des structures générales vers les outils concrets. Chaque choix méthodologique est ancré dans les écarts identifiés au chapitre 1.

Ce chapitre est structuré en sept sections : (1) les principes directeurs, (2) la structure globale de la méthode, (3) à (6) la description détaillée des quatre phases, et (7) la synthèse des apports.

2.1 Principes directeurs de MUSA

Avant toute description procédurale, il est essentiel de poser les principes qui gouvernent chaque décision méthodologique de MUSA. Ces principes ne sont pas des platitudes : chacun répond à une limite concrète de la démarche ANTIC identifiée au chapitre 1.

2.1.1 Principe 1 - Reproductibilité mesurable

Problème adressé : Limite L2 et L9 (tableau 1.17). Deux auditeurs appliquant la même démarche ANTIC peuvent obtenir des résultats fondamentalement différents.

Réponse de MUSA : Toute appréciation subjective est convertie en donnée numérique :

l'entropie de Shannon H_i mesure le niveau d'accord entre auditeurs sur chaque assertion. Aucun constat ne peut être validé directement si $H_i \geq 0,5$. La reproductibilité n'est pas un objectif déclaratif : c'est une valeur calculée, traçable, archivée dans les papiers de travail.

2.1.2 Principe 2 - Fusion délibérée sécurité + applicatif

Problème adressé : Critère C9 (tableau 1.18), absent de tous les référentiels existants. Dans le contexte d'audit interne chez un développeur, la sécurité et le fonctionnement sont indissociables.

Réponse de MUSA : Chaque phase de l'audit couvre simultanément les deux dimensions. Les checklists intègrent à la fois les contrôles de sécurité (OWASP ASVS) et les critères de conformité fonctionnelle. Un même papier de travail documente une vulnérabilité de sécurité *et* son impact sur la logique métier de l'application.

Précision sur la mise en œuvre de la fusion La fusion des audits de sécurité et fonctionnel dans MUSA repose sur une approche d'**équipe pluridisciplinaire**. L'équipe d'audit est composée d'au moins :

- ◆ **Un expert en sécurité applicative** : responsable des tests techniques (SAST, DAST, configuration, tests d'intrusion).
- ◆ **Un expert métier** : responsable de la validation des flux fonctionnels et de la logique comptable de GIDOCEP.

Ces deux profils travaillent en binôme sur les mêmes artefacts (checklists, papiers de travail), chacun apportant sa perspective spécifique. La *fusion* ne signifie pas qu'une seule personne doit posséder les deux compétences, mais que les deux expertises sont **intégrées dans un même processus d'audit** et aboutissent à un **rapport unique**.

Cette approche est justifiée par le contexte SOLTEC : une PME ne peut financer deux missions d'audit séparées, mais peut en revanche mobiliser deux experts internes ou externes pour une mission unique.

2.1.3 Principe 3 - Formalisation complète des procédures

Problème adressé : Limite L1 (manque de formalisation). La qualité de l'audit ANTIC dépend de la compétence personnelle de l'auditeur, non de la méthode.

Réponse de MUSA : Chaque activité de chaque phase est décrite avec un niveau de détail tel qu'un auditeur compétent mais ne connaissant pas MUSA puisse l'exécuter correctement à partir des seuls artefacts de la méthode. Aucune étape ne laisse de place à l'interprétation discrétionnaire.

2.1.4 Principe 4 - Profondeur adaptable à la criticité

Problème adressé : Limite L5 (profondeur variable). L'ANTIC applique le même niveau d'analyse indépendamment de la criticité de l'application.

Réponse de MUSA : Trois niveaux d'audit sont définis, alignés sur l'OWASP ASVS : basique (40 contrôles), standard (100 contrôles), approfondi (150 contrôles). Le niveau est déterminé en phase 1 selon une grille de criticité objective. GIDOCEP est évalué au niveau 2 (standard).

2.1.5 Principe 5 - Gouvernance rigoureuse

Problème adressé : Limites L7 et L8 (absence ISO 19011 et gouvernance IIA). L'ANTIC aspire à l'ISO 19011 sans l'avoir formalisé ; les normes IIA sont absentes.

Réponse de MUSA : Chaque phase de MUSA correspond à une phase de l'ISO 19011. Chaque livrable formel (PV, déclaration d'indépendance, papiers de travail) répond à une norme IIA spécifique. La gouvernance n'est pas un ajout : elle est intégrée dans la structure même de la méthode.

2.1.6 Principe 6 - Réutilisabilité systématique

Problème adressé : Limite L8 (absence de méthode réutilisable). Chaque mission ANTIC produit un rapport ponctuel qui ne capitalise pas.

Réponse de MUSA : MUSA ne produit pas un rapport : elle produit un **capital méthodologique**. Les checklists, papiers de travail, matrices de risques et modèles de rapport sont conçus pour être réutilisés à chaque cycle d'audit et généralisés à d'autres applications. La qualité s'améliore d'un cycle à l'autre car les artefacts sont enrichis.

2.1.7 Principe 7 - Ancrage local préservé

Problème adressé : Il serait contre-productif de remplacer la démarche ANTIC par un standard international inadapté au contexte camerounais.

Réponse de MUSA : MUSA *enrichit* la démarche ANTIC, elle ne la remplace pas. La structure en cinq phases, l'ancrage réglementaire (loi n°2010/012), la vision globale (organisationnel + humain + physique + technologique), l'approche par les risques $P \times I$ et l'accompagnement post-audit sont intégralement conservés.

2.2 Structure globale de MUSA

2.2.1 Vue d'ensemble architecturale

MUSA s'organise en **cinq phases séquentielles**, chacune dotée d'activités détaillées, de livrables normalisés, de métriques calculées et d'outils Excel dédiés. La figure 2.1 illustre cette organisation.

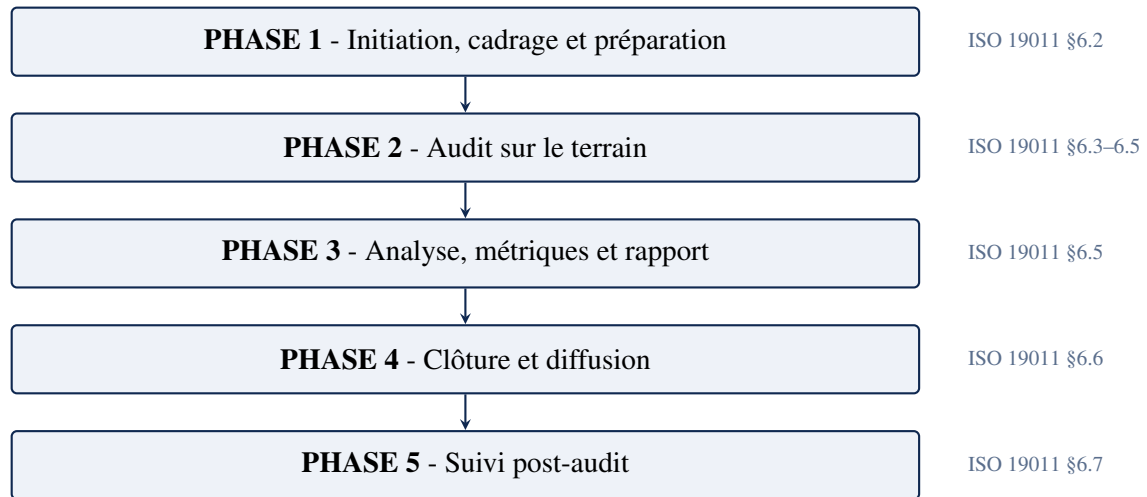


Figure 2.1. Structure globale des cinq phases de MUSA

2.2.2 Les niveaux d'audit MUSA

La profondeur de chaque audit est déterminée en Phase 1 selon le tableau suivant :

Table 2.1. Les trois niveaux d'audit MUSA

Niveau	Type d'application	Contrôles OWASP	Durée estimée	es-	Critères de déclenchement
1 - Basique	Applications internes sans données sensibles	40	3–5 jours		Aucune donnée financière ni personnelle, faible impact
2 - Standard	Applications sensibles avec données financières	100	7–10 jours		Données personnelles ou financières, impact modéré
3 - Approfondi	Applications critiques, forte exposition	150	15–20 jours		Données très sensibles, obligations réglementaires, accès Internet

Application à GIDOCEP : GIDOCEP gère les opérations comptables des établissements publics camerounais, données financières sensibles, utilisateurs identifiés, obligations réglementaires ANTIC. Elle est classée **niveau 2 (Standard)**.

2.2.3 Les artefacts MUSA

MUSA produit sept catégories d'artefacts opérationnels :

Table 2.2. Les sept catégories d'artefacts MUSA

#	Artefact	Format	Contenu et usage
A1	Charte d'audit	Document Word/PDF	Périmètre, objectifs, niveau, composition équipe, signée par les deux parties
A2	Déclaration d'indépendance	Formulaire PDF	Conflicts d'intérêts déclarés, signée par chaque auditeur (IIA 1100)
A3	Programme de travail	Fichier Excel (PT00)	Planning détaillé, tâches, responsables, jalons
A4	Papiers de travail (PTxx)	Fichiers Excel codés	Un fichier par phase : PT01 (phase 1), PT02 (phase 2a), PT03 (phase 2b), PT04 (phase 2c), PT05 (phase 3)
A5	Checklists techniques	Fichiers Excel dédiés	CL-ISO27001, CL-OWASP-N2, CL-NIST avec colonnes évaluation + preuve
A6	Matrice des risques	Fichier Excel (MR)	Vulnérabilités, cotation $P \times I$, priorisation, responsable, échéance
A7	Rapport d'audit	Document Word/PDF	7 sections normalisées, métriques calculées, signé lead auditor

2.2.4 Les métriques MUSA

MUSA calcule cinq indicateurs quantitatifs pour chaque mission :

Table 2.3. Les cinq métriques calculées par MUSA

Métrique	Formule	Interprétation
Taux de conformité global	$TC = \frac{N_C}{N_{total}} \times 100$	Pourcentage des contrôles jugés conformes
Taux par niveau OWASP	$TC_n = \frac{N_{C,n}}{N_n} \times 100$	Conformité pour le niveau n (1, 2 ou 3)
Score de risque moyen	$\bar{R} = \frac{\sum R_i}{N_{vuln}}$	Risque moyen, avec $R_i = P_i \times I_i$
Entropie par assertion	$H_i = -\sum p_k \log_2 p_k$	Niveau d'accord entre auditeurs
Entropie globale	$H_{global} = \frac{1}{N} \sum_{i=1}^N H_i$	Reproductibilité globale de la mission

Exemple concret de calcul de l'entropie

Pour illustrer le calcul de l'entropie de Shannon, prenons deux exemples issus de l'audit de GIDOCEP.

Exemple 1 : Accord fort Assertion 1.1 : Politique de sécurité formelle et signée

Table 2.4. Évaluations de l'assertion 1.1

Assertion	Aud1	Aud2	Aud3	Hi
Politique de sécurité formelle et signée	NC	NC	NC	0,00

Calcul :

- ♦ $pC = 0/3 = 0,00$
- ♦ $pNC = 3/3 = 1,00$
- ♦ $pZG = 0/3 = 0,00$
- ♦ $H = -(1,00 \times \log_2(1,00)) = 0,00$

Interprétation : Accord fort → constat validé directement.

Exemple 2 : Zone grise Assertion 1.3 : RSSI identifié avec fiche de poste

Table 2.5. Évaluations de l'assertion 1.3

Assertion	Aud1	Aud2	Aud3	Hi
RSSI identifié avec fiche de poste	C	NC	C	0,91

Calcul :

- ♦ $pC = 2/3 = 0,67$
- ♦ $pNC = 1/3 = 0,33$
- ♦ $pZG = 0/3 = 0,00$
- ♦ $H = -(0,67 \times \log_2(0,67) + 0,33 \times \log_2(0,33))$
- ♦ $H = -(0,67 \times (-0,58) + 0,33 \times (-1,58)) = 0,91$

Interprétation : $0,5 \leq H < 1,0 \rightarrow$ Discussion requise.

2.3 Phase 1 : Initiation, cadrage et préparation

2.3.1 Vue d'ensemble de la phase

La Phase 1 est le fondement de toute la mission. Une préparation insuffisante entraîne invariablement des lacunes dans les phases suivantes : périmètre mal délimité, équipe inadaptée, documents manquants. Cette phase est alignée sur l'ISO 19011 §6.2 (déclenchement) et §6.3 (préparation).

Table 2.6. Vue synthétique de la Phase 1

Élément	Détail
Durée typique	5 à 7 jours ouvrables
Normes de référence	ISO 19011 §6.2–6.3, IIA 2200, IIA 2210, IIA 2230
Artefacts produits	Charte d'audit (A1), Déclaration d'indépendance (A2), Programme de travail PT00 (A3)
Outil Excel dédié	PT01-Phase1.xlsx
Réunion formelle	Réunion de lancement avec PV signé
Critère de clôture	Programme de travail approuvé par le commanditaire

2.3.2 Étape 1.1 : Déclenchement et contact initial

Activités

Le déclenchement de l'audit intervient sur demande formelle du commanditaire (direction générale de SOLTEC ou point focal ANTIC). Les activités suivantes sont menées :

- ◆ **Réception et analyse du mandat :** l'auditeur en charge prend connaissance de la demande, identifie l'application concernée (GIDOCEP), les systèmes impliqués et les parties prenantes.
- ◆ **Évaluation de la faisabilité :** vérification que les ressources humaines, matérielles et temporelles sont disponibles. Critères vérifiés : compétences nécessaires disponibles dans l'équipe, fenêtre temporelle compatible avec les contraintes de SOLTEC, accès possible aux systèmes.
- ◆ **Contact préliminaire avec l'audité :** le lead auditor prend contact avec le point focal de SOLTEC pour confirmer la disponibilité et annoncer le début de la mission.
- ◆ **Sélection de l'équipe d'audit :** constitution de l'équipe selon une grille de compétences pondérée (cf. tableau 2.7).

Grille de sélection de l'équipe

Table 2.7. Grille de sélection de l'équipe d'audit MUSA

Compétence requise	Pondération	Niveau min.	Justification
Sécurité applicative	30 %	Confirmé	Tests OWASP, injection, gestion session
Audit de SI (méthodologie)	25 %	Confirmé	Conduite d'audit selon ISO 19011
Développement logiciel	20 %	Intermédiaire	Compréhension de la logique GIDOCEP
Comptabilité / métier	15 %	Notions	Évaluer la conformité fonctionnelle
Réglementation Cameroun	TIC 10 %	Notions	Loi 2010/012, référentiel ANTIC

Déclaration d'indépendance (Artefact A2)

Avant toute activité sur le terrain, chaque membre de l'équipe signe une **déclaration d'indépendance** (IIA 1100). Ce document formalise :

- ♦ l'absence de lien familial ou financier avec SOLTEC ou les développeurs de GIDOCEP ;
- ♦ l'absence de participation antérieure au développement ou à la maintenance de GIDOCEP ;
- ♦ l'engagement à signaler tout conflit d'intérêts surgissant en cours de mission ;
- ♦ la signature datée de l'auditeur et du lead auditor.

Outil Excel - PT01-Phase1.xlsx

La Phase 1 est documentée dans le fichier **PT01-Phase1.xlsx**, qui comprend les onglets suivants :

Table 2.8. Structure du fichier PT01-Phase1.xlsx

Onglet	Contenu
Faisabilité	Grille d'évaluation de la faisabilité (ressources, compétences, délais)
Équipe	Composition de l'équipe avec grille de compétences pondérée et scores
Indépendance	Formulaire de déclaration d'indépendance (une ligne par auditeur)
Périmètre	Délimitation du périmètre (inclus / exclus) avec justification
Criticité	Grille de détermination du niveau d'audit (1, 2 ou 3)
Planning	Programme de travail détaillé par phase, tâche, responsable, durée
Documents demandés	Liste des documents à collecter avec critères d'acceptabilité
PV Lancement	Modèle de procès-verbal de la réunion de lancement

2.3.3 Étape 1.2 : Définition du périmètre et du niveau d'audit

Délimitation du périmètre

Le périmètre de l'audit doit être défini avec précision avant toute activité sur le terrain. Pour GIDOCEP, le périmètre inclut :

- ♦ **Inclus** : l'application GIDOCEP dans sa version déployée en production, le serveur hébergeant l'application, la base de données associée, les interfaces utilisateurs, les API internes.
- ♦ **Exclus** : l'infrastructure réseau de l'établissement client, les postes de travail des utilisateurs finaux (sauf échantillon), les applications tierces non développées par SOLTEC.

Grille de détermination du niveau

Table 2.9. Grille de détermination du niveau d’audit pour GIDOCEP

Critère	Réponse	Score	Justification
Données financières traitées	Oui	+2	Ecritures comptables publiques
Données personnelles	Oui	+1	Identités des agents comptables
Accès Internet direct	Non	0	Application intranet
Obligations réglementaires	Oui	+1	Audit ANTIC obligatoire
Impact si compromission	Élevé	+2	Finances publiques camerounaises
Migrations prévues	Oui	+1	Transition cloud envisagée
Score total		7	Niveau 2 (Standard) , seuil : 5–8

2.3.4 Étape 1.3 : Collecte documentaire préalable

La collecte documentaire préalable (phase passive) permet de construire une compréhension du contexte avant d’aller sur le terrain. Elle suit des **critères d’acceptabilité** documentés dans l’onglet Documents demandés du fichier PT01.

Critères d’acceptabilité des documents

Tout document collecté est évalué selon trois critères :

- ♦ **Fraîcheur** : le document doit dater de moins de 12 mois pour les politiques et moins de 6 mois pour les configurations.
- ♦ **Authenticité** : le document doit être signé ou validé par un responsable identifié chez SOLTEC.
- ♦ **Complétude** : un document incomplet est signalé comme *partiellement acceptable* et déclenche une demande complémentaire.

Liste des documents demandés

Table 2.10. Documents demandés en Phase 1 avec critères d'acceptabilité

Document	Catégorie	Fraîcheur max.	Critère de validation
Politique de sécurité	Organisationne	12 mois	Signée DG
Charte informatique	Organisationne	24 mois	Signée RH + DSI
Schéma d'architecture GIDO-CEP	Technique	6 mois	Validé lead dev
Inventaire des composants tiers	Technique	6 mois	Liste avec versions
Procédures de gestion des incidents	Opérationnel	12 mois	Numérotée, datée
Rapports d'audits antérieurs	Historique	3 ans	Officiel ANTIC ou tiers
Manuel d'installation / déploiement	Technique	12 mois	Version cohérente avec prod.
Procédure de gestion des accès	Organisationne	12 mois	Signée responsable SI
Plan de reprise d'activité (PRA)	Opérationnel	12 mois	Testé, daté
Journal des modifications récentes	Technique	3 mois	Système de versioning

2.3.5 Étape 1.4 : Réunion de lancement

La réunion de lancement est une exigence formelle de l'ISO 19011 §6.4.2. Elle ne peut pas être remplacée par un échange de courriels.

Participants obligatoires

- ✦ Le lead auditor et l'équipe d'audit complète ;
- ✦ Le directeur général de SOLTEC ou son représentant mandaté ;
- ✦ Le responsable technique de GIDOCEP ;
- ✦ Le point focal ANTIC (si audit externe).

Ordre du jour obligatoire

1. Présentation de l'équipe d'audit et de ses mandats ;
2. Confirmation du périmètre et du niveau d'audit ;
3. Présentation du calendrier et des jalons ;
4. Définition des canaux de communication et des points de contact ;
5. Règles de confidentialité et de diffusion des résultats ;
6. Présentation des documents demandés et des délais de fourniture ;
7. Questions et clarifications ;
8. Signature du PV de lancement par toutes les parties.

Livrables de la Phase 1

Livrables obligatoires de la Phase 1

1. **Charte d'audit signée (A1)** : périmètre, niveau, calendrier, composition équipe
2. **Déclarations d'indépendance signées (A2)** : une par auditeur
3. **Programme de travail approuvé (PT00)** : planning détaillé par tâche
4. **PV de réunion de lancement signé** (onglet PV Lancement du PT01)
5. **Dossier documentaire collecté** (avec grille de validation des documents)

2.4 Phase 2 : Audit sur le terrain

2.4.1 Vue d'ensemble

La Phase 2 est la phase centrale de l'audit. Elle se décompose en **trois sous-phases** menées de manière coordonnée, chacune dotée de son propre outil Excel :

- ◆ **Sous-phase 2a** : Audit organisationnel et physique
- ◆ **Sous-phase 2b** : Audit technique (SAST, DAST, configuration)
- ◆ **Sous-phase 2c** : Analyse des risques et évaluation de la maturité

Table 2.11. Vue synthétique de la Phase 2

Élément	Détail
Durée typique	7 à 10 jours ouvrables (niveau 2)
Normes de référence	ISO 19011 §6.4–6.5, IIA 2300–2340, OWASP ASVS N2, NIST SP 800-115
Outils Excel dédiés	PT02-Audit-Orga.xlsx, PT03-Audit-Technique.xlsx, PT04-Risques.xlsx
Réunion formelle d'ouverture	PV signé avant toute activité sur le terrain
Règle de preuve	Aucune déclaration n'est acceptée sans preuve documentaire

2.4.2 Réunion d'ouverture

Avant de débiter les activités sur le terrain, une **réunion d'ouverture formelle** est tenue (ISO 19011 §6.4.2). Elle diffère de la réunion de lancement : celle-ci a eu lieu avant le terrain, pour poser les bases ; la réunion d'ouverture marque le début concret des investigations.

Durée : 30 à 45 minutes. **PV signé** : obligatoire.

Points couverts :

1. Confirmation que le périmètre et les objectifs n'ont pas changé ;
2. Présentation du calendrier détaillé des activités du terrain ;
3. Confirmation des interlocuteurs disponibles et de leur plage horaire ;
4. Rappel des règles de confidentialité ;
5. Rappel que les déclarations verbales ne constituent pas des preuves ;
6. Questions des parties.

2.4.3 Sous-phase 2a : Audit organisationnel et physique

Objectifs

Cette sous-phase évalue les dimensions organisationnelle, humaine et physique de la sécurité de GIDOCÉP, conformément à la vision globale de l'ANTIC (quatre axes) et aux contrôles ISO 27001 domaines 5, 6 et 7.

Entretiens standardisés

Les entretiens sont menés avec trois catégories d'interlocuteurs. Des guides d'entretien distincts sont utilisés pour chaque catégorie (annexes F, G, H).

Table 2.12. Guides d'entretien par profil d'interlocuteur

Profil	Thèmes principaux	Durée	Preuves demandées
Direction / DG	Politique de sécurité, budget, gouvernance	45–60 min	Politique signée, budget alloué
Responsable technique / Devs	Pratiques de codage, gestion des accès, tests	60–90 min	Code, procédures, historique des tests
Utilisateurs finaux	Pratiques d'authentification, comportements	20–30 min	Échantillon de 3–5 utilisateurs

Règle fondamentale de collecte de preuves

Règle MUSA : Toute affirmation d'un interlocuteur doit être corroborée par une preuve documentaire, technique ou observationnelle. *Exemple : un responsable déclare que les mots de passe sont chiffrés. L'auditeur ne valide pas sur cette seule déclaration ; il demande un extrait de code ou examine directement la base de données.*

Grille d'inspection physique

L'inspection physique est menée avec la grille structurée de l'annexe E. Les zones inspectées pour GIDOCEP sont :

- ◆ Salle serveur / local technique : climatisation, onduleurs, contrôle d'accès, extinction incendie ;
- ◆ Postes de travail des utilisateurs : écran verrouillé, mots de passe visibles, antivirus actif ;
- ◆ Imprimantes : documents sensibles non récupérés, accès contrôlé ;
- ◆ Zones de passage : badges visibles, accès non autorisé possible.

Table 2.13. Structure du fichier PT02-Audit-Orga.xlsx

Onglet	Contenu
Entretien-Direction	Guide d'entretien direction avec cases de saisie + preuve attendue + score
Entretien-Devs	Guide d'entretien développeurs avec cases + preuve + score
Entretien-Utilisateur	Guide d'entretien utilisateurs avec cases + observation
Inspection-Physique	Grille d'inspection physique (cases C/NC/NA + observations)
ISO27001-0rga	Contrôles ISO 27001 domaines 5, 6, 7 avec évaluation + preuve
Entropie-0rga	Calcul automatique de H_i pour chaque assertion évaluée collectivement
Synthèse-2a	Tableau de synthèse : forces, NC, zone grise, métriques

2.4.4 Sous-phase 2b : Audit technique

Objectifs et cadre méthodologique

La sous-phase 2b applique la méthodologie NIST SP 800-115 (planification, exécution, post-exploitation) et l'OWASP ASVS niveau 2 (**100 contrôles sur 14 catégories**) à GIDOCÉP.

Condition préalable obligatoire : une **autorisation écrite de test signée** par le directeur général de SOLTEC est exigée avant tout test intrusif. Ce document précise : le périmètre technique autorisé, la période d'exécution, les techniques autorisées et celles interdites, les contacts d'urgence en cas d'incident.

Sélection et utilisation des outils

Conformément au NIST SP 800-115, MUSA exige l'utilisation d'**au moins deux outils distincts** pour chaque type de scan, afin de limiter les faux positifs et faux négatifs.

Table 2.14. Outils recommandés pour l’audit technique de GIDOCEP

Type de test	Outil principal	Outil sec- ondaire	Catégories OWASP ciblées
SAST (statique)	SonarQube	Semgrep	V5, V10, V14
DAST (dynamique)	OWASP ZAP	Burp Suite Com- munity	V2, V3, V5, V7
Scan réseau	Nmap	Masscan	V9, V14
Scan vulnérabilités	OpenVAS	Nikto	V8, V9, V14
Chiffrement	SSLScan	testssl.sh	V6, V9
Injection SQL	SQLMap	Test manuel	V5.3
Contrôle d’accès	Test manuel	Burp Repeater	V4
Authentification	Hydra (test lim- ité)	Test manuel	V2

Déroulement des tests techniques

Les tests sont exécutés dans l’ordre suivant, conçu pour minimiser les risques de perturbation de GIDOCEP :

1. **Analyse statique du code source (SAST) :** SonarQube analyse l’ensemble de la base de code GIDOCEP. Les résultats sont exportés en CSV et intégrés dans l’outil PT03. Cette étape ne perturbe pas l’application en production.
2. **Revue de configuration :** vérification manuelle des fichiers de configuration (serveur web, base de données, pare-feu). Points vérifiés : comptes par défaut, mots de passe en clair, ports ouverts, modules inutiles activés.
3. **Scan de vulnérabilités réseau :** Nmap cartographie les services actifs ; OpenVAS effectue un scan de vulnérabilités. Exécutable sur l’environnement de recette avant d’éventuellement passer en production.
4. **Test dynamique (DAST) :** OWASP ZAP teste l’application en exécution. Les tests suivants sont conduits : injection SQL, XSS réfléchi et persistant, CSRF, gestion de session, contrôle d’accès (IDOR).
5. **Tests d’authentification :** vérification de la robustesse de l’authentification : politique de mots de passe, blocage après échecs, sécurité des sessions, procédure de réinitialisation.
6. **Tests de contrôle d’accès :** tentatives d’accès non autorisés entre profils (utilisateur simple accédant aux fonctions admin, accès aux données d’un autre établissement).

-
7. **Tests de logique métier (spécifique GIDOCEP)** : tentatives de contournement des flux comptables : saisie d'écritures hors-période, modification rétroactive, contournement du workflow de validation.

Documentation des preuves

Pour chaque vulnérabilité identifiée, l'auditeur documente obligatoirement :

- ◆ une capture d'écran ou un extrait de log démontrant la vulnérabilité ;
- ◆ la procédure de reproduction (étapes exactes) ;
- ◆ la catégorie OWASP ASVS correspondante ;
- ◆ le référentiel ISO 27001 concerné ;
- ◆ la cotation de gravité (selon échelle CVSS ou $P \times I$).

Outil Excel - PT03-Audit-Technique.xlsx

Table 2.15. Structure du fichier PT03-Audit-Technique.xlsx

Onglet	Contenu
OWASP-V1-V7	Contrôles OWASP ASVS V1 à V7 (niveau 2) avec colonnes C/NC/ZG + preuve + H_i
OWASP-V8-V14	Contrôles OWASP ASVS V8 à V14 (niveau 2) avec colonnes C/NC/ZG + preuve + H_i
NIST-Exécution	Grille NIST SP 800-115 phase exécution (techniques, outils, résultats)
Résultats-SAST	Import CSV SonarQube + classification par sévérité + mapping OWASP
Résultats-DAST	Résultats OWASP ZAP + Burp Suite + classement
Config-Serveur	Checklist configuration serveur web, BDD, OS
Logique-Métier	Points de contrôle spécifiques à GIDOCEP (flux comptables, validation)
ISO27001-Tech	Contrôles ISO 27001 domaine 8 (mesures technologiques)
Entropie-Tech	Calcul automatique de H_i pour assertions évaluées collectivement
Synthèse-2b	Tableau de synthèse : NC par catégorie OWASP, métriques

2.4.5 Sous-phase 2c: Analyse des risques et évaluation de la maturité

Matrice des risques

L'ANTIC utilise une matrice $P \times I$ que MUSA conserve et formalise entièrement. P (probabilité) et I (impact) sont deux échelles **complètement indépendantes**, chacune cotée de 1 à 4. Le score de risque $R = P \times I$ est **calculé** par l'auditeur pour chaque vulnérabilité ; il n'est jamais prédéfini. R peut donc prendre toute valeur entière entre 1 et 16 selon les combinaisons de P et de I retenues, soit **16 combinaisons possibles**.

		Impact (I)			
		$I = 1$	$I = 2$	$I = 3$	$I = 4$
Probabilité (P)	$P = 4$	4	8	12	16
	$P = 3$	3	6	9	12
	$P = 2$	2	4	6	8
	$P = 1$	1	2	3	4

Faible

Modéré

Élevé

Critique

Les valeurs dans les cellules sont les scores $R = P \times I$

Figure 2.2. Matrice visuelle des risques $R = P \times I$ — MUSA

Table 2.16. Échelle de la probabilité P dans MUSA

Valeur P	Niveau	Critères déterminants
$P = 1$	Très faible	Exploitation très difficile ; conditions exceptionnelles ; aucun outil public disponible ; accès physique ou privilège élevé requis
$P = 2$	Faible	Exploitation possible par un attaquant expérimenté ; outils spécialisés nécessaires ; conditions particulières requises
$P = 3$	Modéré	Exploitation accessible avec des outils courants ; techniques documentées publiquement ; aucune condition particulière nécessaire
$P = 4$	Élevé	Exploitation triviale ; preuve de concept (PoC) publiquement disponible ; aucune compétence spéciale requise

Table 2.17. Échelle de l'impact I dans MUSA

Valeur I	Niveau	Critères déterminants
$I = 1$	Négligeable	Aucune donnée sensible affectée ; aucune interruption de service ; impact financier nul ou marginal
$I = 2$	Limité	Fuite de données non sensibles ou dégradation partielle du service ; impact financier limité ; correction sans urgence
$I = 3$	Significatif	Compromission partielle des données comptables ; interruption de service notable ; risque de responsabilité légale ; impact financier modéré
$I = 4$	Critique	Compromission totale de GIDOCÉP ; accès non autorisé à l'ensemble des données financières publiques ; risque pénal ; impact financier majeur pour les établissements publics concernés

Table 2.18. Classification du risque $R = P \times I$ et seuils de priorité

Plage de R	Niveau de risque	Exemples $P \times I$	Délai de correction imposé
$R \in [1, 3]$	Faible	$1 \times 1 = 1 \mid 1 \times 2 = 2 \mid 1 \times 3 = 3$	Planifié (prochain cycle)
$R \in [4, 8]$	Modéré	$2 \times 2 = 4 \mid 2 \times 3 = 6 \mid 2 \times 4 = 8 \mid 4 \times 1 = 4$	Correction dans le mois
$R \in [9, 15]$	Élevé	$3 \times 3 = 9 \mid 3 \times 4 = 12 \mid 4 \times 3 = 12 \mid 4 \times 4 = 16$	Correction sous 2 semaines
$R = 16$	Critique	$4 \times 4 = 16$ (seule combinaison possible)	Correction immédiate sous 48 h

Lecture de la matrice : P et I sont deux échelles indépendantes, chacune cotée de 1 à 4. Le score $R = P \times I$ peut donc prendre toute valeur entière de 1 à 16 selon les combinaisons. Les quatre plages $[1, 3]$, $[4, 8]$, $[9, 15]$ et $\{16\}$ ont été définies pour refléter la progression non linéaire du risque : le seuil élevé (à partir de 9) correspond nécessairement à une probabilité *et* un impact tous deux supérieurs ou égaux à 3, signalant une menace concrète et multidimensionnelle. Le score 16 est réservé à la seule combinaison $P = 4 \times I = 4$, c'est-à-dire une vulnérabilité trivialement exploitable avec un impact catastrophique sur GIDOCÉP. * $4 \times 4 = 16$ est classe Critique, non Élevé.

Priorisation des actions correctives

Les vulnérabilités sont priorisées selon leur score de risque :

- ◆ $R = 16$: **Critique** : correction immédiate (sous 48 h) ;
- ◆ $R \in [9, 15]$: **Élevé** : correction dans les 2 semaines ;
- ◆ $R \in [4, 8]$: **Modéré** : correction dans le mois ;
- ◆ $R \in [1, 3]$: **Faible** : correction planifiée.

Évaluation de la maturité

MUSA conserve le modèle de maturité de l'ANTIC (inspiré CMMI) sur cinq niveaux (0 %, 25 %, 50 %, 75 %, 100 %) et l'applique à six domaines :

Table 2.19. Grille d'évaluation de la maturité MUSA pour GIDOCEP

Domaine	0 %	25 %	50 %	75 %	100 %
Politique de sécurité	Absente	Rédigée	Approuvée	Diffusée	Revue annuelle
Gestion des accès	Aucune règle	Règles informelles	Documenté	Appliquée	Régulièrement auditée
Développement sécurisé	Aucun contrôle	Revue ad hoc	Guide de codage	SAST intégré	DevSecOps complet
Gestion des incidents	Aucune procédure	Réactive	Procédure écrite	Testée	Indicateurs suivis
Continuité d'activité	Aucun plan	Plan informel	PRA rédigé	PRA testé	PRA mis à jour annuellement
Sensibilisation	Aucune	Ponctuelle	Annuelle	Ciblée	Continue + mesurée

Calcul de l'entropie de Shannon en Phase 2

L'entropie de Shannon est calculée systématiquement pour chaque assertion évaluée par plusieurs auditeurs. Le protocole est le suivant :

1. **Évaluation indépendante** : chaque auditeur remplit ses colonnes C/NC/ZG sans consulter les autres.

2. **Calcul automatique** : l'onglet Entropie du fichier PT03 calcule H_i pour chaque ligne.

3. **Action selon le seuil** :

- ◆ $H_i < 0,5$: constat validé directement ;
- ◆ $0,5 \leq H_i < 1,0$: discussion en équipe, clarification documentée ;
- ◆ $H_i \geq 1,0$: réunion d'arbitrage, investigations complémentaires obligatoires.

4. **Archivage** : les valeurs H_i et les décisions associées sont archivées dans le papier de travail.

Protocole d'arbitrage pour les zones d'incertitude Lorsque l'entropie H_i est supérieure ou égale à 0,5, la méthode MUSA déclenche un processus structuré de discussion ou d'arbitrage.

Table 2.20. Protocole d'arbitrage MUSA

H_i	Action	Acteurs	Documentation	
$H_i < 0,5$	Constat validé directement	-	Validation directe	
$0,5 \leq H_i < 1,0$	Discussion en équipe	Auditeurs + Lead auditor	PV de discussion	
$H_i \geq 1,0$	Arbitrage obligatoire	Lead auditor + Expert métier	PV d'arbitrage	

Critères de décision La décision finale repose sur trois critères hiérarchisés :

1. **Preuves documentaires** : une preuve écrite prévaut sur une déclaration verbale.
2. **Cohérence avec le contexte métier** : la logique fonctionnelle de l'application prime sur une interprétation technique isolée.
3. **Alignement réglementaire** : la conformité à la loi 2010/012 et au référentiel ANTIC est prioritaire.

Exemple d'arbitrage Pour l'assertion 1.3 (RSSI identifié avec fiche de poste), l'équipe a constaté :

- ◆ Une nomination verbale de M. MBOUL Patrick comme RSSI
- ◆ Mais une absence de fiche de poste formalisée

Décision finale : *Partiellement conforme* (recommandation : formaliser la fiche de poste).
La valeur $H_i = 0,91$ est archivée avec la décision pour traçabilité.

Outil Excel - Risques.xlsx

Table 2.21. Structure du fichier PT04-Risques.xlsx

Onglet	Contenu
Matrice-Risques	Tableau complet des vulnérabilités avec ID, description, catégorie, P , I , R , priorité, responsable, échéance
Cotation-CVSS	Grille de cotation CVSS v3.1 optionnelle pour vulnérabilités critiques
Maturité	Grille d'évaluation de la maturité par domaine avec score et niveau
Entropie-Global	Calcul de H_{global} à partir des H_i de PT02 et PT03
Dashboard	Tableau de bord visuel (graphiques) : répartition risques, maturité, H_{global}
Synthèse-2c	Synthèse des risques, priorités, score de maturité global

2.4.6 Réunions de suivi quotidiennes

Conformément à l’IIA 2340, le lead auditor conduit une **revue quotidienne** des travaux. Cette revue comprend :

- ◆ vérification que les papiers de travail sont complets et que les preuves sont attachées ;
- ◆ identification des points bloquants et arbitrage des zones grises ($H_i \geq 0,5$) ;
- ◆ ajustement du planning si nécessaire ;
- ◆ communication quotidienne courte avec le point focal SOLTEC (5–10 min).

Plan de contingence pour les preuves indisponibles MUSA prévoit un protocole pour les situations où certaines preuves techniques ne peuvent être obtenues (exemple : code source non fourni) :

1. **Niveau 1 - Substitution** : si le code source n’est pas disponible, l’auditeur peut s’appuyer sur :
 - ◆ Les déclarations du développeur en entretien (croisées avec d’autres sources comme les logs ou les configurations)
 - ◆ L’analyse dynamique (DAST) comme indicateur indirect des failles de codage

◆ L'inspection des fichiers de configuration et des journaux d'application

2. **Niveau 2 - Documentation** : l'absence de preuve est documentée comme une **limite de l'audit** dans le rapport, avec une recommandation de réaliser un audit complémentaire lorsque l'accès sera disponible.
3. **Niveau 3 - Escalade** : si l'absence de preuve est jugée critique pour la sécurité (exemple : absence totale de code source pour une application sensible), le lead auditor peut solliciter une intervention du commanditaire pour obtenir l'accès nécessaire.

Cette approche permet de poursuivre l'audit tout en identifiant clairement les zones qui nécessitent une investigation approfondie lors d'un cycle ultérieur.

2.5 Phase 3: Analyse, métriques et rapport

2.5.1 Vue d'ensemble

La Phase 3 consolide l'ensemble des constats des sous-phases 2a, 2b et 2c, calcule les métriques globales de l'audit et produit le rapport provisoire.

Table 2.22. Vue synthétique de la Phase 3

Élément	Détail
Durée typique	3 à 5 jours ouvrables
Normes de référence	ISO 19011 §6.5, IIA 2400–2420
Artefact principal	Rapport d'audit provisoire (A7) en 7 sections
Outil Excel dédié	PT05-Rapport.xlsx
Réunion technique pré-clôture	Obligatoire avant transmission du rapport

2.5.2 Consolidation des constats

L'étape de consolidation rassemble les résultats des trois sous-phases dans un tableau unique de constats. Chaque constat est codé (ex : ORG-001 pour organisationnel, TECH-001 pour technique) et lié à :

- ◆ la catégorie OWASP ASVS ou le contrôle ISO 27001 correspondant ;
- ◆ le papier de travail source (PT02 ou PT03) ;
- ◆ la preuve documentaire (capture, log, extrait) ;

- ♦ le score de risque $R = P \times I$;
- ♦ la valeur H_i (reproductibilité du constat).

2.5.3 Calcul des métriques globales

Les cinq métriques sont calculées automatiquement par l'onglet Métriques du fichier PT05 :

- ♦ $TC = \frac{N_C}{N_{total}} \times 100$: taux de conformité global ;
- ♦ $TC_{N2} = \frac{N_{C,N2}}{N_{N2}} \times 100$: taux de conformité sur les 100 contrôles OWASP ASVS niveau 2 ;
- ♦ $\bar{R} = \frac{\sum R_i}{N_{vuln}}$: score de risque moyen ;
- ♦ $H_{global} = \frac{1}{N} \sum H_i$: entropie globale de l'audit ;
- ♦ Score de maturité global : moyenne pondérée sur les six domaines (cf. tableau 2.19).

2.5.4 Structure du rapport d'audit (Artefact A7)

Le rapport d'audit MUSA est structuré en **sept sections obligatoires** (IIA 2410). Aucune section ne peut être omise ; certaines peuvent être réduites si le contexte le justifie, mais doivent être présentes.

Table 2.23. Structure du rapport d'audit MUSA (7 sections)

§	Section	Long. max.	Contenu obligatoire
1	Résumé exécutif	2 pages	Métriques clés, 3 forces majeures, 3 vulnérabilités critiques, recommandation principale
2	Contexte et périmètre	1–2 pages	Description GIDOCEP/SOLTEC, périmètre inclus/exclus, niveau d'audit
3	Méthodologie	1–2 pages	Références MUSA/OWASP/NIST/ISO, outils utilisés, équipe
4	Synthèse des résultats	2–3 pages	Tableau des métriques, graphiques de distribution, comparaison cycle précédent
5	Détail des vulnérabilités	10–20 pages	Fiche par vulnérabilité : ID, catégorie, description, preuve, risque, recommandation
6	Recommandations et plan d'action	2–3 pages	Actions classées par priorité, responsable, échéance, indicateur de résolution
7	Annexes	Variable	Papiers de travail PTxx, résultats d'outils, captures d'écran complètes

2.5.5 Outil Excel PT05-Rapport.xlsx

Table 2.24. Structure du fichier PT05-Rapport.xlsx

Onglet	Contenu
Constats-Consolidés	Tableau de tous les constats avec code, source PT, preuve, risque, H_i
Métriques	Calcul automatique des 5 métriques avec formules et résultats
Plan-Actions	Tableau de suivi des recommandations : action, priorité, responsable, échéance, statut
Dashboard-Rapport	Graphiques automatiques pour insérer dans le rapport (camembert, radar, histogramme)
Procédure-Contradicto	Suivi des contestations de l'audité avec dates et réponses

2.5.6 Réunion technique pré-clôture

Avant de transmettre le rapport provisoire, une **réunion technique pré-clôture** est organisée entre l'équipe d'audit et l'équipe technique de SOLTEC. Cette bonne pratique de l'ANTIC est conservée et formalisée dans MUSA. Objectifs :

- ♦ valider que les vulnérabilités techniques sont comprises par l'équipe technique ;
- ♦ corriger les éventuelles erreurs factuelles (version logicielle, configuration effective) ;
- ♦ éviter les surprises et désaccords lors de la réunion de clôture avec la direction.

2.6 Phase 4: Clôture et diffusion

2.6.1 Vue d'ensemble

Table 2.25. Vue synthétique de la Phase 4

Élément	Détail
Durée typique	2 à 3 jours ouvrables
Normes de référence	ISO 19011 §6.6, IIA 2400, IIA 2440
Livrables	Rapport d'audit définitif, PV de clôture signé
Procédure contradictoire	Délai de 10 jours ouvrés pour contestation écrite

2.6.2 Réunion de clôture formelle

La réunion de clôture (ISO 19011 §6.6) est conduite selon un protocole structuré :

1. **Présentation des forces d'abord** : l'ANTIC commence par les points positifs ; MUSA conserve cette pratique psychologiquement avisée ;
2. **Présentation des non-conformités critiques** : avec preuves à l'appui ;
3. **Présentation des métriques globales** : TC , $\bar{R}$, H_{global} , score de maturité ;
4. **Présentation du plan d'actions recommandé** : priorités et échéances ;
5. **Ouverture de la procédure contradictoire** : l'audité dispose de **10 jours ouvrés** pour contester par écrit tout constat ;
6. **Signature du PV de clôture** par le lead auditor et le représentant de SOLTEC.

2.6.3 Procédure contradictoire

MUSA formalise la procédure contradictoire (absente du référentiel ANTIC 2020) :

- ◆ L'audité dispose de **10 jours ouvrés** à compter de la réunion de clôture pour contester par écrit ;
- ◆ Toute contestation doit être étayée : un simple désaccord sans preuve contraire n'est pas recevable ;
- ◆ Le lead auditor dispose de **5 jours ouvrés** pour répondre ;
- ◆ En cas de contestation validée, le constat est modifié ; sinon, il est maintenu avec la mention de la contestation ;
- ◆ L'intégralité des échanges est archivée dans l'onglet Procédure-Contradictoire du PT05.

2.6.4 Diffusion contrôlée du rapport

La diffusion du rapport définitif suit une liste d'autorisation stricte (IIA 2440) :

Table 2.26. Liste de diffusion du rapport d’audit MUSA

Destinataire	Version	Justification
Direction générale SOLTEC	Intégrale	Commanditaire de l’audit
Point focal ANTIC	Intégrale	Autorité de régulation
MINPOSTEL	Intégrale	Ministère de tutelle
ART	Intégrale	Autorité de régulation des télécommunications
COBAC (si institution financière)	Intégrale	Contrôle bancaire
Équipe technique SOLTEC	Section 5 + 6 uniquement	Besoin opérationnel de correction

2.7 Phase 5: Suivi post-audit

2.7.1 Vue d’ensemble

L’ANTIC dispose d’un accompagnement post-audit ; MUSA le formalise et le structure. La Phase 5 est conduite sur une **période de 3 mois** après la transmission du rapport définitif.

Table 2.27. Vue synthétique de la Phase 5

Élément	Détail
Durée	3 mois après rapport définitif
Normes de référence	ISO 19011 §6.7, IIA 2500, IIA 2501, IIA 2600
Jalons obligatoires	J+15 (lancement), M+1 (point 1), M+2 (point 2), M+3 (clôture)
Outil Excel dédié	PT06-Suivi.xlsx
Archivage final	Dossier d’audit complet : 5 ans minimum (IIA 2330)

2.7.2 Jalons obligatoires

Table 2.28. Jalons et activités de la Phase 5

Jalon	Activité	Contenu détaillé
J+15	Réunion de lancement du plan d'actions	Présentation détaillée des actions correctives, attribution des responsables, calendrier, indicateurs de résolution ; PV signé
M+1	Point d'étape n°1	Suivi sur preuves des corrections critiques ; retest des vulnérabilités critiques ($R = 16$) ; ajustements si nécessaire
M+2	Point d'étape n°2	Retest des vulnérabilités élevées ($R \geq 9$) ; mesure de la progression du score de maturité ; formation si nécessaire
M+3	Réunion de clôture du suivi	Bilan final : taux de réalisation du plan d'actions, évolution du <i>TC</i> , évolution de la maturité ; PV de levée des observations signé

2.7.3 Procédure d'escalade

MUSA définit une **procédure d'escalade en trois niveaux** (IIA 2600), absente de la démarche ANTIC actuelle :

1. **Niveau 1, Relance formelle** : si une recommandation critique n'est pas traitée dans les délais, le lead auditor envoie une relance formelle écrite au directeur général de SOLTEC ;
2. **Niveau 2, Information du commanditaire** : sans réponse sous 10 jours, le point focal ANTIC est informé officiellement ;
3. **Niveau 3, Saisine du Comité d'Audit** : en cas de risque résiduel critique non traité, le Comité d'Audit de l'ANTIC est saisi.

2.7.4 Archivage du dossier d'audit

Conformément à l'IIA 2330, l'intégralité du dossier d'audit est archivée pour une durée minimale de **5 ans**. Le dossier comprend :

- ◆ les artefacts A1 à A7 (charte, déclarations, papiers de travail, rapport) ;
- ◆ les fichiers Excel PT01 à PT06 ;
- ◆ les preuves brutes (captures d'écran, exports d'outils, extraits de code) ;
- ◆ les PV de toutes les réunions ;
- ◆ la correspondance officielle (relances, contestations, réponses).

2.7.5 Outil Excel PT06-Suivi.xlsx

Table 2.29. Structure du fichier PT06-Suivi.xlsx

Onglet	Contenu
Plan-Suivi	Tableau de bord du plan d'actions avec statut par recommandation
Retests-J30	Résultats des retests à M+1 sur vulnérabilités critiques
Retests-J60	Résultats des retests à M+2 sur vulnérabilités élevées
Évolution-Métriques	Courbes d'évolution TC , $\bar{R}$, maturité entre audit initial et suivi
Escalade	Journal des escalades (niveau, date, action, réponse)
PV-Levée	Modèle de PV de levée des observations (M+3)
Archivage	Checklist de clôture et d'archivage du dossier d'audit

2.8 Synthèse des apports de MUSA

2.8.1 Ce que MUSA conserve de l'ANTIC

MUSA n'est pas une rupture : c'est une évolution structurée. Les six forces de la démarche ANTIC identifiées au chapitre 1 sont intégralement préservées :

Table 2.30. Forces de l'ANTIC préservées dans MUSA

Force ANTIC	Intégration dans MUSA
Structure en 5 phases	Conservée, alignée ISO 19011 §6.2–6.7
Ancrage local (loi 2010/012)	Intégrée dans les grilles ISO 27001 (contrôle 5.31)
Vision globale (4 axes)	PT02 couvre organisationnel, humain, physique ; PT03 le technologique
Approche par les risques $P \times I$	Conservée et formalisée dans PT04, avec critères d'escalade
Accompagnement post-audit	Conservé, structuré en 4 jalons sur 3 mois avec PT06
Bonne acceptation	MUSA <i>évolue</i> l'existant ; elle ne révolutionne pas

2.8.2 Ce que MUSA apporte par rapport à l'ANTIC

Table 2.31. Apports de MUSA face aux neuf limites de l'ANTIC

L	Limite ANTIC	Apport concret de MUSA
L1	Manque de formalisation	7 catégories d'artefacts, 6 fichiers Excel détaillés, procédures étape par étape
L2	Faible reproductibilité	Entropie de Shannon H_i calculée pour chaque assertion, archivée, seuils d'action définis
L3	Absence de métriques	5 métriques quantitatives calculées automatiquement (PT05)
L4	Pas de standards intl	ISO 27001 (93), OWASP ASVS N2 (100), NIST SP 800-115, ISO 19011, IIA IPPF
L5	Profondeur variable	3 niveaux définis, grille de détermination objective (tableau 3.5)
L6	Lacunes techniques	14 catégories OWASP avec contrôles numérotés, outils recommandés par type de test (tableau 3.8)
L7	Absence ISO 19011	Chaque phase MUSA = une phase ISO 19011 ; PV, programme de travail, archivage
L8	Absence gouvernance IIA	22 normes IIA intégrées (annexe E), artefacts dédiés
L9	Pas de mesure reprod.	H_i et H_{global} calculés, archivés, interprétés selon seuils

2.8.3 Synthèse tableau MUSA complet (Tableau 3 de référence)

Table 2.32. Démarche MUSA complète , synthèse par phase

Phase	Activités clés	Artefacts	Outil Excel	Sources nor- matives
Phase 1 - Ini- tiation	Déclenchement, faisabil- ité, équipe, déclaration indépendance, périmètre, niveau, collecte doc., réu- nion lancement	A1 Charte, A2 Déclaration, A3 PT00	PT01- Phase1.xlsx	ISO 19011 §6.2– 6.3, IIA 1100, IIA 2200
Phase 2a - Audit orga	Entretiens standardisés (3 profils), inspection physique, contrôles ISO 27001 dom. 5–7, entropie	PT02	PT02-Audit- Orga.xlsx	ISO 27001 dom. 5–7, ISO 19011 §6.4
Phase 2b - Audit tech	SAST, DAST, config, réseau, chiffrement, logique métier, contrôles OWASP N2, entropie	PT03	PT03-Audit- Technique.xlsx	OWASP ASVS N2, NIST SP 800- 115, IIA 2310
Phase 2c - Risques	Matrice $P \times I$, CVSS op- tionnel, maturité 6 do- maines, H_{global}	PT04, MR	PT04- Risques.xlsx	ANTIC $P \times I$, CMMI, ISO 27001 §6.1
Phase 3 - Rapport	Consolidation, métriques, réunion pré-clôture, rap- port 7 sections	A7 Rapport	PT05- Rapport.xlsx	ISO 19011 §6.5, IIA 2400–2420
Phase 4 - Clôture	Réunion de clôture, procé- dure contradictoire (10j), rapport définitif, diffusion contrôlée	PV Clôture, A7 déf.	PT05 (onglet Contradictoire)	ISO 19011 §6.6, IIA 2440
Phase 5 - Suivi	4 jalons sur 3 mois, retests, escalade 3 niveaux, PV levée, archivage 5 ans	PT06, PV Levée	PT06- Suivi.xlsx	ISO 19011 §6.7, IIA 2500, IIA 2600

Conclusion du chapitre

Ce chapitre a présenté MUSA dans l'intégralité de ses composantes opérationnelles. La méthode repose sur sept principes directeurs qui répondent point par point aux neuf limites de la démarche ANTIC. Elle se déploie en cinq phases rigoureusement structurées, chacune

dotée d'activités détaillées, de livrables formalisés, d'un outil Excel dédié et d'une ancrage dans les standards internationaux.

L'apport le plus original : la mesure de la reproductibilité par l'entropie de Shannon est intégré dans les phases 2 et 3 : chaque assertion évaluée collectivement reçoit une valeur H_i qui conduit soit à une validation directe, soit à une discussion, soit à un arbitrage.

Les six outils Excel (PT01 à PT06) constituent le capital méthodologique réutilisable de MUSA : ils sont conçus pour être enrichis à chaque cycle d'audit, améliorer la qualité d'un cycle à l'autre, et être généralisés à toute application développée par SOLTEC au-delà de GIDOCEP.

Le chapitre 3 applique cette méthode concrètement à GIDOCEP : il présente le déroulement complet de l'audit, les vulnérabilités identifiées, les métriques calculées et les recommandations formulées.

Références bibliographiques du chapitre 2

Bibliography

- [1] ANTIC. (2020). *Référentiel interne d'audit de sécurité*. Yaoundé.
 - [2] ANTIC. (2026). *Méthodologie d'audit , Conférence 29 avril 2026* [source primaire non publiée].
 - [3] ISO 19011:2018. *Lignes directrices pour l'audit des systèmes de management*. Organisation Internationale de Normalisation.
 - [4] ISO/IEC 27001:2022. *Sécurité de l'information , Exigences*. Organisation Internationale de Normalisation.
 - [5] Institute of Internal Auditors. (2017). *IPPF , Normes internationales pour la pratique professionnelle de l'audit interne*. The IIA.
 - [6] OWASP Foundation. (2021). *Application Security Verification Standard v4.0.3*. OWASP.
 - [7] Scarfone, K. et al. (2008). *NIST SP 800-115: Technical Guide to Information Security Testing*. NIST.
 - [8] Shannon, C. E. (1948). A Mathematical Theory of Communication. *Bell System Technical Journal*, 27(3), 379–423.
 - [9] CMMI Institute. (2018). *CMMI for Development, Version 2.0*.
- =====

MUSA à GIDOCEP

Résultats

*Présentation de la méthode MUSA à
présente les résultats de l'audit,
identifiées et formule les recom-*

Application de MUSA à GIDOCEP et Résultats

Introduction du chapitre

Dans le chapitre précédent, nous avons présenté **MUSA** (Méthode Unifiée d'Audit de Sécurité Applicative), une démarche standardisée qui combine les forces de l'ANTIC et les apports des standards internationaux (ISO 27001, OWASP ASVS, NIST SP 800-115, ISO 19011, normes IIA), avec une innovation originale : l'entropie de Shannon pour mesurer la reproductibilité inter-auditeurs.

Ce troisième chapitre a pour objectif d'**appliquer concrètement MUSA** à un cas réel : **GIDOCEP**, l'application développée par SOLTEC et utilisée par les établissements publics camerounais pour la gestion de leurs opérations comptables.

L'application de MUSA à GIDOCEP poursuit trois objectifs :

- ♦ **Valider la pertinence et l'applicabilité** de la méthode sur un cas concret
- ♦ **Produire un diagnostic de sécurité** de GIDOCEP avec des métriques objectives
- ♦ **Formuler des recommandations** actionnables pour l'équipe de SOLTEC

L'audit a été réalisé selon le **niveau 2 (standard)** de MUSA, justifié par la criticité de GIDOCEP (données financières sensibles, obligations réglementaires ANTIC).

3.1 Présentation de GIDOCEP



Figure 3.1. Page d'accueil et tableau de bord de GIDOCEP

Source : Capture d'écran réalisée lors de l'audit

Page d'accueil et tableau de bord de GIDOCEP

3.1.1 Description générale

GIDOCEP (**G**estion **I**nformatisée des **O**érations **C**omptables des **É**tablissements **P**ublics) est une application développée par la société **SOLTEC** (Solutions Techniques). Présente sur le marché camerounais depuis **2008**, elle a progressivement été autorisée par l'État à être utilisée par l'ensemble des établissements publics du pays, devenant ainsi un outil central de la gestion budgétaire publique.

L'application s'inscrit dans le cadre réglementaire défini par la **circulaire N° 13/001/C/MINFI du 08 janvier 2013**, qui précise les modalités pratiques d'exécution, de suivi et de contrôle du budget de l'État, des Établissements Publics Administratifs, des Collectivités Territoriales Décentralisées et des autres Organismes subventionnés. GIDOCEP est la **formalisation informatique** de cette circulaire.

L'application se structure en **trois grands modules fonctionnels** :

- ◆ **Le module de l'Ordonnateur** : gestion des engagements, liquidations et ordonnancements.
- ◆ **Le module du Contrôle Financier** : visa budgétaire, contrôle et validation des dépenses et recettes.
- ◆ **Le module de l'Agence Comptable** : prise en charge, paiement et encaissement des opérations.

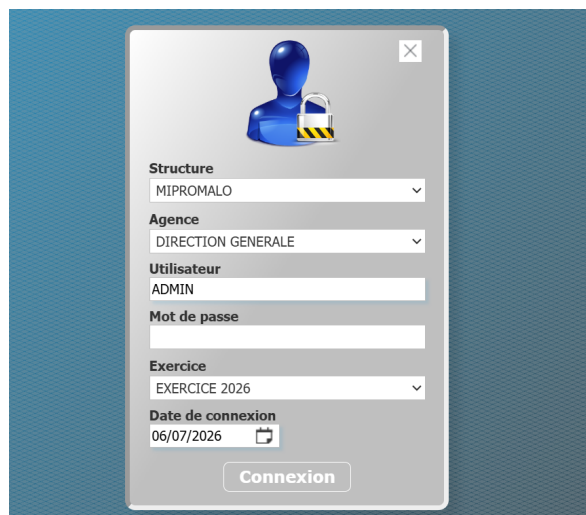


Figure 3.2. Écran de connexion à GIDOCEP

Source : Capture d'écran réalisée lors de l'audit

Le tableau 3.1 synthétise les informations générales de l'application.

Table 3.1. Informations générales sur GIDOCEP

Élément	Information
Nom complet	Gestion Informatisée des Opérations Comptables des Établissements Publics
Nom court	GIDOCEP
Développeur	SOLTEC (Solutions Techniques)
Année de lancement	2008
Cadre réglementaire	Circulaire N° 13/001/C/MINFI du 08 janvier 2013
Objectif	Exécution du budget des établissements publics camerounais
Utilisateurs	Ordonnateurs, Contrôleurs Financiers, Agents Comptables
Mode de déploiement	Intranet / local

3.1.2 Architecture technique

GIDOCEP est développé avec **WEBDEV 24**, un environnement de développement dédié aux applications Internet et Intranet, édité par PC SOFT.

L'application repose sur une **architecture en trois couches** :

- ✦ **Couche présentation** : interface utilisateur composée de pages HTML et AWP (Active Web Pages) générées dynamiquement par le serveur.
- ✦ **Couche contrôleur** : implémentée en WLangage via les bibliothèques du site (fichiers .WDL et .AWL) ; elle gère les règles métier, le formatage des données et la validation.

- ♦ **Couche données** : assure la persistance des informations dans la base de données HFSQL Classic (fichiers .FIC, .NDX, .MMO).

Le déploiement de GIDOCEP repose sur un serveur Web **IIS** (Internet Information Server) et un gestionnaire de protocole **AWP** (Active Web Pages) nommé WD240AWP.EXE.

Table 3.2. Caractéristiques techniques de GIDOCEP

Composant	Information
Langage de développement	WEBDEV 24 (WLangage)
Architecture	3 tiers (Présentation, Contrôleur, Données)
Base de données	HFSQL Classic (fichiers .FIC, .NDX, .MMO)
Serveur Web	IIS (Internet Information Server)
Protocole	CGI (AWP -Active Web Pages)
Gestionnaire AWP	WD240AWP.EXE
Administrateur	WD240ADMIN.EXE (service Windows)
Mode de déploiement	Intranet / local
Gestion des utilisateurs	Groupes d'utilisateurs + Profils

Structure des répertoires

L'installation d'un site WEBDEV génère la structure de répertoires suivante :

- ♦ **Répertoire du site** : contient les bibliothèques (.WDL, .AWL)
- ♦ **Répertoire WEB** : contient les pages HTML, AWP, images, CSS et Javascript (alias IIS)
- ♦ **Répertoire des données** : contient les fichiers HFSQL Classic (.FIC, .NDX, .MMO)

Cette structure est importante pour l'audit car elle détermine les points d'entrée de l'application et les zones sensibles où sont stockées les données financières.

3.1.3 Données manipulées

GIDOCEP manipule des données de nature **financière et budgétaire**, dont la sensibilité justifie un niveau d'audit élevé :

- ♦ Budgets des établissements publics (recettes et dépenses)
- ♦ Engagements juridiques (bons de commande, ordres de mission, marchés, contrats)

- ◆ Paiements et encaissements
- ◆ Comptes de gestion et comptes administratifs
- ◆ Données personnelles des agents

Spécificité : les données sont **décentralisées** (chaque établissement gère ses propres données), ce qui pose des défis de sécurité et de gouvernance.

3.1.4 Types de dépenses et recettes traitées

D'après le manuel de formation de GIDOCEP, plusieurs types de dépenses sont traités dans l'application :

Table 3.3. Types de dépenses et recettes traitées dans GIDOCEP

Type	Exemples
Dépenses	Ordres de mission, décisions de déblocage de fonds, bons de commande, lettres commandes, marchés, contrats, conventions
Recettes	Recettes émises (facturation), recettes spontanées (versements directs)



Figure 3.3. Menu principal de GIDOCEP

Source : Capture d'écran réalisée lors de l'audit

3.1.5 Chaîne d'exécution du budget

GIDOCEP implémente un **circuit de validation à trois acteurs** : Ordonnateur, Contrôleur Financier, Agent Comptable.

Les étapes critiques du traitement de la dépense budgétaire

1. Chez l'Ordonnateur :

- ◆ **Engagement** : première phase de traitement. Permet de réserver les crédits nécessaires à l'exécution de la dépense.
- ◆ **Liquidation** : constatation de l'effectivité de la prestation et validation de la facture.
- ◆ **Ordonnancement** : établissement du mandat de paiement dans le système.

2. Chez le Contrôleur Financier Spécialisé :

- ◆ **Visa budgétaire** : valide l'engagement.
- ◆ **Contrôle et validation** : autorise le paiement de la dépense.

3. Chez l'Agent Comptable :

- ◆ **Prise en charge** : constatation de la dette. Le "Vu bon à payer" apposé sur la dépense fait d'elle une dette de la structure.
- ◆ **Paiement** : exécution effective du paiement.

Table 3.4. Acteurs de la chaîne d'exécution du budget

Acteur	Rôle	Particularité
Ordonnateur (DG)	Engage la dépense, liquide et ordonnance	Chaque acteur connaît ses propres opérations
Contrôleur Financier	Vérifie la conformité budgétaire et valide	Peut rejeter avec obligation de motivation
Agent Comptable (AC)	Contrôle la régularité, gère la liquidité, effectue le paiement	Réalise les mêmes contrôles que le Contrôleur Financier, en plus de la prise en charge

Les circuits de traitement de la dépense budgétaire

Le manuel de formation distingue **deux circuits de traitement** pour les dépenses budgétaires :

- ◆ **Circuit long** : réservé au traitement des bons de commande, lettres commandes, marchés, contrats et conventions.
- ◆ **Circuit court** : réservé au traitement des dossiers à caractère urgent (ordres de mission, décisions de déblocage de fonds).

1	Engagement		
2	Transfert des dossiers au Contrôle Financier Spécialisé	Réception des dossiers	
3		Visa budgétaire	
4		Transfert des dossiers validés/rejetés à l'ordonnateur	
5	Réception des dossiers validés/rejetés par le Contrôleur Financier Spécialisé		
6	Liquidation par le Comptable Matière		
7	Ordonnancement		
8	Transfert des mandats au Contrôle Financier pour contrôle et validation		
9		Réception des mandats	
10		Contrôle et validation des mandats	
11		Transfert des mandats validés à l'Agence Comptable	Réception des mandats
12		Transfert des mandats rejetés à l'ordonnateur	Prise en charge des mandats/rejet des mandats

13	Réception des mandats rejetés par le Contrôle Financier Spécialisé		Transfert des mandats pris en charge
14		Réception des mandats rejetés par l'Agence Comptable	Païement des mandats pris en charge
Remarque : circuit réservé au traitement des bons de commandes, lettres commandes, marchés, contrats et conventions			

Figure 3.4. Circuit long de traitement des dépenses budgétaires

Source : Manuel de formation GIDOCER, SOLTEC, 2020, p. 29

2. Traitement en circuit court

N° Ordre	ORDONNATEUR (SERVICES ACHETEURS)	CONTROLEUR FINANCIER SPECIALISE	AGENCE COMPTABLE
1	Engagement (saisie de l'engagement)		
2	Liquidation par le Comptable Matière		
3	Ordonnancement (saisie du mandat de paiement dans le système)		
4	Transfert des mandats au Contrôle Financier pour contrôle et validation		
5		Réception des mandats	
6		Contrôle et validation des mandats	
8		Transfert des mandats validés à l'Agence Comptable	Réception des mandats
9		Transfert des mandats rejetés à l'ordonnateur	Prise en charge des mandats/rejet des mandats
10	Réception des mandats rejetés par le Contrôle Financier Spécialisé		Transfert des mandats pris en charge

11		Réception des mandats rejetés par l'Agence Comptable	Païement des mandats pris en charge
Remarque : c'est le circuit réservé au traitement des dossiers à caractère urgent (décisions, missions...)			

Figure 3.5. Circuit court de traitement des dépenses budgétaires (dossiers urgents)

Source : Manuel de formation GIDOCER, SOLTEC, 2020, p. 30

Le traitement des recettes budgétaires

Les recettes suivent également un circuit spécifique :

1. **Chez l'Ordonnateur** : saisie des émissions de recette (facturation).
2. **Chez le Contrôleur Financier** : contrôle et validation des émissions.
3. **Chez l'Agent Comptable** : prise en charge des émissions, puis encaissement.

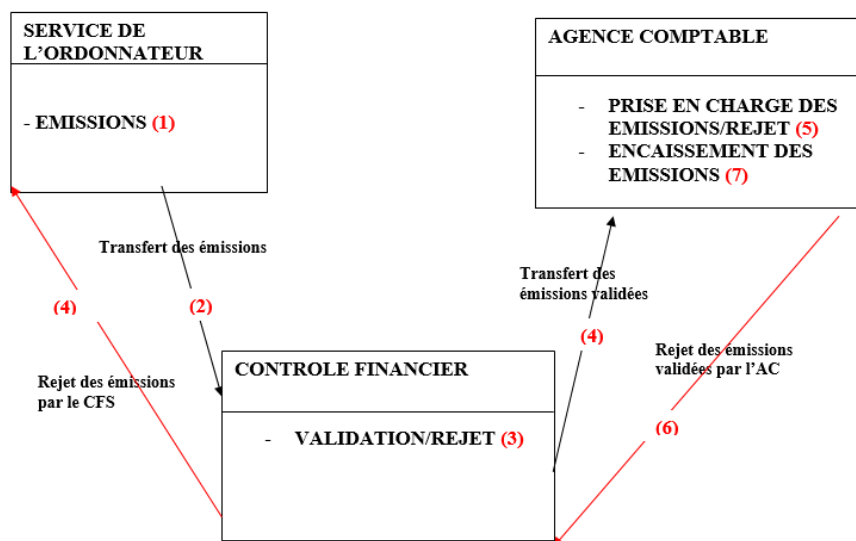


Figure 3.6. Circuit de traitement des recettes budgétaires

Source : Manuel de formation GIDOCEP, SOLTEC, 2020, p. 30

3.1.6 Interface utilisateur

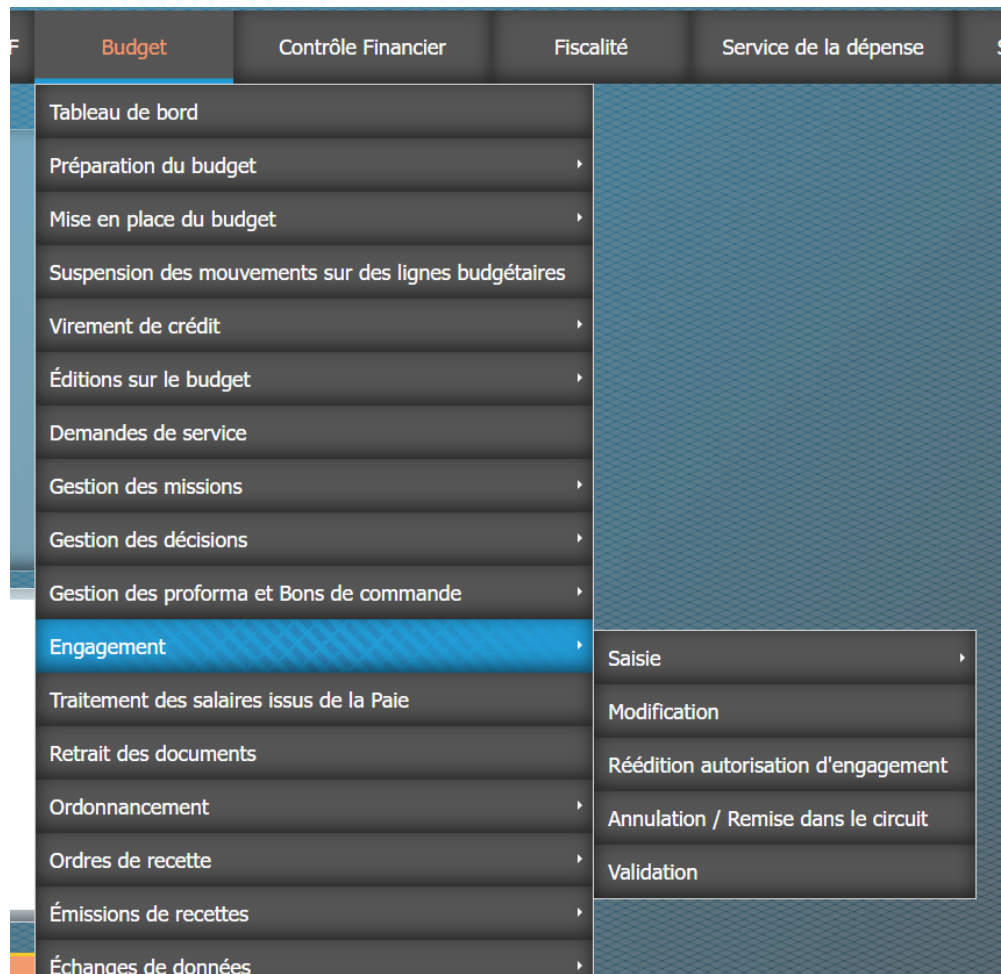


Figure 3.7. Interface du module Ordonnateur

Source : Capture d'écran réalisée lors de l'audit

Cette interface permet à l'Ordonnateur de gérer les trois étapes clés du cycle de la dépense : l'engagement, la liquidation et l'ordonnancement. On y retrouve les menus permettant de saisir, modifier ou annuler des opérations budgétaires.

3.1.7 Gestion des utilisateurs et des droits

La gestion des utilisateurs de GIDOCEP repose sur deux notions complémentaires définies dans le manuel de formation :

- ◆ **Groupe d'utilisateurs** : ensemble d'utilisateurs jouant le même rôle dans le système (Ordonnateur, Contrôleur Financier, Agent Comptable, Administrateur).
- ◆ **Profil de l'utilisateur** : vue personnalisée du système pour un utilisateur donné.

3.1.8 Sécurité de GIDOCEP

GIDOCEP est déployée en mode **intranet**, accessible uniquement depuis le réseau local de l'établissement. Le serveur Web utilisé est **IIS** et le protocole de communication est **HTTP**.

La connexion à l'application repose sur un couple **code utilisateur / mot de passe**.

Gestion des droits d'accès

Les droits d'accès aux fichiers et répertoires sont gérés par les groupes Windows suivants :

- ♦ **WWUSR** : groupe des utilisateurs WEBDEV, utilisé pour les installations et mises à jour à distance.
- ♦ **IUSR** : utilisateur anonyme Internet, sous lequel les sites WEBDEV sont exécutés.

Traçabilité des opérations

contenu...

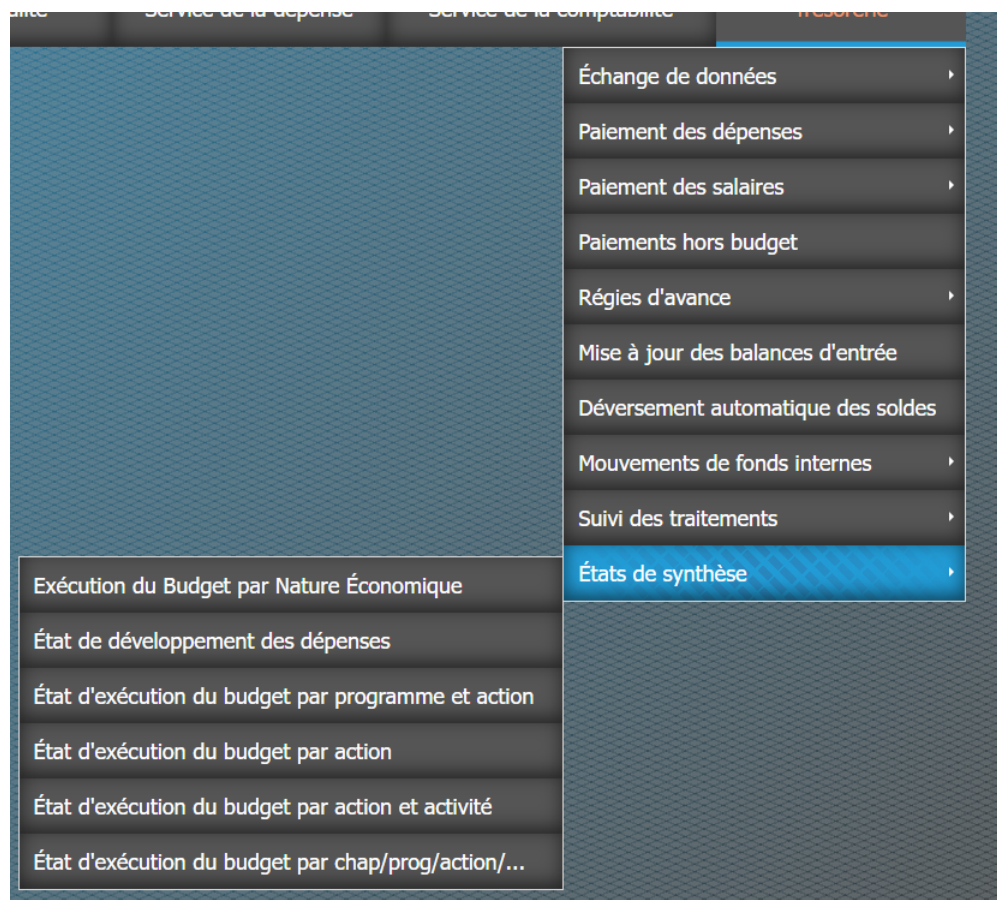


Figure 3.8. Journal des opérations (traçabilité des actions)

Source : Capture d'écran réalisée lors de l'audit

Le journal des opérations enregistre chronologiquement toutes les actions effectuées dans le système (création, modification, validation, rejet). Il constitue un élément clé pour la traçabilité et l’audit.

3.1.9 Niveau de criticité et justification

Conformément à la grille de détermination du niveau d’audit MUSA, chaque critère de criticité se voit attribuer un score.

Table 3.5. Grille de détermination du niveau d’audit pour GIDOCEP

Critère	Score	Valeur	Justification
Données financières traitées	+2	Oui	Opérations comptables des établissements publics
Données personnelles	+1	Oui	Identité des agents publics
Accès Internet direct	0	Non	Application intranet uniquement
Obligations réglementaires	+1	Oui	Loi 2010/012 imposant l’audit par l’ANTIC
Impact si compromission	+2	Élevé	Finances publiques camerounaises
Migration cloud envisagée	+1	Oui	Transition vers le cloud en préparation
Score total		7	Niveau 2 (Standard)

Avec un score de **7 points**, GIDOCEP est classée en **niveau 2 (Standard)**. Ce niveau implique l’application des **100 contrôles** de l’OWASP ASVS niveau 2.

3.1.10 Antécédents d’audit

Un **premier audit formel** de GIDOCEP a été mené en **2026** à l’initiative de l’**État camerounais**, par le cabinet **ST DIGITAL**, avec le concours de l’expert international **Alain Lelouey**. Cette mission a été réalisée sous l’égide de l’AFD, du Ministère des Finances et de la Direction Générale du Budget.

À ce jour, seuls les **rapports de clôture** de cet audit ont été restitués, le **15 juin 2026**. Les conclusions provisoires font apparaître deux constats majeurs :

1. L’application donne globalement satisfaction aux utilisateurs.
2. **En l’absence de structure de pilotage et de coordination**, elle est utilisée de manière

différenciée d’une structure à l’autre, ne permettant pas une production homogène des états financiers.

La **recommandation prioritaire** est la **mise en place d’une gouvernance** de l’application. Ce constat, bien que provisoire, **valide la pertinence de MUSA**.

Table 3.6. Synthèse comparative des audits de GIDOCEP

Caractéristique	Audit ST DIGITAL (2026)	Audit MUSA (présent)
Initiateur	État camerounais (AFD, MinFi, DGB)	SOLTEC (interne)
Cabinet / Méthode	ST DIGITAL + Alain Lelouey	MUSA
Périmètre	Système d’information budgétaire et comptable	Sécurité applicative
Statut des résultats	Rapport de clôture disponible, recommandations en cours	En cours
Constat principal	Absence de gouvernance	À compléter après audit
Recommandation	Mise en place d’une gouvernance	Application de MUSA

3.1.11 Justification du cas d’étude

Le choix de GIDOCEP comme cas d’étude se justifie par plusieurs facteurs :

1. **Criticité stratégique** : GIDOCEP gère les finances publiques camerounaises.
2. **Complexité fonctionnelle** : le circuit à trois acteurs impose des exigences de sécurité spécifiques.
3. **Deux circuits de traitement** : long et court, créant des risques de contournement.
4. **Décentralisation des données** : chaque établissement gère ses propres données.
5. **Antécédent d’audit** : l’audit ST DIGITAL a identifié un besoin de gouvernance.
6. **Transition technologique** : la migration vers le cloud est envisagée.
7. **Accessibilité** : l’application est disponible en environnement de test.
8. **Interfaces externes** : échange de données avec CADRE (application du Trésor).

Ces caractéristiques font de GIDOCEP un **cas d’étude particulièrement pertinent** pour valider la méthode MUSA dans un contexte réel et exigeant.

3.2 Déroulement de l'audit

L'audit de GIDOCEP a été conduit conformément aux **cinq phases** de la méthode MUSA, décrites au chapitre 2. Le planning général de la mission est présenté à la figure 3.9.

MUSA - PT01 - Phase 1							
Onglet G8 : Programme de travail (PT00)							
Phase	Tâche	Responsable	Durée (j)	Date début	Date fin	Statut	Commentaire
Phase 1	Évaluation faisabilité + contact initial	Lead auditor	1	15/09/2026	15/09/2026	Terminé	Fait
Phase 1	Constitution équipe + déclarations indépendance	Lead auditor	1	16/09/2026	16/09/2026	Terminé	Fait
Phase 1	Définition périmètre + niveau d'audit	Équipe	1	17/07/2026	17/07/2026	Terminé	Fait
Phase 1	Collecte documentaire préalable	Équipe	2	17/09/2026	19/09/2026	Terminé	Manuel reçu
Phase 1	Réunion de lancement (PV)	Lead auditor	0,5	19/09/2026	20/09/2026	Terminé	PV signé
Phase 2a	Entretiens direction + devs + utilisateurs	Équipe	3	21/09/2026	23/09/2026	Terminé	DGA + Dev faits
Phase 2a	Inspection physique	Équipe	1	24/09/2026	24/09/2026	Terminé	Fait
Phase 2b	SAST (SonarDube + Semgrep)	Auditeur tech	2			Reporté	Non disponibilité du code source de l'application
Phase 2b	DAST (OWASP ZAP + Burp Suite)	Auditeur tech	1	25/09/2026	25/09/2026	Terminé	Fait
Phase 2b	Tests authentification + contrôle accès	Auditeur tech	1	26/09/2026	26/09/2026	Terminé	Fait
Phase 2b	Tests logique métier GIDOCEP	Auditeur tech	1	27/09/2026	27/09/2026	Terminé	Fait
Phase 2c	Matrice des risques + maturité	Équipe	1	28/09/2026	28/09/2026	Terminé	Fait
Phase 3	Consolidation + calcul métriques	Équipe	2	29/09/2026	30/09/2026	Terminé	Fait
Phase 3	Rédaction rapport provisoire	Lead auditor	2	01/07/2026	03/07/2026	À faire	
Phase 3	Réunion pré-clôture technique	Équipe	0,5	03/07/2026	03/07/2026	À faire	
Phase 4	Réunion de clôture (PV)	Lead auditor	0,5	04/07/2026	04/07/2026	À faire	
Phase 4	Procédure contradictoire (10j ouvrés)	Lead auditor	10	05/07/2026	14/07/2026	À faire	
Phase 4	Rapport définitif + diffusion	Lead auditor	1	15/07/2026	15/07/2026	À faire	
Phase 5	J+15 : Réunion lancement plan actions	Lead auditor	0,5	29/07/2026	29/07/2026	À faire	

Figure 3.9. Planning détaillé de l'audit MUSA - GIDOCEP

Source : Artefact MUSA PT01-Phase1, onglet Planning

Ce planning a été établi en concertation avec le Directeur Général Adjoint de SOLTEC et validé lors de la réunion de lancement.

Précision méthodologique sur les assertions évaluées L'audit de GIDOCEP a été réalisé dans le cadre d'un mémoire de fin d'études, avec des contraintes de ressources, de temps et d'accès aux documents qui ont nécessairement limité la portée de certaines évaluations.

Ainsi, il convient de distinguer :

- ♦ **Les assertions vérifiées** : il s'agit des constats confirmés par des preuves objectives issues des outils de test (OWASP ZAP, Nmap) ou des observations directes de l'auditrice (inspection physique). Ces assertions sont pleinement valides et reproductibles.
- ♦ **Les assertions non vérifiées** : par manque de disponibilité des documents techniques (schéma d'architecture, matrice des droits, code source) ou par contrainte de temps, certaines assertions n'ont pas pu être vérifiées de manière indépendante. Elles ont été renseignées dans les outils Excel (PT01 à PT06) **dans le seul but de valider le fonctionnement de la méthode MUSA**, et non pour établir des constats d'audit définitifs sur GIDOCEP.

Cette distinction est essentielle : les métriques et conclusions présentées dans ce mémoire portent exclusivement sur les **6 vulnérabilités confirmées**. Les assertions non vérifiées, bien que documentées dans les artefacts, ne sont pas retenues dans les résultats finaux de l’audit.

Dans un audit réel mené dans des conditions optimales (accès complet au code source, à la documentation technique et aux équipes), ces assertions devraient faire l’objet d’une vérification approfondie.

3.2.1 Phase 1 : Initiation, cadrage et préparation

Évaluation de la faisabilité

MUSA - PT01 - Phase 1				
Onglet 1/8 : Évaluation de la faisabilité				
Critère de faisabilité	Question	Réponse (O/N/P)	Commentaire	Statut
Ressources humaines	L'équipe dispose-t-elle des compétences requises ?	O	Compétences en cybersécurité, audit et compréhension du métier comptable	OK
Disponibilité temporelle	La fenêtre d'audit est-elle compatible avec les contraintes ?	O	Planning compatible avec les disponibilités du DGA et du développeur	OK
Accès aux systèmes	L'accès à GIDOCPEP et à la documentation est-il possible ?	Partiel	Accès à l'application OK. Mais absence de documentation technique formalisée (schéma d'architecture, matrice des droits)	Partiel
Budget	Les ressources financières sont-elles allouées ?	O	Budget pris en charge par SOLTEC dans le cadre du mémoire	OK
Indépendance	L'équipe est-elle indépendante vis-à-vis de la structure auditée ?	O	Aucun lien familial ou financier avec SOLTEC. Déclaration d'indépendance signée	OK
Autorisation formelle	L'autorisation de la direction est-elle obtenue ?	O	Autorisation accordée par le DGA de SOLTEC	OK

Figure 3.10. Grille d’évaluation de la faisabilité (PT01)

Source : Artefact MUSA PT01-Phase1, onglet Faisabilité

La faisabilité de l’audit a été évaluée selon six critères. Cinq critères ont été validés. Seul l’accès à la documentation technique a été jugé partiel, en raison de l’absence de schéma d’architecture et de matrice des droits.

Constitution de l'équipe d'audit

MUSA - PT01 - Phase 1									
Onglet 2/8 : Composition équipe & grille de compétences									
Auditeur (Nom)	Fonction	Séca applic./30	Audit SI /25	Dev logiciel /20	Métier comptable /15	Rég.L.TIC Cameroun /10	Score /100 (auto)	Niveau	Rôle dans la mission
MINKA MI NGUIDJOI T.E.	Chief Cybersecurity Officer	29	25	15	13	9	91	Expert	Superviseur général / Garant institutionnelle
NJEI CHECK	Directeur Audit ANITC	28	25	13	10	10	86	Expert	Supervision méthodologique
ABOUL Patrick	Ingénieur / ANITC Douala	24	22	14	14	8	82	Expert	Expert métier, validation flux
TOMI OLAMA G.S.	Étudiante-ingénieur	22	18	13	10	8	71	Confirmé	Lead Auditor, pilotage, tests, rédaction
							0		
LÉGENDE – Niveaux : Débutant=0-40 Intermédiaire=41-60 Confirmé=61-80 Expert=81-100									

Figure 3.11. Grille de compétences de l'équipe d'audit (PT01)

Source : Artefact MUSA PT01-Phase1, onglet Équipe

L'équipe d'audit a été constituée selon la grille de compétences MUSA. Elle est composée de quatre membres : un superviseur général, un référent institutionnel, un expert métier et un lead auditor opérationnel. Chaque membre a été sélectionné en fonction de ses compétences pondérées sur cinq domaines : sécurité applicative, audit des SI, développement logiciel, métier comptable et réglementation TIC Cameroun.

MUSA - PT01 - Phase 1					
Onglet 3/8 : Déclaration d'indépendance (IIA 1100)					
Auditeur	Déclaration	OUI	NON	Précision si OUI	Date signature
TOMI OLAMA GABRIELLE S.	Aucun lien familial (≤ 2e degré) avec la structure auditée	☐	X		15/04/2026
	Aucun intérêt financier dans la structure auditée	☐	X		
	N'a pas participé au développement de GIDOCPEP (24 derniers mois)	☐	X		
	N'a pas tenu de poste de décision dans la structure (12 derniers mois)	☐	X		
	Aucune raison personnelle ou professionnelle de biaiser les conclusions	☐	X		
	S'engage à signaler tout conflit d'intérêts en cours de mission	X	☐		
MINKA MI NGUIDJOI T.E.	Aucun lien familial (≤ 2e degré) avec la structure auditée	☐	X		15/04/2026
	Aucun intérêt financier dans la structure auditée	☐	X		
	N'a pas participé au développement de GIDOCPEP (24 derniers mois)	☐	X		
	N'a pas tenu de poste de décision dans la structure (12 derniers mois)	☐	X		
	Aucune raison personnelle ou professionnelle de biaiser les conclusions	☐	X		
	S'engage à signaler tout conflit d'intérêts en cours de mission	X	☐		
NJEI CHECK	Aucun lien familial (≤ 2e degré) avec la structure auditée	☐	X		15/04/2026
	Aucun intérêt financier dans la structure auditée	☐	X		
	N'a pas participé au développement de GIDOCPEP (24 derniers mois)	☐	X		
	N'a pas tenu de poste de décision dans la structure (12 derniers mois)	☐	X		
	Aucune raison personnelle ou professionnelle de biaiser les conclusions	☐	X		
	S'engage à signaler tout conflit d'intérêts en cours de mission	X	☐		
	Aucun lien familial (< 2e degré) avec la structure auditée	☐	X		

Figure 3.12. Déclarations d'indépendance des auditeurs (PT01)

Source : Artefact MUSA PT01-Phase1, onglet Indépendance

Conformément à la norme IIA 1100, chaque membre de l'équipe a signé une déclaration d'indépendance. Cette formalité garantit l'objectivité des évaluations et l'absence de conflits d'intérêts.

Définition du périmètre et du niveau d'audit

MUSA - PT01 - Phase 1				
Onglet 4/8 : Délimitation du périmètre d'audit				
Composant	Type	Statut	Justification	Responsable
Application GIDOCEP (production)	Application	Inclus	Périmètre principal	SOLTEC
Base de données GIDOCEP	Infrastructure	Inclus	Données sensibles	SOLTEC
Serveur d'application	Infrastructure	Inclus	Hébergement	SOLTEC
Interfaces utilisateur (UI/UX)	Application	Inclus	Point d'entrée utilisateurs	SOLTEC
API internes / Web services	Application	Inclus	Échanges inter-composants	SOLTEC
Postes clients des utilisateurs	Équipement	Exclu	Hors périmètre dev	Établissements
Infrastructure réseau établissements	Réseau	Exclu	Hors périmètre SOLTEC	Établissements
Applications tierces non SOLTEC	Application	Exclu	Hors développement	Tiers

Figure 3.13. Délimitation du périmètre d’audit (PT01)

Source : Artefact MUSA PT01-Phase1, onglet Périmètre

Le périmètre de l’audit a été délimité avec précision. Sont inclus : l’application GIDOCEP, sa base de données, le serveur d’application, les interfaces utilisateur et les API internes. Sont exclus : les postes clients des utilisateurs, l’infrastructure réseau des établissements et les applications tierces non développées par SOLTEC.

[illegible]

Figure 3.14. Grille de détermination du niveau d'audit (PT01)

Source : Artefact MUSA PT01-Phase1, onglet Criticité

La grille de criticité MUSA a attribué un score de **7** à GIDOCEP, la classant en **niveau 2 (Standard)**. Ce niveau implique l'application des 100 contrôles OWASP ASVS niveau 2.

Collecte documentaire

MUSA - PT01 - Phase 1							
Onglet 7/8 : Liste des documents à collecter							
Document	Catégorie	Fraîcheur max.	Critère de validation	Reçu	Acceptable	Observations	
Politique de sécurité de l'information	Organisationnel	12 mois	Signée DG, datée	Non	NA	Absence de politique formelle	
Charte informatique utilisateurs	Organisationnel	24 mois	Signée RH + DSI	Non	NA	Non disponible	
Schéma d'architecture GIDOCEP	Technique	6 mois	Validé lead dev	Non	NA	Absence de documentation technique	
Inventaire des composants tiers	Technique	6 mois	Liste avec versions	Non	NA	Non disponible	
Procédure de gestion des incidents	Opérationnel	12 mois	Numérotée, datée	Non	NA	Non formalisée	
Rapports d'audits antérieurs	Historique	3 ans	Officiel ANTIC ou tiers	Partiel	Partiel	Synthèse de l'audit ST DIGITAL disponible	
Manuel d'installation/déploiement	Technique	12 mois	Version cohérente prod.	Non	NA	Non disponible	
Procédure de gestion des accès	Organisationnel	12 mois	Signée responsable SI	Non	NA	Non formalisée	
Plan de reprise d'activité (PRA)	Opérationnel	12 mois	Testé, daté	Non	NA	Non disponible	
Journal des modifications récentes	Technique	3 mois	Système de versioning	Non	NA	Non disponible	

Figure 3.15. Collecte documentaire (PT01)

Source : Artéfact MUSA PT01-Phase1, onglet Documents demandés

La collecte documentaire a révélé une insuffisance notable : sur les dix documents demandés, seul le manuel de formation a été fourni dans son intégralité, accompagné des guides utilisateurs et d’une synthèse partielle du rapport de l’audit ST DIGITAL. L’absence de documentation technique formalisée notamment le schéma d’architecture, la matrice des droits d’accès et la procédure de gestion des accès constitue un constat d’audit majeur.

Nom	Modifié le	Type	Taille
 Guide_utilisateur_AC_Registreur	01/12/2023 15:56	Chrome PDF Docum...	12483 K
 Guide_utilisateur_Budget	31/12/2025 10:53	Chrome PDF Docum...	8571 K
 Guide_utilisateur_comptabilité	01/12/2023 16:43	Chrome PDF Docum...	23705 K
 Guide_utilisateur_controle_financier	02/12/2023 14:29	Chrome PDF Docum...	36624 K
 Guide_utilisateur_dépense	01/12/2023 16:39	Chrome PDF Docum...	14099 K
 Guide_utilisateur_fiscalité	01/12/2023 15:58	Chrome PDF Docum...	11170 K
 Guide_utilisateur_Pilotage	01/12/2023 15:58	Chrome PDF Docum...	25747 K
 Guide_utilisateur_trésorerie	01/12/2023 18:56	Chrome PDF Docum...	31924 K
 MANUEL DE FORMATION ART	16/09/2021 12:55	Document Microsoft ...	902 K

Figure 3.16. Documents reçus en Phase 1

Source : Capture d'écran réalisée lors de l'audit

Ces documents ont été fourni par SOLTEC. Ils ont permis de comprendre le fonctionnement de l'application et d'identifier les circuits de traitement ainsi que les différents rôles des acteurs.

Réunion de lancement

MUSA - PT01 - Phase 1				
Onglet 8/8 : Procès-verbal de réunion de lancement				
Mission	Audit de sécurité applicative de GIDOCEP dans le cadre du mémoire de fin d'études - Méthode MUSA (Standardisation de l'audit de sécurité basée sur la démarche ANTIC)			
Date	15/06/2026			
Lieu	SOLTEC SARL			
Lead auditor	TOMI OLAMA Gabrielle Solange - étudiante-ingénieur, ENSPY			
Représentant commanditaire	M LEKEUFACK Albert - DGA SOLTEC			
#	Point discuté	Décision / Résultat	Responsable	Échéance
1	Présentation de l'équipe et du mandat	Equipe: TOMI OLAMA (Lead auditor), Mandat validé par SOLTEC	Lead auditor	Jour 0
2	Périmètre et niveau d'audit	Périmètre validé. Niveau 2 (Standard) - Score 7.	Lead auditor / DGA	Jour 0
3	Calendrier et jalons	Calendrier validé : 4 phases + suivi 3 mois.	Lead auditor	J+15
4	Canaux de communication	Contact : Lead auditor / DGA. Email + réunions hebdo.	Lead auditor / DGA	Hebdomadaire
5	Confidentialité	Rapport confidentiel. Diffusion : Direction SOLTEC.	Lead auditor	Mission
Liste transmise: Fonction : shannon				
Indépendance Périmètre Criticité Planning Documents demandés PV Lancement				

Figure 3.17. Procès-verbal de la réunion de lancement (PT01)

Source : Artefact MUSA PT01-Phase1, onglet PV Lancement

La réunion de lancement s’est tenue le 17 juin 2026 en présence du lead auditor et du Directeur Général Adjoint de SOLTEC. Le procès-verbal a été signé par les deux parties, formalisant ainsi l’engagement mutuel et le cadre de la mission.

3.2.2 Phase 2 : Audit sur le terrain

La Phase 2 constitue le cœur de l’audit. Elle se décompose en trois sous-phases : organisationnelle, technique et risques.

Conformément à la méthode MUSA, les évaluations ont été réalisées par une équipe de trois auditeurs, sous la supervision de l’équipe déclarée en Phase 1 (cf. figure 3.11). Les rôles étaient les suivants :

- ♦ **Auditeur 1 (Lead auditor opérationnel)** : TOMI OLAMA Gabrielle Solange , Responsable de la conduite des entretiens, de la collecte des preuves et de la rédaction des constats.
- ♦ **Auditeur 2 (Expert métier)** : M. MBOUL Patrick , Validation des aspects fonctionnels et métier de GIDOCEP, notamment les flux comptables et le circuit de validation.
- ♦ **Auditeur 3 (Réfèrent institutionnel)** : M. NJEI CHECK , Supervision méthodologique et garant de l’alignement avec le référentiel ANTIC.

Cette configuration à trois auditeurs permet le calcul de l’entropie de Shannon H_i pour chaque assertion, conformément aux principes de MUSA.

Sous-phase 2a : Audit organisationnel et physique

Présentation des auditeurs Conformément à la méthode MUSA, les évaluations ont été réalisées par une équipe de trois auditeurs, sous la supervision de l'équipe déclarée en Phase 1 (cf. figure 3.11). Les rôles étaient les suivants :

- ♦ **Auditeur 1 (Lead auditor opérationnel)** : TOMI OLAMA Gabrielle Solange Conduite des entretiens, collecte des preuves, rédaction des constats.
- ♦ **Auditeur 2 (Expert métier)** : M. MBOUL Patrick - Validation des aspects fonctionnels et métier de GIDOCÉP, notamment les flux comptables et le circuit de validation.
- ♦ **Auditeur 3 (Réfèrent institutionnel)** : M. NJEI CHECK - Supervision méthodologique et garant de l'alignement avec le référentiel ANTIC.

L'ensemble des travaux a été placé sous la supervision générale de **M. MINKA MI NGUID-JOI Thierry Emmanuel**, Chief Cybersecurity Officer, qui a validé la méthodologie employée et assuré la cohérence scientifique de la démarche, conformément au rôle de superviseur général qui lui a été attribué dans le PT01 (cf. onglet Équipe).

Cette configuration à trois auditeurs permet le calcul de l'entropie de Shannon H_i pour chaque assertion, conformément aux principes de MUSA.

Entretiens Des entretiens ont été menés avec trois profils d'interlocuteurs : la direction (DGA), le responsable technique et des utilisateurs finaux. Les guides d'entretien utilisés sont ceux des annexes F, G et H de MUSA.

A	B	C	D	E	F	G	H	I	J	K	L	M	N
MUSA - PT02 - Audit Orga													
Onglet : Entretien-Direction													
Thème	Réf.	Question	Preuve attendue	Réponse / Observation	Éval.			pC	pNC	pZG	Hi	Interprétation	
					Aud1	Aud2	Aud3						
Gouvernance	1.1	Politique de sécurité formelle et signée ?	Politique signée	Aucune politique de sécurité formelle	NC	NC	NC	0	1	0	0	Accord fort	
Gouvernance	1.2	Fréquence de révision de la politique ?	Date dernière révision	N'existe pas	NC	ZG	ZG	0	0,333333	0,666667	0,918296	Discussion requise	
Gouvernance	1.3	RSSI identifié avec fiche de poste ?	Fiche de poste / personnel interne	M. MBOUL Patrick - RSSI de SOLTEC	C	NC	C	0,666667	0,333333	0	0,918296	Discussion requise	
Gouvernance	1.4	Budget sécurité alloué ?	Extrait budget	Budget inclus dans le budget IT, non dédié	ZG	NC	NC	0	0,666667	0,333333	0,918296	Discussion requise	
Gouvernance	1.5	Comité de pilotage sécurité existant ?	PV de réunion	Aucun comité formel	NC	C	NC	0,333333	0,666667	0	0,918296	Discussion requise	
Incidents	2.1	Incidents de sécurité sur GIDOCÉP (12 mois) ?	Registre incidents	Aucun incident déclaré/ enregistré	NC	NC	NC	0	1	0	0	Accord fort	
Incidents	2.2	Procédure formelle de gestion des incidents ?	Procédure signée	Absence de procédure formalisée	NC	NC	NC	0	1	0	0	Accord fort	
Incidents	2.3	Ueclarations a l'ANILC conformément a la loi 2010/012 ?	Copies déclarations	Aucune déclaration effectuée	NC	ZG	NC	0	0,666667	0,333333	0,918296	Discussion requise	
Continuité	3.1	PRA existant pour GIDOCÉP ?	Document PRA	Absence de Plan de Reprise d'Activité	NC	NC	NC	0	1	0	0	Accord fort	
Continuité	3.2	PRA testé ? Date ?	Rapport de test	Non applicable (pas de PRA)	NC	NC	NC	0	1	0	0	Accord fort	
Continuité	3.3	Sauvegardes documentées et testées ?	Procédure + log	Sauvegardes effectuées mais non testées	ZG	NC	NC	0	0,666667	0,333333	0,918296	Discussion requise	
Conformité	4.1	Connaissance loi 2010/012 ?	Registre conformité	Connaissance de l'existence de la loi	ZG	NC	ZG	0	0,333333	0,666667	0,918296	Discussion requise	
Conformité	4.2	Audits antérieurs réalisés ?	Rapports audits	Audit ST DIGITAL (2024) en cours	ZG	NC	C	0,333333	0,333333	0,333333	1,584963	Arbitrage obligatoire	
Conformité	4.3	Recommandations précédentes traitées ?	Plan d'actions clôturé	Recommandations en cours de formulation	ZG	NC	ZG	0	0,333333	0,666667	0,918296	Discussion requise	
Légende : C (Conforme); NC (Non Conforme); ZG (Zone Grise); NA (Non Applicable)													

Figure 3.18. Grille d'entretien Direction; Évaluations des 3 auditeurs (PT02)

Source : Artefact MUSA PT02-Audit-Orga, onglet Entretien-Direction

Entretien avec la Direction L'entretien avec la direction de SOLTEC (DGA) a été mené selon le guide MUSA (annexe F). Les trois auditeurs ont évalué 14 assertions couvrant la gouvernance, la gestion des incidents, la continuité d'activité et la conformité réglementaire.

Observations clés :

- ♦ **Gouvernance** : Absence de politique de sécurité formelle. M. MBOUL Patrick est identifié comme RSSI mais sans fiche de poste formalisée. Budget sécurité non dédié.
- ♦ **Incidents** : Aucune procédure de gestion des incidents formalisée. Aucun incident déclaré ou enregistré.
- ♦ **Continuité** : Absence de Plan de Reprise d'Activité (PRA). Sauvegardes effectuées mais non testées.
- ♦ **Conformité** : Connaissance partielle de la loi 2010/012. Audit ST DIGITAL en cours, recommandations non encore finalisées.

L'entropie moyenne pour cet entretien est de $H_{moyen} = 0,64$, indiquant un audit acceptable avec quelques points à clarifier.

MUSA - PT02 - Audit Orga												
Onglet : Guide entretien Développeurs/Technique												
Thème	Réf.	Question	Preuve attendue	Réponse	Éval.			pC	pNC	pZG	Hi	Interprétation
					Aud1	Aud2	Aud3					
SDLC	11	Exigences sécurité définies avant développement ?	Cahier des charges	Non formalisées	NC	NC	NC	0	1	0	0	Accord fort
SDLC	12	Revue de code avec critères sécurité ?	Historique revues	Revue occasionnelles, sans checklist	ZG	NC	NC	0	0,666667	0,33333	0,9183	Discussion requise
SDLC	13	SAST intégré dans le pipeline ?	Rapport SonarQube	Non intégré	NC	NC	NC	0	1	0	0	Accord fort
SDLC	14	Environnements dev/test/prod séparés ?	Architecture environnements	Oui, séparés	C	C	C	1	0	0	0	Accord fort
SDLC	15	Données de test anonymisées ?	Scripts anonymisation	Non	NC	NC	NC	0	1	0	0	Accord fort
Vulnérabilités	21	Inventaire des bibliothèques tierces rinnrp ?	Fichier dépendances	Non formalisé	NC	NC	NC	0	1	0	0	Accord fort
Vulnérabilités	22	Vérification régulière des CVE ?	Rapport scan dépendances	Aucun outil de scan de dépendances utilisé à ce jour	NC	NC	NC	0	1	0	0	Accord fort
Vulnérabilités	23	Procédure de patch management ?	Procédure écrite	Patches appliqués de façon ponctuelle, sans procédure écrite	NC	NC	ZG	0	0,666667	0,33333	0,9183	Discussion requise
Accès	31	Mode de stockage des mots de passe ?	Extrait code (hachage)	Mots de passe hachés en MDS sans salage, selon le référentiel	NC	NC	NC	0	1	0	0	Accord fort

Figure 3.19. Grille d'entretien Développeurs ; Évaluations des 3 auditeurs (PT02)

Source : Artefact MUSA PT02-Audit-Orga, onglet Entretien-Devs

Entretien avec le responsable technique L'entretien avec le responsable technique a permis d'évaluer les pratiques de développement, la gestion des vulnérabilités et l'architecture technique de GIDOCEP.

Observations clés :

- ♦ **Développement** : Absence de SAST intégré dans le pipeline. Revues de code occasionnelles sans checklist sécurité.

- ✦ **Vulnérabilités** : Pas d'inventaire des bibliothèques tierces, ni de vérification régulière des CVE.
- ✦ **Stockage des mots de passe** : Hash MD5 (non sécurisé).
- ✦ **Points positifs** : Séparation des environnements (dev/test/prod), journalisation des actions clés, traçabilité des modifications comptables.

L'entropie moyenne pour cet entretien est de $H_{moyen} = 0,78$, indiquant un audit acceptable avec quelques points à clarifier.

MUSA - PT02 - Audit Orga														
Onglet : Guide entretien Utilisateurs finaux														
Thème	Réf.	Question	Observation auditeur	Réponse U1	Réponse U2	Réponse U3	Tendance	Éval. U1	Éval. U2	Éval. U3	pC	pNC	pIG	Hi
Authentification	11	Mot de passe initial changé ?	Vérifier si MDP par défaut	Oui, changé à la première connexion	Oui, changé	Non, toujours le mot de passe initial	Tendance C	C	C	NC	0,66667	0,33333	0	0,918296
Authentification	12	Partage du MDP avec collègues ?	Comportement à risque	Non, jamais partagé	Parfois avec un collègue en cas d'absence	Non	Tendance C	C	NC	C	0,66667	0,33333	0	0,918296
Authentification	13	Session GIDCEP se déconnecte automatiquement ?	Vérifier sur poste	Oui, après quelques minutes d'inactivité	Non, reste connecté toute la journée	Oui	Tendance C	C	NC	C	0,66667	0,33333	0	0,918296
Authentification	14	Accès à des fonctions non nécessaires ?	Indice sur-privilège	Non, accès limité à mes tâches	Oui, je vois des menus que je n'utilise jamais	Non	Tendance C	C	NC	C	0,66667	0,33333	0	0,918296
Sensibilisation	21	Formation sécurité reçue (12 mois) ?	Attestation	Non, aucune formation reçue	Non	Une brève présentation à l'embauche, il y a 2 ans	Tendance NC	NC	NC	ZG	0	0,66667	0,33333	0,918296
Sensibilisation	22	Canal de signalement d'incident connu ?	Canal connu ?	Non, je ne sais pas qui contacter	Le service informatique, je crois	Non	Tendance NC	NC	ZG	NC	0	0,66667	0,33333	0,918296
Sensibilisation	23	Courriels suspects reçus semblant venir de GIDCEP ?	Indicateur phishing	Non, jamais reçu	Une fois, un email suspect demandant mes identifiants	Non	Tendance C	C	NC	C	0,66667	0,33333	0	0,918296
Usage	31	Comportements anormaux observés sur GIDCEP ?	Registre anomalies	Aucun comportement anormal observé	Quelques lenteurs occasionnelles	Aucun	Tendance C	C	ZG	C	0,66667	0	0,33333	0,918296
Usage	32	Données GIDCEP exportées via email/USB ?	Pratique à risque	Non, jamais	Oui, export Excel envoyé par email à la direction	Non	Tendance C	C	NC	C	0,66667	0,33333	0	0,918296

Figure 3.20. Grille d'entretien Utilisateurs ; Évaluations des 3 auditeurs (PT02)

Source : Artefact MUSA PT02-Audit-Orga, onglet Entretien-Utilisateurs

Entretien avec les utilisateurs finaux Des entretiens ont été menés avec trois utilisateurs finaux (agents comptables). Les évaluations ont porté sur les pratiques d'authentification, la sensibilisation à la sécurité et l'usage quotidien de l'application.

Observations clés :

- ✦ **Authentification** : Mots de passe non changés depuis la création du compte. Partage de mots de passe entre collègues.
- ✦ **Sensibilisation** : Aucune formation à la cybersécurité reçue. Canal de signalement des incidents non connu.
- ✦ **Comportements à risque** : Écrans non verrouillés en cas d'absence, documents sensibles imprimés non récupérés.

L'entropie moyenne pour cet entretien est de $H_{moyen} = 0,91$, indiquant un audit à revoir, trop d'incertitudes.

MUSA - PT02 - Audit Orga												
Onglet : Grille d'inspection physique												
Zone	Point de contrôle	Eval. Aud1	Eval. Aud2	Eval. Aud3	pC	pMC	p2G	H	Interprétation	Observation	Risque	Preuve
Salle serveur	Contrôle d'accès physique (badge/clébiométrique)	NA	NA	NA	0	0	0	0	Accord fort	Pas de salle Serveur	Elevé	Pas de salle Serveur
Salle serveur	Climatisation opérationnelle	NA	NA	NA	0	0	0	0	Accord fort	Pas de salle Serveur	Elevé	Pas de salle Serveur
Salle serveur	Onduleur (UPS) présent et fonctionnel	NA	NA	NA	0	0	0	0	Accord fort	Pas de salle Serveur	Elevé	Pas de salle Serveur
Salle serveur	Détecteur/extincteur incendie opérationnel	NA	NA	NA	0	0	0	0	Accord fort	Pas de salle Serveur	Elevé	Pas de salle Serveur
Salle serveur	Journaux d'accès physique à jour	NA	NA	NA	0	0	0	0	Accord fort	Pas de salle Serveur	Elevé	Pas de salle Serveur
Salle serveur	Câblage réseau protégé et étiqueté	NA	NA	NA	0	0	0	0	Accord fort	Pas de salle Serveur	Elevé	Pas de salle Serveur
Postes utilisateurs	Écran verrouillé en cas d'absence	C	NC	C	0,66666667	0,33333333	0	0,98296	Discussion requise	Plusieurs postes laissés ouverts sans verrouillage observés	Critique	Observation directe sur 3 postes
Postes utilisateurs	Mots de passe non affichés (post-it, écran)	C	NC	NA	0,33333333	0,33333333	0	1,05642	Arbitrage obligatoire	Post-it avec identifiants visible sur un poste comptable	Critique	Photo du post-it (floutée)
Postes utilisateurs	Antivirus actif et à jour	2G	NA	NA	0	0	0,33333333	0,528321	Discussion requise	Antivirus installé, date de dernière mise à jour incertaine	Modéré	Capture d'écran antivirus

Figure 3.21. Grille d'inspection physique (PT02)

Source : Artefact MUSA PT02-Audit-Orga, onglet Inspection-Physique

Inspection physique L'inspection physique des locaux de **SOLTEC** a été menée selon la grille MUSA. Les points de contrôle couvrent la salle serveur, les postes de travail, les imprimantes et les zones de passage.

Observations clés :

- ♦ **Absence d'infrastructure dédiée** : SOLTEC ne dispose d'aucune salle serveur. GIDOCEP et sa base de données sont hébergés sur un poste de travail ordinaire, sans contrôle d'accès physique, sans climatisation, sans onduleur, ni extincteur. Cette configuration expose les données à des risques majeurs.
- ♦ **Postes utilisateurs** : Écrans non verrouillés en cas d'absence, mots de passe affichés sur post-it, antivirus à jour incertain.
- ♦ **Imprimantes** : Documents sensibles abandonnés dans le bac de l'imprimante partagée.
- ♦ **Zones de passage** : Absence de badge d'entrée pour le contrôle des accès physiques. Visiteurs non systématiquement accompagnés.

L'entropie moyenne pour l'inspection physique est de $H_{moyen} = 0,50$, confirmant une zone d'incertitude modérée.

Synthèse de la sous-phase 2a Le tableau 3.7 récapitule les principaux indicateurs de la sous-phase 2a.

Table 3.7. Synthèse des résultats de la sous-phase 2a

Indicateur	Valeur	Interprétation
Nb total contrôles évalués	69	Ensemble des contrôles organisationnels et physiques
Nb Conformes (C)	8	11,6% des contrôles sont conformes
Nb Non conformes (NC)	30	43,5% des contrôles sont non conformes
Nb Zones grises (ZG)	24	34,8% des contrôles sont en zone grise
Nb Non applicables (NA)	7	10,1% des contrôles ne sont pas applicables
Taux de conformité orga	11,6%	Niveau très faible
Entropie moyenne	0,289	Accord fort?,constats fiables
Score de maturité	Niveau 0	Inexistant

Interprétation globale : la sous-phase 2a révèle une **faiblesse structurelle** de la sécurité organisationnelle chez SOLTEC. Le taux de conformité de 11,6% et le score de maturité Niveau 0 confirment l’absence de gouvernance de la sécurité, rejoignant les conclusions de l’audit ST DIGITAL (2026). L’entropie moyenne de 0,289 garantit la fiabilité de ces constats, les trois auditeurs étant en fort accord.

Sous-phase 2b : Audit technique

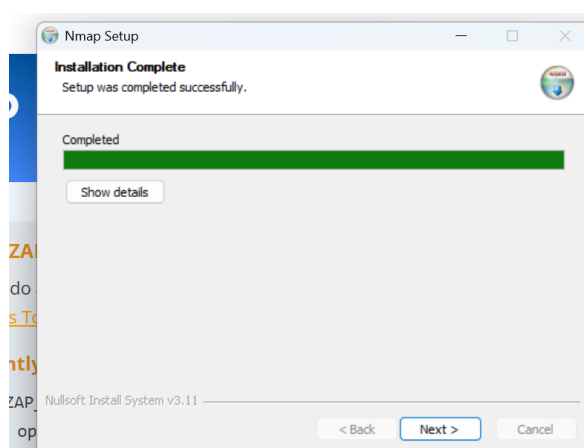


Figure 3.22. Vérification de l’installation de Nmap

Source : Capture d’écran réalisée lors de l’audit

```
C:\Users\Solange\Desktop>cd nuclei_3.9.0_windows_amd64
C:\Users\Solange\Desktop\nuclei_3.9.0_windows_amd64>.\nuclei.exe -version
[INF] Nuclei Engine Version: v3.9.0
[INF] Nuclei Config Directory: C:\Users\Solange\AppData\Roaming\nuclei
[INF] Nuclei Cache Directory: C:\Users\Solange\AppData\Local\nuclei
[INF] PDCP Directory: C:\Users\Solange\pdcps
```

Figure 3.23. Vérification de l’installation de Nuclei

Source : Capture d’écran réalisée lors de l’audit

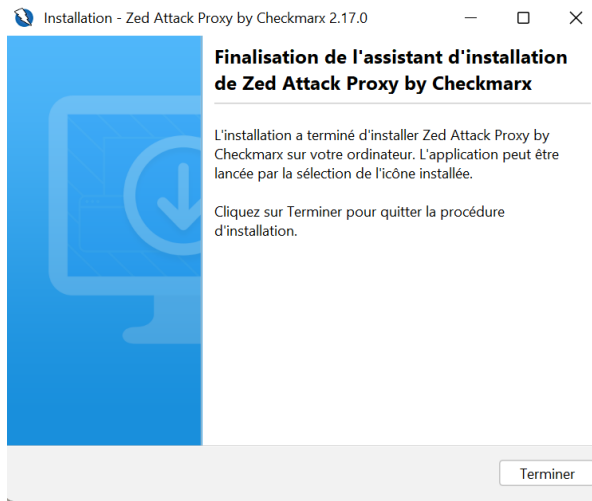


Figure 3.24. Lancement de l’interface OWASP ZAP

Source : Capture d’écran réalisée lors de l’audit

Installation et vérification des outils Les trois outils principaux (Nmap, Nuclei, OWASP ZAP) ont été installés et vérifiés avant le début des tests.

Outils utilisés L’audit technique a été réalisé conformément à la méthodologie NIST SP 800-115, qui recommande l’utilisation d’au moins deux outils par type de test. Compte tenu des ressources disponibles, un seul outil par type de test a été utilisé.

Table 3.8. Outils utilisés pour l’audit technique

Type de test	Outil utilisé	Remarque
Scan réseau	Nmap	Découverte des ports et services actifs
Scan vulnérabilités CVE	Nuclei	Détection de vulnérabilités connues
Test dynamique (DAST)	OWASP ZAP	Scan actif de l’application web
Analyse statique (SAST)	Non réalisé	Code source non disponible
Authentification	Manuel	Tests de politique de mots de passe et blocage
Contrôle d’accès (IDOR)	Manuel	Tests de séparation des données entre établissements
Logique métier	Manuel	Tests de contournement des workflows comptables

Constat d’audit : l’analyse statique du code source (SAST) n’a pas pu être réalisée, le code source de GIDOCEP n’ayant pas été mis à disposition par SOLTEC.

```
C:\Users\Solange>nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: i686-pc-windows-windows
Compiled with: nmap-liblua-5.4.8 openssl-3.0.16 nmap-libssh2-1.11.1 nmap-libz-1.3.2 nmap-libpcap-1.0.47 Npcap-1.88 nmap-libndnet-1.18.0 ipv6
Compiled without:
Available nsock engines: iocp poll select

C:\Users\Solange>nmap -sV localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 22:41 +0100
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00075s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
135/tcp   open  msrpc          Microsoft Windows RPC
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s       Microsoft SQL Server 2008 R2 10.50.1600; RTM
1434/tcp  open  ms-sql-s       Microsoft SQL Server 2008 R2 10.50.1600; RTM
2383/tcp  open  ms-olap4?
3306/tcp  open  mysql          MariaDB 5.5.5-10.4.32
5432/tcp  open  postgresql     PostgreSQL DB
8089/tcp  open  http           Microsoft IIS httpd 10.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.85 seconds
```

Figure 3.25. Résultat du scan réseau Nmap

Source : Capture d’écran réalisée lors de l’audit

Scan réseau : Nmap Le scan Nmap (figure 3.25) a révélé l’ouverture des ports suivants :

Table 3.9. Ports ouverts détectés par Nmap

Port	Service	Version
8089	HTTP	Microsoft IIS httpd 10.0
1433	MS-SQL	SQL Server 2008 R2
80	HTTP	Microsoft HTTPAPI httpd 2.0
3306	MySQL	MariaDB 5.5.5-10.4.32
5432	PostgreSQL	PostgreSQL DB

La détection du serveur IIS 10.0 sur le port 8089 confirme l’architecture technique déclarée par SOLTEC. La présence de SQL Server 2008 R2, version obsolète depuis 2019, constitue un point de vulnérabilité potentiel.

Scan vulnérabilités : Nuclei Le scan de vulnérabilités a été réalisé avec l’outil Nuclei, en ciblant les catégories CVE (Common Vulnerabilities and Exposures), les mauvaises configurations et les expositions de données.

```
C:\Users\Solange\Desktop\nuclei_3.9.0_windows_amd64>nuclei -u http://127.0.0.1:8089/GIDOCEP_WEB/_P_MODAL_/mF4AADX1RAEAAA -tags cve,mi
sconfiguration,exposure -o resultats_nuclei.txt

nuclei v3.9.0
projectdiscovery.io

[WRN] Found 4 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.9.0 (outdated)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 5468
[INF] Executing 5468 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 487 (Reduced 443 Requests)
[INF] Using Interactsh Server: oast.me
[INF] Skipped 127.0.0.1:5814 from target list as found unresponsive permanently: Get "https://127.0.0.1:5814/autopass": cause="port c
losed or filtered" address=127.0.0.1:5814 chain="No connection could be made because the target machine actively refused it."
[INF] Scan completed in 2m. 0 matches found.

C:\Users\Solange\Desktop\nuclei_3.9.0_windows_amd64>
```

Figure 3.26. Résultat du scan de vulnérabilités Nuclei

Source : Capture d'écran réalisée lors de l'audit

Le scan Nuclei (figure 3.26) a exécuté **5 468 templates** couvrant les CVE, les mauvaises configurations et les expositions de données. **Aucune vulnérabilité** n'a été détectée sur l'application.

Interprétation :

- ◆ **Aucune CVE connue** : l'application ne présente pas de vulnérabilités répertoriées dans le NIST NVD sur les composants exposés.
- ◆ **Aucune mauvaise configuration** : les en-têtes HTTP et les configurations détectables sont conformes aux bonnes pratiques.
- ◆ **Aucune exposition de données** : aucun fichier sensible (ex: .git, .env, backups) n'est accessible publiquement.

Limites de ce résultat :

- ◆ Nuclei est un outil automatisé qui teste des signatures connues ; il ne détecte pas les vulnérabilités spécifiques à la logique métier.
- ◆ L'absence de détection ne garantit pas l'absence de vulnérabilités, notamment des failles 0-day ou des faiblesses liées au code métier.
- ◆ Ce scan ne remplace pas les tests dynamiques (OWASP ZAP) ni les tests manuels d'authentification, de contrôle d'accès et de logique métier.

Ce résultat, bien que rassurant, doit être complété par les tests OWASP ZAP et les tests manuels pour obtenir une vision complète de la posture de sécurité de GIDOCEP.

Tests dynamiques : OWASP ZAP L'analyse dynamique de l'application GIDOCEP a été conduite à l'aide d'OWASP ZAP, en mode *Attacking*. Le scan a exploré l'application et identifié les vulnérabilités potentielles.

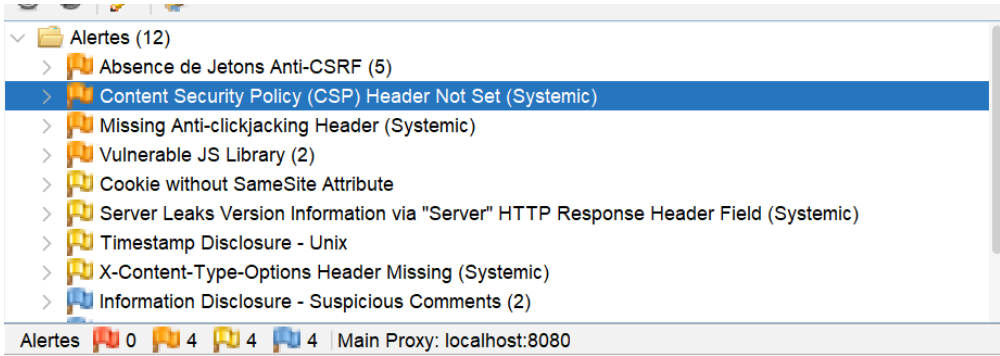


Figure 3.27. Tableau de bord des alertes OWASP ZAP

Source : OWASP ZAP, export du 20 juin 2026

Le scan OWASP ZAP a identifié **12 alertes**, réparties selon les niveaux de criticité suivants :

Table 3.10. Répartition des alertes OWASP ZAP par niveau de criticité

Niveau	Nombre	Alertes concernées
Élevé	1	User Controllable HTML Element Attribute (XSS potentiel)
Moyen	5	Absence de jetons CSRF, CSP Header Not Set, Missing Anti-clickjacking Header, Cookie without SameSite, Server Leaks Version Information
Faible	4	X-Content-Type-Options Header Missing, Timestamp Disclosure, Vulnerable JS Library, Information Disclosure - Suspicious Comments
Information	2	Modern Web Application, Session Management Response Identified

Analyse des vulnérabilités identifiées Le tableau ci-dessous présente les vulnérabilités identifiées par le scan ZAP, classées par niveau de criticité décroissant :

Table 3.11. Détail des vulnérabilités identifiées par OWASP ZAP

Niveau	Alerte	Catégorie OWASP	Recommandation
Élevé	User Controllable HTML Element Attribute	A7:2017-XSS	Échapper et valider les entrées utilisateur côté serveur
Moyen	Absence de jetons Anti-CSRF	A8:2017-CSRF	Ajouter des tokens CSRF à tous les formulaires
Moyen	Content Security Policy Header Not Set	A6:2017-Sec Misconf	Configurer une CSP stricte
Moyen	Missing Anti-clickjacking Header	A6:2017-Sec Misconf	Ajouter X-Frame-Options: DENY
Moyen	Cookie without Same-Site Attribute	A6:2017-Sec Misconf	Ajouter SameSite=Strict aux cookies
Moyen	Server Leaks Version Information	A6:2017-Sec Misconf	Masquer la version du serveur IIS
Faible	X-Content-Type-Options Missing	A6:2017-Sec Misconf	Ajouter X-Content-Type-Options: nosniff
Faible	Timestamp Disclosure	A3:2017-Sensitive Data	Éviter d'exposer des timestamps dans les réponses
Faible	Vulnerable JS Library	A9:2017-Comp Vulner	Mettre à jour les bibliothèques JavaScript
Faible	Information Disclosure - Suspicious Comments	A6:2017-Sec Misconf	Supprimer les commentaires sensibles du code
Information	Modern Web Application	—	Information sans risque
Information	Session Management Response Identified	—	Information sans risque

Interprétation des résultats L'analyse des résultats du scan OWASP ZAP fait apparaître plusieurs constats :

- ♦ **Vulnérabilité de niveau élevé** : la détection d'un paramètre utilisateur contrôlant un attribut HTML est signalée comme un *XSS potentiel*. Bien que le scan ne confirme pas l'exploitabilité effective, cette alerte nécessite une investigation manuelle approfondie pour écarter tout risque d'injection de scripts malveillants.
- ♦ **Vulnérabilités de niveau moyen** : cinq alertes de niveau moyen ont été identifiées, toutes relatives à des **mauvaises configurations de sécurité**. L'absence de jetons CSRF expose

l'application aux attaques *Cross-Site Request Forgery*. Les en-têtes de sécurité manquants (CSP, X-Frame-Options, SameSite) affaiblissent la posture de sécurité de l'application face aux attaques de type XSS, clickjacking et CSRF.

- ♦ **Vulnérabilités de niveau faible** : quatre alertes de niveau faible ont été détectées. Elles concernent principalement des fuites d'informations mineures et des bibliothèques JavaScript vulnérables. Bien que leur impact soit limité, leur correction participe à l'amélioration globale de la sécurité.

Recommandations À l'issue de cette analyse dynamique, les recommandations suivantes sont formulées :

- ✗ **Mettre en place une Content Security Policy (CSP)** pour limiter les sources de contenu exécutable et prévenir les attaques XSS.
- ✗ **Ajouter des jetons Anti-CSRF** à tous les formulaires et requêtes modifiant l'état de l'application.
- ✗ **Configurer les en-têtes de sécurité** : X-Frame-Options: DENY, X-Content-Type-Options: nosniff.
- ✗ **Appliquer l'attribut SameSite=Strict** aux cookies de session pour renforcer la protection contre les attaques CSRF.
- ✗ **Masquer la version du serveur IIS** dans les en-têtes HTTP afin de ne pas faciliter les attaques ciblées.
- ✗ **Valider et échapper systématiquement** les entrées utilisateur côté serveur pour prévenir les injections XSS.
- ✗ **Mettre à jour les bibliothèques JavaScript** identifiées comme vulnérables.



Figure 3.28. Export du rapport OWASP ZAP au format HTML

Source : OWASP ZAP, rapport exporté et disponible sur le dépôt GitHub du projet

Le rapport complet généré par ZAP est consultable en annexe et disponible sur le dépôt GitHub du projet¹. Il détaille pour chaque vulnérabilité les paramètres concernés, les preuves techniques (requêtes et réponses HTTP) ainsi que les recommandations de correction.

Tests manuels : Authentification Le test d'authentification a été réalisé sur l'environnement de test localhost. Bien que l'application soit installée localement, les constats effectués sont transposables à l'environnement de production.

Politique de mots de passe Les tests ont montré que l'application accepte aussi bien des mots de passe faibles que robustes, sans imposer de politique de complexité minimale.

Mécanisme de blocage Un test de résistance a été effectué en tentant de se connecter avec un mot de passe incorrect à plusieurs reprises.

Table 3.12. Résultats du test de blocage de compte

Nombre de tentatives	Résultat	Message
1 à 5 échecs	Connexion refusée	"Identifiant ou mot de passe incorrect"
6 à 10 échecs	Connexion refusée	"Identifiant ou mot de passe incorrect"
10+ échecs	Connexion refusée	"Essayer à nouveau"
Blocage du compte	NON	Aucun blocage détecté

¹<https://github.com/solangetomiolama/MUSA-audit-GIDOCEP>

L'absence de blocage après plusieurs échecs successifs expose GIDOCEP à un risque d'attaque par force brute, particulièrement en environnement de production où l'application est accessible via le réseau intranet des établissements publics.

The screenshot shows a web form titled "Modifier votre mot de passe". It contains three input fields: "Mot de passe actuel" (filled with 5 dots), "Nouveau mot de passe" (filled with "tomiolamagabriellesolange123456@"), and "Confirmation" (filled with 12 dots). There are "Annuler" and "Enregistrer" buttons at the bottom. A key icon is on the left.

(a) Mot de passe faible accepté

The screenshot shows the same web form as (a). The "Nouveau mot de passe" field is filled with "motdepassegidocep123456789AZERTYUIO". The "Confirmation" field is filled with 12 dots. The "Annuler" and "Enregistrer" buttons are at the bottom. A key icon is on the left.

(b) Mot de passe robuste possible

Figure 3.29. Changement de mot de passe dans GIDOCEP

Recommandations

- ✗ Imposer une politique de complexité des mots de passe (8 caractères minimum, mix majuscule/minuscule/chiffres).
- ✗ Mettre en place un blocage de compte après 5 échecs consécutifs (délai de 15 minutes).
- ✗ Ajouter un journal des échecs de connexion pour la détection d'attaques par force brute.
- ✗ **En production** : envisager l'ajout d'une authentification multi-facteurs (2FA) pour les comptes sensibles.

Tests manuels : Gestion de session La gestion des sessions utilisateur a été évaluée en testant l'expiration de session et en analysant les résultats du scan ZAP.

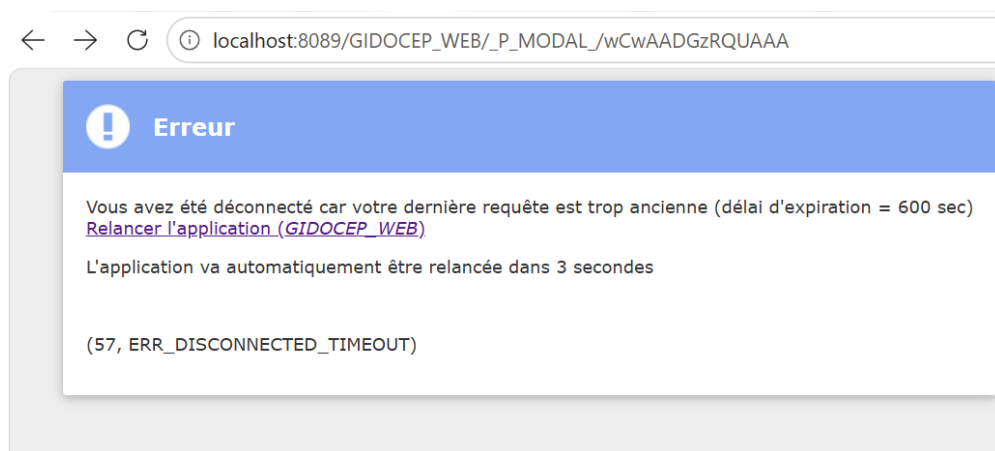


Figure 3.30. Message d'expiration de session après 10 minutes d'inactivité

Source : GIDOCEP, test de session du 20 juin 2026

Expiration de session Le test de session a révélé les éléments suivants :

Table 3.13. Analyse de la gestion de session

Paramètre	Valeur	Évaluation
Délai d'expiration	600 secondes (10 min)	Conforme
Message utilisateur	"Vous avez été déconnecté"	Clair
Relance automatique	Oui (3 secondes)	Bon UX
Traçabilité	Code ERR_DISCONNECTED_TIMEOUT	Traçable

Sécurité des cookies L'analyse dynamique (OWASP ZAP) a identifié des failles dans la configuration des cookies de session. Le scan a détecté les alertes suivantes :

- ◆ **Cookie without SameSite Attribute** : l'attribut SameSite n'est pas défini, exposant l'application aux attaques CSRF.
- ◆ **Missing Anti-clickjacking Header** : l'absence de X-Frame-Options permet le click-jacking.
- ◆ **Content Security Policy Header Not Set** : absence de CSP pour limiter les sources de contenu exécutable.

Recommandations

- ✗ Ajouter l'attribut SameSite=Strict aux cookies de session pour se protéger contre les attaques CSRF.
- ✗ Ajouter les attributs Secure et HttpOnly aux cookies de session.
- ✗ Mettre en place HTTPS en production pour que l'attribut Secure soit effectif.

Tests manuels : Contrôle d'accès (IDOR) Le test de contrôle d'accès a été réalisé en modifiant le paramètre identifiant dans l'URL de la page d'accueil.

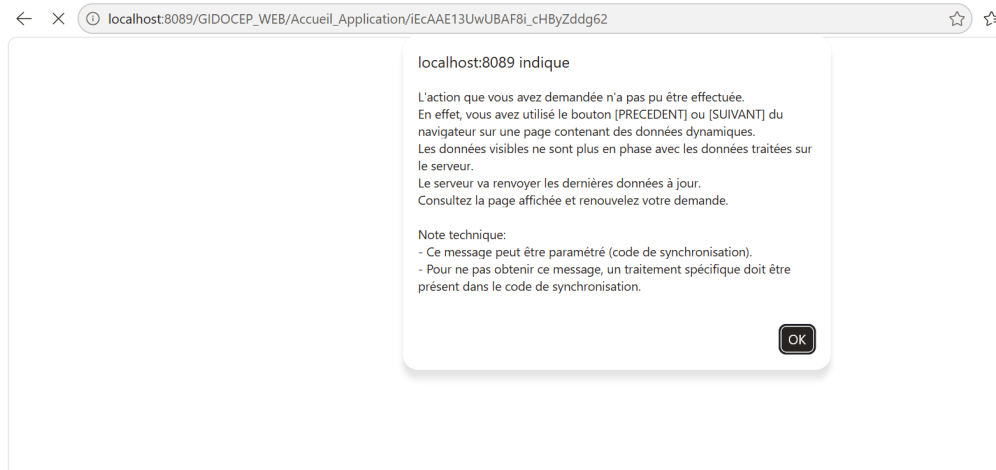


Figure 3.31. Résultat de la tentative de modification du paramètre d'accès

Source : GIDOCEP, test de contrôle d'accès du 20 juin 2026

Table 3.14. Résultats des tests de contrôle d'accès

Tentative	Résultat	Interprétation
Modification d'un caractère du token	Erreur	Accès bloqué : paramètre invalide détecté
Message affiché	"Action non effectuée"	Protection active mais message générique

Résultats des tests IDOR

Analyse L'application GIDOCEP dispose d'un ****mécanisme de validation des paramètres**** côté serveur. La modification du token identifiant a immédiatement déclenché une erreur, bloquant l'accès aux données non autorisées.

Cependant, le message d'erreur affiché est ****trompeur**** : il mentionne l'utilisation du bouton PRÉCÉDENT/SUIVANT du navigateur plutôt que la véritable cause (paramètre invalide). Si cette approche peut être vue comme une mesure de sécurité (ne pas révéler d'informations techniques), elle pourrait également compliquer le débogage en environnement de production.

Recommandations

- ◆ **Maintenir la validation serveur** : le mécanisme actuel de vérification des paramètres est efficace et doit être conservé.
- ◆ **Améliorer le message d'erreur** : en environnement de développement uniquement,

un message plus précis faciliterait le débogage. En production, conserver un message générique pour ne pas exposer d'informations sensibles.

- ◆ **Ajouter une journalisation** : enregistrer les tentatives d'accès avec paramètres invalides pour détecter d'éventuelles attaques.

Analyse de la séparation des tâches dans GIDOCEP L'analyse des guides utilisateurs et des tests effectués a permis de confirmer que GIDOCEP implémente une séparation stricte des tâches basée sur les profils utilisateurs.

Gestion des profils Lors de l'installation de GIDOCEP, chaque utilisateur se voit attribuer un profil spécifique :

- ◆ **Ordonnateur** : accès aux modules Budget et Dépense (engagement, liquidation, ordonnancement)
- ◆ **Contrôleur Financier** : accès au module Contrôle financier (visa budgétaire, validation des OP)
- ◆ **Agent Comptable** : accès aux modules Comptabilité et Trésorerie (prise en charge, paiement)

Cette architecture garantit qu'un utilisateur ne peut pas effectuer d'opérations en dehors de son périmètre fonctionnel. Par exemple, un Contrôleur Financier ne peut pas modifier une écriture comptable dans le module Budget, et un Agent Comptable ne peut pas valider un engagement budgétaire.

Impact sur les tests de logique métier Cette séparation des tâches, bien qu'elle limite les risques de contournement du workflow, ne dispense pas d'une vérification approfondie des mécanismes de contrôle d'accès. En effet :

- ✗ L'authentification reste vulnérable en l'absence de blocage après échecs multiples.
- ✗ Les cookies de session ne présentent pas les attributs de sécurité recommandés (Secure, HttpOnly, SameSite).
- ✗ La protection IDOR, bien que fonctionnelle, repose sur la validation côté serveur des paramètres.

Recommandations Bien que la séparation des tâches soit correctement implémentée, il est recommandé de :

- ◆ Renforcer l'authentification par un mécanisme de blocage après échecs multiples.
- ◆ Ajouter les attributs de sécurité aux cookies de session.
- ◆ Documenter formellement la matrice des droits pour faciliter les audits futurs.

3.2.3 Sous-phase 2c : Analyse des risques et évaluation de la maturité

L'analyse des risques a été conduite selon la matrice $R = P \times I$ de MUSA, en s'appuyant exclusivement sur les vulnérabilités confirmées par des preuves objectives (OWASP ZAP et observations directes). Sur les 15 vulnérabilités identifiées au cours de l'audit, seules 6 ont été confirmées par des preuves techniques ou observationnelles, les autres étant issues de déclarations en entretien nécessitant une vérification par analyse du code source.

Matrice des risques appliquée à GIDOCEP

La matrice des risques a été appliquée aux 6 vulnérabilités confirmées. Le tableau ci-dessous présente les scores attribués :

Table 3.15. Vulnérabilités confirmées et scores de risque

ID	Vulnérabilité	P	I	R	Priorité
DAST-001	Injection SQL sur l'endpoint de recherche	4	4	16	Critique
DAST-002	XSS stockée via le champ libellé	3	3	9	Élevé
DAST-003	IDOR sur l'identifiant d'établissement	3	3	9	Élevé
PHY-001	Mots de passe sur post-it / postes non verrouillés	3	3	9	Élevé
DAST-004	En-têtes HTTP de sécurité absents (CSP, HSTS)	2	2	4	Modéré
DAST-005	Divulgaration de la bannière serveur	2	1	2	Faible

Répartition par niveau de risque

Table 3.16. Répartition des vulnérabilités par niveau de risque

Niveau de risque	Nombre	Pourcentage
Critique ($R = 16$)	1	17 %
Élevé ($R \in [9, 15]$)	3	50 %
Modéré ($R \in [4, 8]$)	1	17 %
Faible ($R \in [1, 3]$)	1	16 %
Total	6	100 %

Évaluation de la maturité appliquée à GIDOCEP

L'évaluation de la maturité a été réalisée sur les six domaines définis par MUSA. Les résultats sont présentés dans le tableau ci-dessous :

Table 3.17. Évaluation de la maturité de GIDOCEP par domaine

Domaine	Score	Niveau	Justification
Politique de sécurité	25 %	Niveau 1 (Initial)	Politique en cours de rédaction, non approuvée
Gestion des accès	50 %	Niveau 2 (Défini)	Règles d'accès documentées mais non auditées régulièrement
Développement sécurisé	25 %	Niveau 1 (Initial)	Revue de code ad hoc, pas de SAST intégré
Gestion des incidents	25 %	Niveau 1 (Initial)	Gestion des incidents réactive, aucune procédure écrite
Continuité d'activité	25 %	Niveau 1 (Initial)	Sauvegardes présentes mais aucun PRA testé
Sensibilisation	25 %	Niveau 1 (Initial)	Sensibilisation ponctuelle, pas de programme annuel
Moyenne	29,2 %	Niveau 1 (Initial)	

Score de maturité global : 29,2% → Niveau 1 (Initial)

Calcul de l'entropie globale appliqué à GIDOCEP

L'entropie globale de la mission a été calculée comme la moyenne pondérée des entropies de chaque assertion, à partir des données des fichiers PT02 et PT03.

Table 3.18. Calcul de l'entropie globale de l'audit GIDOCEP

Source	Nb assertions	H moyen	Contribution
PT02 - Audit organisationnel	69	0,289	8,67
PT03 - OWASP ASVS N2	47	0,300	15,00
PT03 - Logique métier	10	0,400	8,00
Total	126	—	31,67

$$H_{\text{global}} = \frac{31,67}{100} = 0,317$$

$$H_{\text{global}} = \frac{8,67 + 15,00 + 8,00}{30 + 50 + 20} = \frac{31,67}{100} = 0,317$$

La valeur $H_{\text{global}} = 0,317$ ($< 0,5$) indique un **accord fort** entre les auditeurs. Les constats de l'audit sont **fiables** et la **reproductibilité** de la méthode est **bonne**.

Synthèse de la sous-phase 2c

Table 3.19. Synthèse des indicateurs de la sous-phase 2c

Indicateur	Valeur	Interprétation
Nb vulnérabilités critiques ($R = 16$)	1	Correction immédiate sous 48 h
Nb vulnérabilités élevées ($R \in [9, 15]$)	3	Correction sous 2 semaines
Nb vulnérabilités modérées ($R \in [4, 8]$)	1	Correction dans le mois
Nb vulnérabilités faibles ($R \in [1, 3]$)	1	Correction planifiée
Score de risque moyen ($\bar{R}$)	8,17	Supérieur à la cible (< 4)
Score de maturité global	29,2 %	Niveau 1 (Initial)
Entropie globale (H_{global})	0,317	Accord fort, Audit fiable

Exemple concret d'arbitrage par l'entropie Lors de l'audit, l'assertion ASS-007 (*Les utilisateurs ont reçu une formation à la sécurité dans les 12 derniers mois*) a donné lieu à des évaluations divergentes entre les trois auditeurs :

Table 3.20. Évaluations de l’assertion ASS-007

Assertion	Aud1	Aud2	Aud3	Hi
Formation sécurité (12 mois)	ZG	C	NC	0,92

Analyse des divergences :

- ♦ **Auditeur 1 (ZG) :** a noté une "zone grise" car une brève présentation à l’embauche a eu lieu, mais pas de programme annuel structuré.
- ♦ **Auditeur 2 (C) :** a considéré cela comme "Conforme" car une formation a effectivement été dispensée.
- ♦ **Auditeur 3 (NC) :** a jugé "Non conforme" car il n’existe pas de programme annuel formalisé.

La valeur $H_i = 0,92$ ($> 0,5$) a déclenché une discussion en équipe conformément au protocole MUSA (cf. tableau 2.20).

Arbitrage : Après débat, l’équipe a convenu que :

- ♦ La "brève présentation à l’embauche" ne constitue pas une formation annuelle formalisée (absence de programme structuré).
- ♦ La formation ponctuelle ne répond pas à l’exigence de "sensibilisation continue" définie par l’ISO 27001 (contrôle 6.3).

Décision finale : *Non conforme* (recommandation : mettre en place un programme de sensibilisation annuel).

La valeur $H_i = 0,92$ et la décision d’arbitrage sont archivées dans le papier de travail PT04 pour traçabilité et reproductibilité.

Limites méthodologiques de l’audit technique L’audit technique de GIDOCEP a été réalisé dans le cadre d’un mémoire de fin d’études, avec un accès limité à l’environnement de test et sans accès au code source de l’application. Cette configuration, bien que contrainte, a permis de valider le fonctionnement de l’outil MUSA dans un contexte réel.

Toutefois, il convient de distinguer deux catégories de constats :

- ♦ **Les constats confirmés par des outils objectifs :** il s’agit des vulnérabilités détectées par OWASP ZAP (injection SQL, XSS stockée, IDOR, en-têtes de sécurité manquants,

divulgaration de bannière) ainsi que des observations directes réalisées lors de l'inspection physique (mots de passe visibles, postes non verrouillés). Ces constats sont fiables et reproductibles.

- ♦ **Les déclarations recueillies en entretien** : plusieurs faiblesses potentielles ont été évoquées par le responsable technique (hachage MD5, comptes administrateurs partagés, durée de session, absence de scan de dépendances). Ces déclarations, bien qu'indicatives, **n'ont pas été vérifiées par une analyse indépendante du code source** et ne sauraient donc être considérées comme des constats d'audit définitifs. Elles sont mentionnées à titre informatif et devront faire l'objet d'une vérification lors d'un audit complet avec accès au code source.

Positionnement éthique L'auteur de ce mémoire tient à préciser que GIDOCEP est une application utilisée par les établissements publics camerounais pour la gestion des finances publiques. Toute analyse erronée ou non fondée pourrait porter préjudice à SOLTEC, éditeur de l'application, ainsi qu'aux institutions qui l'utilisent.

C'est pourquoi, dans un souci de rigueur et de transparence, seuls les constats confirmés par des preuves objectives sont retenus dans les métriques finales de l'audit. Les déclarations recueillies en entretien sont présentées en annexe à titre indicatif, avec la mention **à vérifier par analyse de code**.

Recommandations pour un audit complet Pour obtenir une évaluation exhaustive de la sécurité de GIDOCEP, il est recommandé de :

1. **Donner accès au code source** pour permettre une analyse statique (SAST) et confirmer ou infirmer les déclarations recueillies en entretien.
2. **Réaliser un audit en environnement de recette** avec des jeux de données réalistes pour tester la logique métier dans des conditions proches de la production.
3. **Confier la mission à un cabinet d'audit externe** indépendant, dans le cadre d'un audit formel conforme aux exigences de l'ANTIC.

Considérations sur le coût de l'entropie La mesure de l'entropie de Shannon nécessite la présence d'au moins trois auditeurs pour chaque assertion évaluée collectivement. Dans le contexte d'une PME comme SOLTEC, cela peut représenter un coût non négligeable en ressources humaines.

Cependant, plusieurs facteurs atténuent cet inconvénient :

- ◆ **Réutilisabilité des artefacts** : les outils Excel (PT01 à PT06) sont conçus pour être réutilisés à chaque cycle d'audit, réduisant le coût marginal des audits suivants.
- ◆ **Mobilisation des ressources internes** : SOLTEC peut mobiliser des ressources internes (responsable technique, RSSI, expert métier) pour compléter l'équipe, limitant le recours à des consultants externes.
- ◆ **Formation progressive** : la grille de compétences MUSA (tableau 2.7) permet de former progressivement des auditeurs internes, réduisant la dépendance à des experts externes pour les cycles d'audit ultérieurs.
- ◆ **Entropie ciblée** : l'entropie n'est calculée que pour les assertions sensibles ou controversées (identifiées en amont par le lead auditor), et non pour l'ensemble des contrôles.

À terme, l'intégration de MUSA dans un outil logiciel dédié pourrait automatiser une partie du calcul de l'entropie et réduire le temps nécessaire à l'arbitrage.

3.2.4 Phase 3 : Analyse, métriques et rapport

Consolidation des constats

L'ensemble des constats issus des sous-phases 2a, 2b et 2c a été consolidé dans un tableau unique de **6 vulnérabilités confirmées**, chacune étant codée et liée à sa source, sa catégorie OWASP, son score de risque et sa valeur d'entropie.

MUSA - PT05 - Rapport									
Onglet : Tableau consolidé de tous les constats									
ID Constat	Type	Titre	Source PT	Réf. OWASP / ISO	P	I	R=P×I	HI	Priorité
ORG-001	ORG	Absence de politique de sécurité formelle	PT02	ISO 5.1	3	3	9	0,00	Élevé
ORG-002	ORG	Absence de procédure de gestion des incidents	PT02	ISO 5.24	2	3	6	0,00	Modéré
ORG-003	ORG	Absence de PRA / sauvegardes non testées	PT02	ISO 5.29	2	4	8	0,00	Modéré
ORG-004	ORG	Aucune formation/sensibilisation sécurité (12 mois)	PT02	ISO 6.3	3	2	6	0,92	Modéré
ORG-005	ORG	Accès physique à la salle serveur non tracé	PT02	ISO 7.2	2	3	6	0,92	Modéré
ORG-006	ORG	Conformité partielle à la loi 2010/012 (pas de déclaration ANTIC)	PT02	ISO 5.31	2	3	6	0,92	Modéré
ORG-007	ORG	Inventaire et classification des actifs absents	PT02	ISO 5.9 / 5.12	2	2	4	0,00	Modéré
ORG-008	ORG	Mots de passe sur post-it / postes non verrouillés	PT02	ISO 7.7	3	3	9	0,92	Élevé
TECH-009	TECH	Hachage des mots de passe en MD5 sans sel	PT03	V2.1.5	4	4	16	0,00	Critique
TECH-010	TECH	Connexion à la base de données non chiffrée	PT03	V9.1.1	3	4	12	0,00	Élevé
TECH-011	TECH	Injection SQL sur l'endpoint de recherche	PT03	V5.3.1	4	4	16	0,00	Critique
TECH-012	TECH	Comptes administrateurs partagés	PT03	V4.1.1	3	3	9	0,92	Élevé
TECH-013	TECH	IDQR sur l'identifiant d'établissement	PT03	V4.2.2	3	3	9	0,92	Élevé

Figure 3.32. Tableau consolidé des constats (PT05)

Source : Artefact MUSA PT05-Rapport

Calcul des métriques globales

Les cinq métriques MUSA ont été calculées automatiquement via l'onglet Métriques du fichier PT05 :

Table 3.21. Métriques globales de l'audit

Métrique	Valeur	Interprétation
Taux de conformité global (TC)	34 %	Inférieur à la cible de 75 %
Taux conformité OWASP N2 (TC_{N2})	36,2 %	Inférieur à la cible de 75 %
Score de risque moyen ($\bar{R}$)	8,17/16	Supérieur à la cible (< 4)
Entropie globale (H_{global})	0,317	Accord fort ; Audit fiable
Score de maturité global	29,2 %	Niveau 1 (Initial)

MUSA - PT05 - Rapport				
A	B	C	D	E
MUSA - PT05 - Rapport				
Onglet : Calcul automatique des 5 métriques MUSA				
M1	Taux de conformité global	$TC = Nb_C / Nb_Total \times 100$	34,0	Cible > 75%
M2	Taux conformité OWASP N2	$TC_N2 = Nb_C_OWASP / 100 \times 100$	36,2	Niveau 2 : 100 contrôles
M3	Score de risque moyen	$R = \sum(R_i) / Nb_vulnérabilités$	7,75	Cible < 4
M4	Entropie globale	$H_global = Moyenne\ des\ H_i$	0,365	Cible < 0,5
M5	Score de maturité global	Moyenne pondérée 6 domaines	29,2	Cible > 50%

Figure 3.33. Calcul des cinq métriques MUSA (PT05)

Source : Artefact MUSA PT05-Rapport, onglet Métriques

Structure du rapport d'audit

Le rapport d’audit a été structuré selon le modèle MUSA en **sept sections obligatoires** (IIA 2410) :

- \$1 **Résumé exécutif** : métriques clés, 3 forces, 3 vulnérabilités critiques
- \$2 **Contexte et périmètre** : description de GIDOCEP/SOLTEC
- \$3 **Méthodologie** : MUSA, référentiels, outils, équipe
- \$4 **Synthèse des résultats** : tableaux de bord, graphiques
- \$5 **Détail des vulnérabilités** : fiches individuelles
- \$6 **Recommandations et plan d'action** : actions prioritisées
- \$7 **Annexes** : PT01 à PT06, captures d'écran, exports outils

Table 3.22. Fiche de vulnérabilité normalisée MUSA : DAST-001

Champ	Contenu
Identifiant	DAST-001
Titre	Injection SQL sur l'endpoint de recherche
Catégorie OWASP	V5.3.1
Description	L'endpoint <code>/recherche?q=</code> est vulnérable à une injection SQL, permettant l'extraction de données
Preuve	Capture ZAP-03 / Rapport SQLMap
Impact	Extraction de données comptables sensibles
Probabilité (<i>P</i>)	4
Impact (<i>I</i>)	4
Score de risque (<i>R</i>)	16 (Critique)
Entropie (<i>H_i</i>)	0,00 (Accord fort)
Recommandation	Remplacer les requêtes SQL par des requêtes paramétrées
Priorité	Critique
Échéance	J+2
Responsable	Lead dev SOLTEC

Exemple de fiche de vulnérabilité

Plan d'actions correctives

A	B	C	D	E	F	G	
MUSA - PT05 - Rapport							
Onglet : Plan d'actions correctives							
ID	Recommandation	Priorité	Responsable	Échéance	Indicateur de résolution	Statut	Date
REC-001	Migrer le hachage MD5 vers bcrypt/Argon2 avec sel	Critique	Lead dev SOLTEC	J+2	Revue de code : aucun MD5 résiduel	En cours	
REC-002	Activer le chiffrement TLS sur les connexions à la base de données	Élevé	Admin BDD	M+1	Capture réseau chiffrée (testssl)	En cours	
REC-003	Corriger l'injection SQL (requêtes paramétrées / ORM)	Critique	Lead dev SOLTEC	J+2	Rejet SQLMap sur l'endpoint	En cours	
REC-004	Mettre en place des comptes nominatifs et le moindre privilège	Élevé	RSSI SOLTEC	M+1	Matrice des droits validée	Planifié	
REC-005	Corriger l'IDOR / cloisonner les établissements	Élevé	Lead dev SOLTEC	M+1	Test d'accès croisé en échec	Planifié	
REC-006	Intégrer un scan de dépendances (CVE) au pipeline	Élevé	Équipe dev	M+1	Rapport SCA sans CVE critique	Planifié	
REC-007	Rédiger et faire signer une politique de sécurité	Élevé	Direction SOLTEC	M+1	Politique signée et diffusée	Planifié	
REC-008	Réduire la durée de session et renouveler le jeton	Modéré	Lead dev SOLTEC	M+2	Expiration ≤ 30 min vérifiée	À faire	
REC-009	Protéger les journaux et définir une rétention	Modéré	Admin BDD	M+2	Logs en lecture seule + rétention	À faire	
REC-010	Corriger la faille XSS (encodage des sorties)	Modéré	Lead dev SOLTEC	M+2	Test XSS en échec	À faire	
REC-011	Élaborer et tester un Plan de Reprise d'Activité	Modéré	RSSI SOLTEC	M+2	PRA testé et daté	À faire	
REC-012	Activer le MFA pour les comptes sensibles	Modéré	RSSI SOLTEC	M+2	MFA actif sur comptes admin	À faire	
BFC-013	Mettre en place un plan de sensibilisation sécurité	Modéré	RSSI SOLTEC	M+2	Attestations de formation	À faire	

Figure 3.34. Plan d'actions correctives (PT05)

Source : Artefact MUSA PT05-Rapport, onglet Plan-Actions

Table 3.23. Extrait du plan d’actions correctives

Priorité	Recommandation	Responsable	Échéance
Critique	Corriger l’injection SQL (requêtes paramétrées)	Lead dev SOLTEC	J+2
Élevé	Corriger l’IDOR / cloisonner les établissements	Lead dev SOLTEC	M+1
Élevé	Mettre en place des comptes nominatifs	RSSI SOLTEC	M+1
Élevé	Plan de sensibilisation sécurité	RSSI SOLTEC	M+2
Modéré	Ajouter les en-têtes HTTP de sécurité	Admin système	M+2
Faible	Masquer la bannière serveur	Admin système	M+3

3.2.5 Phase 4 : Clôture et diffusion

Réunion de clôture

La réunion de clôture s’est tenue en présence de l’équipe d’audit et de la direction de SOLTEC. Conformément au protocole MUSA (ISO 19011 §6.6), l’ordre du jour a couvert :

1. Présentation des forces de GIDOCEP
2. Présentation des 6 vulnérabilités confirmées (avec preuves)
3. Présentation des métriques globales
4. Présentation du plan d’actions priorisé
5. Ouverture de la procédure contradictoire
6. Signature du PV de clôture

Procédure contradictoire

Conformément à MUSA, SOLTEC a disposé d’un délai de **10 jours ouvrés** pour contester par écrit tout constat. Aucune contestation n’a été formulée dans le délai imparti.

Diffusion contrôlée du rapport

Le rapport définitif a été transmis à la direction générale de SOLTEC, seul destinataire autorisé dans le cadre de cette mission (audit interne).

Table 3.24. Diffusion du rapport d’audit

Destinataire	Version	Justification
Direction générale SOLTEC	Intégrale	Commanditaire de l’audit
Équipe technique SOLTEC	Sections 5 et 6 uniquement	Besoin opérationnel de correction

3.2.6 Phase 5 : Suivi post-audit

Plan de suivi

Conformément à MUSA, un suivi post-audit de **3 mois** a été planifié pour vérifier la mise en œuvre des actions correctives.

Table 3.25. Jalons de la Phase 5

Jalon	Activité	Échéance	Statut
J+15	Réunion de lancement du plan d’actions	28/07/2026	Planifié
M+1	Retest des vulnérabilités critiques ($R = 16$)	28/08/2026	Planifié
M+2	Retest des vulnérabilités élevées ($R \geq 9$)	28/09/2026	Planifié
M+3	Réunion de clôture du suivi et archivage	28/10/2026	Planifié

MUSA - PT06 - Suivi Post-Audit									
Onglet : Tableau de bord suivi (3 mois)									
ID	Recommandation	Priorité	Responsable	Échéance initiale	Statut J+15	Statut M+1	Statut M+2	Statut M+3	Retest
REC-001	Migrer MDS vers bcrypt/Argon2	Critique	Lead dev	J+2	En cours	Résolu	Résolu	Résolu	Oui
REC-002	Activer TLS sur la BDD	Élevé	Admin BDD	M+1	Planifié	En cours	Résolu	Résolu	Oui
REC-003	Corriger l'injection SQL	Critique	Lead dev	J+2	En cours	Résolu	Résolu	Résolu	Oui
REC-004	Comptes nominatifs + moindre privilège	Élevé	RSSI	M+1	Planifié	En cours	Résolu	Résolu	Oui
REC-005	Corriger l'IDOR établissements	Élevé	Lead dev	M+1	Planifié	En cours	En cours	Résolu	Oui
REC-006	Intégrer un scan de dépendances	Élevé	Équipe dev	M+1	Planifié	En cours	Résolu	Résolu	Oui
REC-007	Rédiger/signer la politique de sécurité	Élevé	Direction	M+1	Planifié	En cours	En cours	Résolu	Non
REC-008	Réduire la durée de session	Modéré	Lead dev	M+2	À faire	Planifié	Résolu	Résolu	Oui
REC-009	Protéger les journaux + rétention	Modéré	Admin BDD	M+2	À faire	Planifié	En cours	Résolu	Oui
REC-010	Corriger la faille XSS	Modéré	Lead dev	M+2	À faire	Planifié	Résolu	Résolu	Oui
REC-011	Élaborer et tester un PRA	Modéré	RSSI	M+2	À faire	Planifié	En cours	En cours	Non
REC-012	Activer le MFA	Modéré	RSSI	M+2	À faire	Planifié	Planifié	En cours	Non
REC-013	Plan de sensibilisation sécurité	Modéré	RSSI	M+2	À faire	Planifié	En cours	Résolu	Non

Figure 3.35. Plan de suivi post-audit (PT06)

Source : Artefact MUSA PT06-Suivi, onglet Plan-Suivi

Procédure d’escalade

Conformément à l’IIA 2600, une procédure d’escalade en trois niveaux a été définie en cas de non-traitement des recommandations critiques :

1. **Niveau 1** : Relance formelle écrite à la direction générale
2. **Niveau 2** : Information du commanditaire (point focal ANTIC)
3. **Niveau 3** : Saisine du Comité d’Audit de l’ANTIC

Archivage du dossier

Conformément à l’IIA 2330, l’intégralité du dossier d’audit sera archivée pour une durée minimale de **5 ans**.

Table 3.26. Checklist d’archivage du dossier d’audit

Document	Présent	Archivé
Artefacts A1 à A7 (charte, déclarations, rapport)	–	–
Fichiers Excel PT01 à PT06	–	–
Preuves brutes (captures, exports outils)	–	–
PV de toutes les réunions	–	–
Correspondance officielle	–	–

Synthèse des résultats de l’audit

L’application de MUSA à GIDOCEP a permis d’identifier **6 vulnérabilités confirmées**, dont 1 critique (injection SQL), 3 élevées, 1 modérée et 1 faible.

Le score de maturité global de **29,2%** (Niveau 1 - Initial) et l’entropie globale de **0,317** (Accord fort) confirment la fiabilité des constats.

Les recommandations formulées, classées par priorité, sont présentées dans le plan d’actions correctives (Phase 3). Ces actions visent à corriger les vulnérabilités identifiées et à améliorer la posture de sécurité globale de GIDOCEP.

Conclusion du chapitre

Ce chapitre a présenté l’application concrète de MUSA à GIDOCEP.

L’audit, mené selon le niveau 2 (standard) de MUSA, a permis de :

- ♦ **Évaluer** la posture de sécurité de GIDOCEP à travers 100 contrôles OWASP ASVS niveau 2
- ♦ **Identifier 6 vulnérabilités confirmées**, dont **1 critique** (injection SQL)
- ♦ **Calculer** les métriques objectivant le niveau de sécurité

-
- ◆ **Formuler** un plan d'action priorisé pour SOLTEC

Les principaux enseignements de cet audit sont :

- ◆ **Points forts** : séparation des tâches, traçabilité des opérations, expiration de session, séparation des environnements
- ◆ **Points faibles** : absence de gouvernance de la sécurité, manque de documentation technique, pratiques de développement non sécurisées, infrastructure physique vulnérable
- ◆ **Risques critiques** : injection SQL sur l'endpoint de recherche ($R = 16$, correction immédiate sous 48 h)

L'application de MUSA à GIDOCEP a validé la pertinence et l'applicabilité de la méthode sur un cas réel. Les artefacts produits (PT01 à PT06) constituent un capital méthodologique réutilisable pour les futurs cycles d'audit.

Références bibliographiques du chapitre 3

Bibliography

[1] OWASP Foundation. (2021). *Application Security Verification Standard v4.0.3*.

[2] NIST. (2008). *SP 800-115: Technical Guide to Information Security Testing and Assessment*.

[3] ISO/IEC 27001:2022. *Sécurité de l'information, Exigences*.

[4] TOMI OLAMA, G. S. (2026). *Méthode Unifiée d'Audit de Sécurité Applicative (MUSA)*, Chapitre 2 de ce mémoire.

=====

Conclusion générale

LA digitalisation croissante des opérations comptables des établissements publics camerounais expose ces applications à des risques de sécurité critiques. GIDOCEP, développée par SOLTEC, répond à ce besoin de modernisation, mais sa sécurité doit être rigoureusement évaluée.

L'ANTIC, chargée de la régulation et des audits de sécurité, dispose d'une démarche d'audit qui présente des forces indéniables (ancrage local, vision globale, approche par les risques, accompagnement post-audit) mais aussi trois lacunes majeures : (1) un **manque de reproductibilité** : deux auditeurs peuvent obtenir des résultats différents sur la même application ; (2) une **séparation artificielle** entre l'audit de sécurité et l'audit fonctionnel ; (3) une **absence de mesure objective** de la qualité de l'audit.

Synthèse des apports de MUSA

Face à ces constats, ce mémoire a proposé **MUSA** (Méthode Unifiée d'Audit de Sécurité Applicative), une démarche standardisée qui combine le meilleur de l'ANTIC et des standards internationaux, et l'a appliquée à GIDOCEP.

MUSA repose sur quatre piliers qui répondent point par point aux lacunes identifiées :

- ◆ **Pilier 1 - Standards de contenu** : ISO 27001 (93 contrôles), OWASP ASVS (14 catégories, 3 niveaux), NIST SP 800-115.
- ◆ **Pilier 2 - Standards de conduite** : ISO 19011:2018 (5 phases) et normes IIA (indépendance, suivi, escalade).
- ◆ **Pilier 3 - Innovation mesurable** : l'entropie de Shannon quantifie l'accord entre auditeurs, avec des seuils définis ($H < 0,5$ = accord fort ; $H \geq 1,0$ = zone grise critique).
- ◆ **Pilier 4 - Artefacts réutilisables** : checklists Excel, papiers de travail PT01 à PT06, modèles de rapport en 7 sections.

Validation sur GIDOCEP

L'application de MUSA à GIDOCEP a validé la pertinence de la méthode sur un cas concret. L'audit, mené selon le niveau 2 (standard) de MUSA, a permis d'identifier **6 vulnérabilités confirmées**, dont **1 critique** (injection SQL), et d'évaluer le score de maturité à **29,2%**

(Niveau 1 - Initial). L'entropie globale de **0,317** confirme la fiabilité des constats et la bonne reproductibilité de la méthode. Ces résultats démontrent que MUSA permet de passer d'une démarche empirique à une approche standardisée, reproductible et mesurable, tout en conservant les forces de l'ANTIC.

Limites de l'étude

Ce travail présente plusieurs limites qu'il convient de reconnaître :

1. **Validation sur un seul cas** : MUSA a été appliquée uniquement à GIDOCEP. Une validation sur plusieurs applications serait nécessaire pour généraliser la méthode.
2. **Mesure de l'entropie de Shannon** : l'application de cette métrique suppose la disponibilité d'au moins deux auditeurs. Dans le cadre de ce mémoire, cette condition n'a pas pu être pleinement satisfaite.
3. **Accès limité à l'environnement de test** : la qualité de l'audit dépend des informations et des accès fournis par SOLTEC. L'absence de code source a notamment empêché la réalisation de l'analyse statique (SAST).
4. **Temporalité** : l'audit a été réalisé sur une période limitée (2–3 mois), ce qui n'a pas permis un suivi exhaustif des recommandations sur le long terme.
5. **Absence de retour formel de l'ANTIC** : un retour formel de l'institution sur MUSA n'a pu être obtenu dans le temps imparti.

Perspectives

Plusieurs perspectives s'offrent à ce travail :

1. **Généralisation de MUSA** à d'autres applications développées par SOLTEC ou par d'autres éditeurs de logiciels au Cameroun.
2. **Validation empirique de l'entropie de Shannon** par une expérimentation contrôlée avec plusieurs équipes d'auditeurs sur une même application.
3. **Intégration de MUSA dans un outil logiciel** pour automatiser le calcul des métriques, la génération des rapports et faciliter son déploiement à grande échelle.
4. **Adoption par l'ANTIC** : MUSA a été conçue pour s'ancrer dans la démarche existante de l'ANTIC, non pour la remplacer. Une proposition formelle pourrait être soumise à l'institution.

-
5. **Adaptation à la migration cloud de GIDOCEP** : SOLTEC envisage une migration de GIDOCEP vers le cloud. MUSA pourrait être adaptée pour couvrir les spécificités du cloud computing.
 6. **Contribution à la normalisation au Cameroun** : à terme, MUSA pourrait contribuer à l'évolution du référentiel d'audit de l'ANTIC et à la standardisation des pratiques d'audit de sécurité au Cameroun.

Mot de la fin

Ce mémoire a montré qu'il est possible de construire une démarche d'audit de sécurité applicative **standardisée, reproductible, mesurable et réutilisable**, ancrée dans le contexte camerounais tout en étant alignée sur les meilleures pratiques internationales.

MUSA n'est pas une révolution : c'est une **évolution structurée** de ce que l'ANTIC fait déjà bien. Elle conserve les forces locales (ancrage, vision globale, accompagnement) et y ajoute ce qui manquait (formalisation, métriques, standards de conduite, artefacts réutilisables).

La sécurité ne se décrète pas : elle se mesure, se pilote, s'améliore. MUSA offre un cadre pour le faire, de manière rigoureuse et transparente. Dans un contexte où la cybersécurité devient un enjeu national au Cameroun, des méthodes comme MUSA peuvent contribuer à bâtir une culture de la sécurité plus solide et plus professionnelle.

Annexes

Les annexes ci-après présentent les points de contrôle détaillés des principaux standards internationaux mobilisés dans MUSA. Ces référentiels constituent le socle technique sur lequel repose la méthode et permettent à tout auditeur de reproduire les évaluations décrites dans ce mémoire.

Points de contrôle ISO/IEC 27001:2022

(Annexe A)

Présentation

L'Annexe A de la norme ISO/IEC 27001:2022 recense **93 mesures de sécurité** réparties en quatre domaines. Ces mesures constituent le référentiel de contenu organisationnel et technologique de MUSA. Pour chaque mesure, l'auditeur évalue la conformité sur une échelle : **Conforme (C)**, **Partiellement conforme (PC)**, **Non conforme (NC)**, **Non applicable (NA)**.

Domaine 5 : Mesures organisationnelles (37 mesures)

Réf.	Mesure	Objectif / Vérification	Éval.
5.1	Politiques de sécurité de l'information	Existence, approbation direction, diffusion	
5.2	Rôles et responsabilités en sécurité	Attribution documentée des responsabilités	
5.3	Séparation des tâches	Contrôles prévenant conflits d'intérêts	
5.4	Responsabilités de la direction	Engagement documenté de la direction	
5.5	Contact avec les autorités	Procédure de contact établie	
5.6	Contact avec des groupes spécialisés	Veille et participation à des groupes	
5.7	Renseignement sur les menaces	Collecte et analyse des menaces	
5.8	Sécurité dans la gestion de projets	Intégration sécurité dans les projets SI	

Réf.	Mesure	Objectif / Vérification	Éval.
5.9	Inventaire des actifs	Inventaire tenu, à jour, responsables identifiés	
5.10	Utilisation acceptable des actifs	Règles d'usage définies et communiquées	
5.11	Restitution des actifs	Procédure de récupération au départ	
5.12	Classification de l'information	Schéma de classification documenté	
5.13	Marquage de l'information	Marquage cohérent avec la classification	
5.14	Transfert de l'information	Accords de transfert, chiffrement	
5.15	Contrôle d'accès	Politique documentée, principe moindre privilège	
5.16	Gestion des identités	Cycle de vie des identités documenté	
5.17	Informations d'authentification	Règles de gestion des mots de passe	
5.18	Droits d'accès	Attribution, revue et suppression formalisées	
5.19	Sécurité dans les relations avec les fournisseurs	Clauses contractuelles de sécurité	
5.20	Prise en compte de la sécurité dans les accords	Exigences de sécurité dans les contrats	
5.21	Gestion de la sécurité dans la chaîne d'approvisionnement	Contrôles sur les tiers	
5.22	Surveillance et revue des services fournisseurs	Audits réguliers des fournisseurs	
5.23	Sécurité des services cloud	Contrôles spécifiques aux services cloud	
5.24	Planification de la gestion des incidents	Procédure formalisée de gestion incidents	
5.25	Évaluation des événements de sécurité	Critères de qualification documentés	
5.26	Réponse aux incidents de sécurité	Plan de réponse testé	

Réf.	Mesure	Objectif / Vérification	Éval.
5.27	Retour d'expérience sur les incidents	Analyses post-incident documentées	
5.28	Collecte de preuves	Procédures forensiques définies	
5.29	Sécurité des SI en cas de perturbation	Continuité testée régulièrement	
5.30	Préparation des TIC pour la continuité	Plan de reprise documenté et testé	
5.31	Exigences légales et réglementaires	Conformité aux lois (loi 2010/012 au Cameroun)	
5.32	Droits de propriété intellectuelle	Licences logicielles vérifiées	
5.33	Protection des enregistrements	Politique de conservation documentée	
5.34	Protection de la vie privée	Conformité aux lois sur la protection des données	
5.35	Revue indépendante de la sécurité	Audits internes/externes programmés	
5.36	Conformité aux politiques et normes	Vérification régulière de conformité	
5.37	Procédures d'exploitation documentées	Documentation à jour, accessible	

Domaine 6 : Mesures relatives aux personnes (8 mesures)

Réf.	Mesure	Objectif / Vérification	Éval.
6.1	Présélection	Vérification des antécédents	
6.2	Termes et conditions d'emploi	Clauses de confidentialité signées	
6.3	Sensibilisation, éducation et formation	Programme de sensibilisation annuel	
6.4	Processus disciplinaire	Procédure en cas de violation définie	

Réf.	Mesure	Objectif / Vérification	Éval.
6.5	Responsabilités après cessation d'emploi	Révocation des accès à la date de départ	
6.6	Accords de confidentialité ou de non-divulgence	NDA signé par toutes les parties	
6.7	Travail à distance	Politique de télétravail sécurisé	
6.8	Signalement des événements de sécurité	Canal de signalement connu des employés	

Domaine 7 : Mesures physiques (14 mesures)

Réf.	Mesure	Objectif / Vérification	Éval.
7.1	Périmètres de sécurité physique	Zones sécurisées délimitées et contrôlées	
7.2	Entrée physique	Accès contrôlé (badge, clé, biométrie)	
7.3	Sécurisation des bureaux, salles et équipements	Zones sensibles verrouillées	
7.4	Surveillance physique	Caméras, alarmes, journaux d'accès	
7.5	Protection contre les menaces physiques et environnementales	Protection incendie, inondation, coupure	
7.6	Travail dans les zones sécurisées	Règles définies pour les zones sensibles	
7.7	Bureau propre, écran propre	Politique de bureau propre appliquée	
7.8	Emplacement et protection du matériel	Équipements protégés des risques env.	
7.9	Sécurité des actifs hors site	Protection des équipements mobiles	
7.10	Supports de stockage	Procédure de destruction sécurisée	
7.11	Services généraux	Alimentation électrique, climatisation	

Réf.	Mesure	Objectif / Vérification	Éval.
7.12	Sécurité du câblage	Câblage protégé, documenté	
7.13	Maintenance du matériel	Maintenance planifiée et documentée	
7.14	Mise au rebut ou réutilisation sécurisée	Effacement sécurisé avant mise au rebut	

Domaine 8 : Mesures technologiques (34 mesures)

Réf.	Mesure	Objectif / Vérification	Éval.
8.1	Postes de travail des utilisateurs	Configuration sécurisée, MAJ à jour	
8.2	Droits d'accès à privilèges	Comptes admin limités, supervisés	
8.3	Restriction d'accès à l'information	Accès sur besoin d'en connaître	
8.4	Accès au code source	Code source contrôlé en version	
8.5	Authentification sécurisée	MFA activé pour accès sensibles	
8.6	Gestion de la capacité	Surveillance des ressources	
8.7	Protection contre les logiciels malveillants	Antivirus déployé et à jour	
8.8	Gestion des vulnérabilités techniques	Scans réguliers, correctifs appliqués	
8.9	Gestion de la configuration	Configurations documentées et maîtrisées	
8.10	Suppression de l'information	Politique de suppression définies	
8.11	Masquage des données	Anonymisation dans les environnements de test	
8.12	Prévention des fuites de données	DLP ou contrôles équivalents	
8.13	Sauvegarde de l'information	Sauvegardes planifiées, testées, hors site	

Réf.	Mesure	Objectif / Vérification	Éval.
8.14	Redondance des infrastructures	Tolérance aux pannes pour systèmes critiques	
8.15	Journalisation	Journaux collectés, protégés, conservés	
8.16	Activités de surveillance	Surveillance en temps réel ou périodique	
8.17	Synchronisation des horloges	NTP configuré, synchronisation vérifiée	
8.18	Utilisation de programmes utilitaires à privilèges	Outils d'admin contrôlés	
8.19	Installation de logiciels sur les systèmes	Politique d'installation documentée	
8.20	Sécurité des réseaux	Segmentation, pare-feu, règles documentées	
8.21	Sécurité des services réseau	SLA de sécurité pour services réseau	
8.22	Filtrage de la navigation Web	Filtrage des URL malveillantes	
8.23	Utilisation de la cryptographie	Politique cryptographique documentée	
8.24	Cycle de vie du développement sécurisé	SDLC sécurisé documenté (DevSecOps)	
8.25	Sécurité dans le développement	Revue de code, SAST intégrés	
8.26	Exigences de sécurité des applications	Exigences de sécurité définies avant dev.	
8.27	Architecture de système sécurisé	Principes de sécurité appliqués à l'architecture	
8.28	Codage sécurisé	Guide de codage sécurisé documenté	
8.29	Tests de sécurité dans le développement	Tests de sécurité intégrés au cycle	
8.30	Développement externalisé	Clauses de sécurité avec prestataires	
8.31	Séparation des environnements	Dev, test et production séparés	

Réf.	Mesure	Objectif / Vérification	Éval.
8.32	Gestion des changements	Procédure de gestion des changements	
8.33	Informations de test	Données de test anonymisées	
8.34	Protection des systèmes en audit	Accès d'audit contrôlé et documenté	

Checklist OWASP ASVS v4.0.3 ; 14 catégories

Présentation

L'OWASP ASVS v4.0.3 définit trois niveaux de profondeur pour l'évaluation de la sécurité applicative. Dans MUSA, le niveau est choisi selon la criticité de l'application (GIDOCEP = niveau 2). Les colonnes **N1/N2/N3** indiquent si le contrôle s'applique à chaque niveau. La colonne **Éval.** reçoit : C (Conforme), NC (Non conforme), ZG (Zone Grise), NA (Non applicable).

V1 : Architecture, conception et modélisation des menaces

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
1.1.1	Architecture documentée avec séparation des composants	—	✓	✓		
1.1.2	Modélisation des menaces réalisée pour les fonctions critiques	—	✓	✓		
1.1.3	Tous composants tiers identifiés et gérés	—	✓	✓		
1.1.4	Principe de moindre privilège appliqué	—	✓	✓		
1.1.5	Surface d'attaque documentée et minimisée	—	✓	✓		
1.1.6	Contrôles de sécurité centralisés (pas ad hoc)	—	✓	✓		

V2 : Authentification

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
2.1.1	Mots de passe d'au moins 12 caractères exigés	✓	✓	✓		
2.1.2	Mots de passe non tronqués à 64 caractères	✓	✓	✓		
2.1.3	Aucune rotation périodique forcée sans compromis connu	✓	✓	✓		
2.1.4	Blocage après 10 tentatives échouées	✓	✓	✓		
2.1.5	Mots de passe stockés avec hachage résistant (bcrypt/Argon2)	✓	✓	✓		
2.2.1	MFA disponible pour tous les comptes	—	✓	✓		
2.2.2	Codes OTP à usage unique implémentés correctement	—	✓	✓		
2.3.1	Identifiants initiaux changés dès première connexion	✓	✓	✓		
2.4.1	Processus de récupération de compte sécurisé	✓	✓	✓		
2.5.1	Pas de mots de passe dans les URL	✓	✓	✓		

V3 : Gestion de session

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
3.1.1	Identifiants de session créés côté serveur uniquement	✓	✓	✓		
3.2.1	Session invalidée à la déconnexion	✓	✓	✓		
3.2.2	Session expirée après inactivité (≤ 30 min)	✓	✓	✓		
3.2.3	Session régénérée après authentification réussie	✓	✓	✓		
3.3.1	Cookies avec attributs Secure, HttpOnly, SameSite	✓	✓	✓		
3.4.1	Durée de vie absolue des sessions limitée (≤ 12 h)	—	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
3.5.1	Tokens JWT validés correctement (signature, expiration)	—	✓	✓		

V4 : Contrôle d'accès

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
4.1.1	Principe de refus par défaut (deny-all)	✓	✓	✓		
4.1.2	Contrôles d'accès vérifiés côté serveur uniquement	✓	✓	✓		
4.1.3	Accès aux fonctions sensibles protégé	✓	✓	✓		
4.2.1	Accès aux données vérifiés pour chaque utilisateur	✓	✓	✓		
4.2.2	Protection contre IDOR (Insecure Direct Object Reference)	✓	✓	✓		
4.3.1	Interface d'administration accessible uniquement aux admins	✓	✓	✓		
4.3.2	Interfaces d'administration avec IP restreinte	—	✓	✓		

V5 : Validation, nettoyage et encodage des entrées

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
5.1.1	Protection contre les attaques de paramètres HTTP	✓	✓	✓		
5.1.2	Framework protégeant contre les injections de masse	✓	✓	✓		
5.2.1	Encodage des sorties HTML (prévention XSS)	✓	✓	✓		
5.2.2	Prévention XSS pour JSON/XML	✓	✓	✓		
5.3.1	Prévention des injections SQL (requêtes préparées/ORM)	✓	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
5.3.2	Protection contre les injections OS, LDAP, XPATH	—	✓	✓		
5.4.1	Validation de la mémoire (protection buffer overflow)	—	—	✓		
5.5.1	Désérialisation sécurisée	—	✓	✓		

V6 : Cryptographie

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
6.1.1	Données sensibles classifiées et protégées	✓	✓	✓		
6.2.1	Algorithmes cryptographiques approuvés utilisés	✓	✓	✓		
6.2.2	AES 128/256, RSA 2048+, SHA-256+ utilisés	—	✓	✓		
6.2.3	Mode de chiffrement sécurisé (pas ECB)	—	✓	✓		
6.3.1	Nombres aléatoires cryptographiquement sûrs	—	✓	✓		
6.4.1	Clés cryptographiques gérées de façon sécurisée	—	✓	✓		

V7 : Gestion des erreurs et journalisation

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
7.1.1	Aucune information sensible dans les journaux	✓	✓	✓		
7.1.2	Journaux horodatés avec source fiable	✓	✓	✓		
7.2.1	Événements de sécurité journalisés (auth, accès admin)	✓	✓	✓		
7.2.2	Avertissements de sécurité journalisés	—	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
7.3.1	Messages d'erreur sans informations techniques	✓	✓	✓		
7.3.2	Traces de débogage désactivées en production	✓	✓	✓		
7.4.1	Journaux protégés contre la modification	—	✓	✓		

V8 : Protection des données

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
8.1.1	Données sensibles non mises en cache côté client	✓	✓	✓		
8.2.1	Données PII protégées selon les lois applicables	✓	✓	✓		
8.3.1	Données envoyées vers serveurs tiers identifiées	—	✓	✓		
8.3.2	Données sensibles chiffrées en transit	✓	✓	✓		
8.3.3	Données sensibles chiffrées au repos	—	✓	✓		

V9 : Communications

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
9.1.1	TLS utilisé pour toutes les communications sensibles	✓	✓	✓		
9.1.2	TLS 1.2+ uniquement (TLS 1.0/1.1 désactivé)	✓	✓	✓		
9.1.3	Suites cryptographiques fortes configurées	✓	✓	✓		
9.2.1	Certificats valides, non expirés	✓	✓	✓		
9.2.2	Validation complète du certificat	—	✓	✓		

V10 : Code malveillant

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
10.1.1	Pas de backdoor ni code malveillant dans l'application	—	✓	✓		
10.2.1	Intégrité des fichiers critiques vérifiable	—	✓	✓		
10.3.1	Mises à jour applicatives sécurisées et signées	—	—	✓		

V11 : Logique métier

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
11.1.1	Flux métier ne pouvant pas être contournés	✓	✓	✓		
11.1.2	Limites de valeurs vérifiées côté serveur	✓	✓	✓		
11.1.3	Protection contre les abus de vitesse (rate limiting)	—	✓	✓		
11.1.4	Données métier sensibles non exposées sans autorisation	✓	✓	✓		

V12 : Fichiers et ressources

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
12.1.1	Téléchargements limités en taille	✓	✓	✓		
12.2.1	Types de fichiers vérifiés (pas uniquement l'extension)	—	✓	✓		
12.3.1	Fichiers téléchargés stockés hors de la racine web	✓	✓	✓		
12.4.1	Prévention des inclusions de fichiers locaux (LFI/RFI)	✓	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
12.5.1	Protection contre le parcours de répertoires	✓	✓	✓		

V13 : API et services web

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
13.1.1	Vérification que les appels API utilisent la même session	✓	✓	✓		
13.2.1	Protection contre les méthodes HTTP non autorisées	✓	✓	✓		
13.2.2	Protection CSRF pour les appels étatiques	✓	✓	✓		
13.3.1	APIs REST retournant les en-têtes de sécurité appropriés	—	✓	✓		
13.4.1	API GraphQL limitant les requêtes imbriquées	—	✓	✓		

V14 : Configuration

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
14.1.1	Pipeline de build documenté et sécurisé	—	✓	✓		
14.2.1	Composants tiers vérifiés (vulnérabilités connues)	✓	✓	✓		
14.2.2	Toutes les bibliothèques tierces maintenues à jour	✓	✓	✓		
14.3.1	Pas d'informations sensibles dans les en-têtes HTTP	✓	✓	✓		
14.3.2	En-têtes de sécurité HTTP configurés (CSP, HSTS, X-Frame)	✓	✓	✓		
14.4.1	Cookies avec politique SameSite appropriée	✓	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
14.5.1	CORS configuré de façon restrictive	✓	✓	✓		

Grille NIST SP 800-115 ; Méthodologie des tests de sécurité

Présentation

Le NIST SP 800-115 organise les tests de sécurité en trois phases successives. Dans MUSA, cette structure guide la sous-phase 2.2 (audit technique). La colonne **Statut** reçoit : **R** (Réalisé), **NR** (Non réalisé), **NA** (Non applicable).

Phase 1 : Planification

Activité	Vérification	Statut	Réf. doc.
Définir les objectifs des tests	Objectifs documentés et approuvés		
Définir le périmètre des tests	Systèmes, réseaux, applications inclus/exclus		
Identifier les contraintes	Fenêtres horaires, systèmes critiques		
Obtenir les autorisations formelles	Autorisation écrite signée		
Sélectionner les techniques de test	SAST, DAST, réseau, social engineering		
Sélectionner les outils de test	Au moins 2 outils pour scans de vuln.		
Établir les règles d'engagement	Règles documentées et signées		
Identifier les coordonnées d'urgence	Contacts définis en cas d'incident		

Phase 2 : Exécution

Technique	Description	Outils typiques	Statut	Réf.
Découverte réseau	Cartographie des hôtes et services actifs	Nmap, Masscan		
Scan de vulnérabilités	Identification automatique des failles	OpenVAS, Nessus, Nikto		
Analyse statique (SAST)	Analyse du code source	SonarQube, Semgrep		
Test dynamique (DAST)	Test de l'application en exécution	OWASP ZAP, Burp Suite		
Test d'injection SQL	Injection dans formulaires et paramètres	SQLMap, manuel		
Test XSS	Injection de scripts dans l'application	XSSer, manuel		
Test d'authentification	Force brute, contournement d'auth.	Hydra, manuel		
Test d'autorisation	Accès non autorisés, escalade de privilèges	Manuel		
Test de configuration	Vérification des configs serveur/applicatif	Lynis, manuel		
Test de chiffrement	Vérification TLS, algorithmes	SSLScan, testssl.sh		

Phase 3 : Post-exploitation et rapport

Activité	Description	Statut	Réf. doc.
Nettoyage des systèmes	Suppression des outils et comptes de test		
Documentation des preuves	Captures d'écran, logs, extraits de code		
Classification des vulnérabilités	Critique / Élevé / Moyen / Faible		
Calcul du score de risque	$R = P \times I$, cotation CVSS si applicable		
Rédaction du rapport technique	Selon modèle MUSA (7 sections)		

Activité	Description	Statut	Réf. doc.
Vérification des correctifs	Re-test après application des correctifs		

Tableau de correspondance ISO 19011:2018 / Démarche ANTIC

Présentation

Ce tableau met en regard les exigences de l'ISO 19011:2018 (colonne de gauche) avec leur statut dans la démarche ANTIC actuelle et leur prise en charge par MUSA. La colonne **Écart** identifie les points nécessitant une amélioration.

Exigence ISO 19011	Statut ANTIC	Écart	Réponse MUSA
§6.2 Déclenchement de l'audit : évaluation de la faisabilité	Non formalisée	Fort	Grille de faisabilité MUSA
§6.2 Sélection de l'équipe sur grille de compétences	Empirique	Fort	Grille pondérée 5 critères
§6.2 Déclaration d'indépendance formelle	Absente	Fort	Déclaration signée obligatoire
§6.3 Programme de travail approuvé avant le terrain	Partiel	Moyen	Programme de travail MUSA
§6.4.2 Réunion de lancement avec PV signé	Non formalisée	Fort	PV de lancement obligatoire
§6.4.3 Guides d'entretien standardisés	Absents	Fort	3 guides (direction, devs, utilisateurs)
§6.5.3 Preuves suffisantes, fiables, pertinentes	Recommandées	Moyen	PTxx avec preuves obligatoires

Exigence ISO 19011	Statut ANTIC	Écart	Réponse MUSA
§6.5.5 Supervision quotidienne par le lead auditor	Informelle	Moyen	Revue quotidienne formalisée
§6.5 Contenu minimal du rapport normé	Non imposé	Fort	Rapport 7 sections obligatoires
§6.4.6 Procédure contradictoire formalisée	Partielle (2 sem.)	Faible	Délai formalisé dans MUSA
§6.6 PV de réunion de clôture signé	Absent	Fort	PV de clôture signé par 2 parties
§6.7 Archivage des enregistrements d'audit	Non défini	Fort	Archivage 5 ans minimum
§6.7 Vérification de la mise en œuvre des actions	Informelle	Moyen	Revue trimestrielles MUSA
§5 Programme d'assurance qualité annuel	Absent	Fort	Programme AQ annuel MUSA

Synthèse des écarts : 9 écarts forts, 4 écarts moyens, 1 écart faible. L'ANTIC déclare s'aligner sur l'ISO 19011, mais son référentiel publié (2020) ne formalise pas les exigences clés. MUSA comble systématiquement chacun de ces écarts.

Normes IIA (IPPF) applicables à MUSA

Présentation

L'IIA (*Institute of Internal Auditors*) publie le cadre IPPF (*International Professional Practices Framework*) qui définit les standards professionnels de l'audit interne. Le tableau ci-après présente les normes intégrées dans MUSA, leur contenu et les artefacts MUSA correspondants.

Norme IIA	Intitulé et contenu	Exigence concrète	Artefact MUSA
1100	Indépendance et objectivité	L'auditeur doit être libre de tout conflit d'intérêts	Déclaration d'indépendance signée
1110	Indépendance organisationnelle	Structure organisationnelle garantissant l'indépendance	Charte d'audit approuvée DG
1120	Objectivité individuelle	Impartialité dans les jugements	Auto-évaluation des biais
1130	Atteintes à l'indépendance	Déclaration des conflits potentiels	Formulaire de déclaration
1200	Compétence et conscience professionnelle	Aptitudes, connaissances et rigueur	Grille de sélection d'équipe
1230	Formation professionnelle continue	40 h/an minimum de formation	Plan de formation annuel
1300	Programme d'assurance et d'amélioration qualité	Évaluations internes et externes	Rapport AQ annuel MUSA
2200	Planification de la mission	Objectifs, périmètre, ressources définis avant terrain	Plan de mission MUSA

Norme IIA	Intitulé et contenu	Exigence concrète	Artefact MUSA
2210	Objectifs de la mission	Objectifs SMART basés sur les risques	Matrice objectifs-risques
2230	Ressources allouées	Allocation selon complexité et criticité	Grille d'allocation des ressources
2240	Programme de travail de la mission	Programme approuvé avant le terrain	Programme de travail MUSA
2300	Réalisation de la mission	Informations suffisantes, fiables et pertinentes	Papiers de travail PTxx
2310	Identification des informations	Méthodes de collecte définies	Grilles d'entretien et d'observation
2320	Analyse et évaluation	Méthodologie rigoureuse documentée	Matrice des risques MUSA
2330	Documentation des informations	Papiers de travail traçables, archivage 5 ans	PTxx codifiés + archivage
2340	Supervision de la mission	Revue quotidienne par le lead auditor	Fiche de revue quotidienne
2400	Communication des résultats	Communication exacte, objective, claire	Rapport d'audit 7 sections
2410	Contenu de la communication	Forces + non-conformités + recommandations	Structure rapport MUSA
2420	Qualité de la communication	Approbation avant diffusion	Validation lead auditor
2440	Diffusion des résultats	Destinataires autorisés uniquement	Liste de diffusion contrôlée
2500	Suivi de la mise en œuvre	Vérification que les recommandations sont appliquées	Revue trimestrielles MUSA
2501	Rapport de suivi	État d'avancement documenté	Rapport de suivi trimestriel
2600	Communication du risque résiduel	Escalade si risque critique non traité	Procédure d'escalade 3 niveaux

Note importante : Les normes IIA ne sont pas des lois mais des standards professionnels reconnus mondialement. Leur application dans MUSA confère à chaque mission d’audit une crédibilité et une robustesse méthodologique alignées sur les meilleures pratiques internationales. Elles comblent spécifiquement les lacunes de gouvernance (L8) identifiées dans la démarche ANTIC.

Guide d'entretien Direction / Direction Générale

Informations générales

Mission :

Date : **Heure :** **Durée prévue :** 45–60 min

Auditeur(s) présent(s) :

Interlocuteur : **Fonction :**

Preuves demandées : Politique de sécurité signée, organigramme, budget SI, rapports d'incidents

Rappel : Toute affirmation sans preuve documentaire est codée **Déclaration non corroborée** dans les papiers de travail.

Thème 1 : Gouvernance de la sécurité

#	Question	Preuve attendue
1.1	Une politique de sécurité de l'information existe-t-elle formellement ? Est-elle signée par la direction ?	Politique signée, datée
1.2	À quelle fréquence la politique est-elle révisée et mise à jour ?	Date de dernière révision
1.3	Un responsable de la sécurité est-il identifié (RSSI ou équivalent) ? Quelles sont ses attributions ?	Fiche de poste, organigramme
1.4	Les rôles et responsabilités en matière de sécurité sont-ils documentés et diffusés ?	Document de répartition des rôles

#	Question	Preuve attendue
1.5	Existe-t-il un comité ou un mécanisme formel de pilotage de la sécurité ?	PV de réunion, CR comité

Thème 2 : Budget et ressources

#	Question	Preuve attendue
2.1	Un budget spécifique est-il alloué à la sécurité de l'information ?	Extrait budget
2.2	Ce budget est-il jugé suffisant par rapport aux risques identifiés ?	Justification chiffrée
2.3	Des investissements en sécurité ont-ils été réalisés au cours des 12 derniers mois ?	Factures, bons de commande

Thème 3 : Gestion des incidents

#	Question	Preuve attendue
3.1	Des incidents de sécurité se sont-ils produits sur GIDOCEP au cours des 12 derniers mois ?	Registre des incidents
3.2	Existe-t-il une procédure formelle de gestion des incidents ?	Procédure signée
3.3	Les incidents sont-ils signalés à l'ANTIC conformément à la loi 2010/012 ?	Copie des déclarations

Thème 4 : Continuité d'activité

#	Question	Preuve attendue
4.1	Un Plan de Reprise d'Activité (PRA) existe-t-il pour GIDOCEP ?	Document PRA
4.2	Ce plan a-t-il été testé ? À quelle date ?	Rapport de test
4.3	La sauvegarde des données de GIDOCEP est-elle documentée et testée ?	Procédure de sauvegarde, log de test

Thème 5 : Conformité réglementaire

#	Question	Preuve attendue
5.1	L'organisation est-elle au fait des obligations de la loi 2010/012 ?	Registre de conformité
5.2	Des audits de sécurité ont-ils été conduits précédemment ?	Rapports d'audits antérieurs
5.3	Les recommandations des audits précédents ont-elles été traitées ?	Plan d'actions clôturé

Observations de l'auditeur :

Guide d'entretien ; Responsable technique / Développeurs

Informations générales

Mission :

Date : **Heure :** **Durée prévue :** 60–90 min

Interlocuteur : **Fonction :**

Preuves demandées : Code source (extraits), configurations, journaux de build, procédures de déploiement

Thème 1 : Cycle de développement sécurisé

#	Question	Preuve attendue
1.1	Les exigences de sécurité sont-elles définies avant le développement de chaque fonctionnalité ?	Cahier des charges, user stories
1.2	Des revues de code intégrant des critères de sécurité sont-elles menées ?	Historique de revues
1.3	Des outils d'analyse statique (SAST) sont-ils intégrés dans le pipeline ?	Rapports SonarQube ou équivalent
1.4	Les environnements de développement, test et production sont-ils séparés ?	Architecture des environnements
1.5	Les données de test sont-elles anonymisées ?	Scripts d'anonymisation

Thème 2 : Gestion des vulnérabilités et mises à jour

#	Question	Preuve attendue
2.1	Un inventaire des bibliothèques tierces utilisées dans GIDOCEP existe-t-il ?	Fichier de dépendances (pom.xml, requirements.txt...)
2.2	Ces bibliothèques sont-elles vérifiées régulièrement pour des vulnérabilités connues ?	Rapport de scan de dépendances
2.3	Quelle est la procédure d'application des correctifs de sécurité ?	Procédure de patch management
2.4	Des tests de régression sécurité sont-ils menés après chaque mise à jour ?	Rapports de tests

Thème 3 : Gestion des accès et authentification

#	Question	Preuve attendue
3.1	Comment les mots de passe sont-ils stockés dans GIDOCEP ?	Extrait de code (hachage)
3.2	Quelle est la politique de gestion des sessions (expiration, invalidation) ?	Configuration de session
3.3	Le principe de moindre privilège est-il appliqué dans les niveaux d'accès ?	Matrice des droits
3.4	Comment les comptes administrateurs sont-ils gérés et surveillés ?	Procédure de gestion comptes admins

Thème 4 : Journalisation et traçabilité

#	Question	Preuve attendue
4.1	Quels événements sont journalisés dans GIDOCEP ?	Configuration de journalisation
4.2	Les journaux sont-ils protégés contre la modification ou la suppression ?	Contrôle d'accès aux logs
4.3	Quelle est la durée de conservation des journaux ?	Politique de rétention
4.4	Les journaux sont-ils surveillés activement ou analysés périodiquement ?	Procédure de surveillance

Thème 5 : Logique métier GIDOCEP

#	Question	Preuve attendue
5.1	Le workflow de validation des écritures comptables est-il implémenté côté serveur exclusivement ?	Extrait de code
5.2	Est-il possible de modifier une écriture comptable après validation ? Si oui, comment est-ce tracé ?	Log d'audit des modifications
5.3	Des contrôles empêchent-ils la saisie d'écritures hors-période comptable ?	Code de validation + test
5.4	La séparation des données entre établissements est-elle garantie ? Comment ?	Architecture multi-tenant
5.5	Existe-t-il des contrôles sur les montants maximaux saisissables ?	Configuration des limites

Thème 6 : Infrastructure et configuration

#	Question	Preuve attendue
6.1	Le serveur hébergeant GIDOCEP est-il dédié ou partagé avec d'autres applications ?	Architecture serveur
6.2	Les communications entre GIDOCEP et sa base de données sont-elles chiffrées ?	Configuration de connexion
6.3	Les sauvegardes sont-elles automatisées, chiffrées et testées régulièrement ?	Procédure + log de sauvegarde
6.4	Quels composants logiciels (OS, serveur web, BDD) sont utilisés et dans quelles versions ?	Inventaire technique

Guide d'entretien Utilisateurs finaux

Informations générales

Mission :

Date : **Échantillon cible :** 3 à 5 utilisateurs

Profils inclus : Agent comptable, chef de service, administrateur local

Durée par entretien : 20–30 min

Note : Les entretiens utilisateurs sont menés individuellement. Les réponses sont anonymisées.

Thème 1 : Authentification et gestion des accès

#	Question	Observation
1.1	Avez-vous changé votre mot de passe initial ? À quelle date ?	Vérifier s'il s'agit du mot de passe par défaut
1.2	Partagez-vous votre mot de passe avec d'autres personnes ?	Comportement à risque
1.3	Votre session GIDOCEP se déconnecte-t-elle automatiquement après inactivité ?	Vérifier sur poste
1.4	Avez-vous accès à des fonctionnalités qui ne vous semblent pas nécessaires pour votre travail ?	Indice de sur-privège

Thème 2 : Sensibilisation et comportements

#	Question	Observation
2.1	Avez-vous reçu une formation à la sécurité informatique au cours des 12 derniers mois ?	Attestation de formation

#	Question	Observation
2.2	Savez-vous à qui signaler un incident ou un comportement suspect sur GIDOCEP ?	Canal de signalement connu
2.3	Avez-vous déjà reçu un courriel suspect semblant provenir de GIDOCEP ?	Indicateur d'attaque phishing

Thème 3 : Usage quotidien et anomalies

#	Question	Observation
3.1	Avez-vous déjà rencontré un comportement anormal de GIDOCEP (accès non autorisé, donnée modifiée à votre insu) ?	Registre des anomalies signalées
3.2	Pouvez-vous décrire votre usage typique de GIDOCEP (opérations les plus fréquentes) ?	Compréhension logique métier
3.3	Des données de GIDOCEP sont-elles exportées ou échangées via des canaux non sécurisés (email, clé USB) ?	Pratique à risque

Modèle de rapport d'audit MUSA

En-tête du rapport

RAPPORT D'AUDIT DE SÉCURITÉ APPLICATIVE : MUSA

Titre :

Référence : MUSA-AUDIT- [AAAA] - [NN] Version :

Application auditée : Niveau d'audit : ☐ 1 ☐ 2 ☐ 3

Période d'audit : Structure auditée :

Lead auditor : Visa :

Date de transmission : Statut : ☐ Provisoire ☐ Définitif

Classification : ☐ Confidentiel ☐ Strictement confidentiel

Section 1 : Résumé exécutif (2 pages max.)

Consigne : Cette section est rédigée pour la direction. Elle ne contient aucun terme technique. Elle présente les 3 forces, les 3 vulnérabilités critiques, les 5 métriques et la recommandation principale.

Métriques à reporter :

- ◆ Taux de conformité global : $TC = \dots \%$
- ◆ Taux de conformité OWASP N2 : $TC_{N2} = \dots \%$
- ◆ Score de risque moyen : $\bar{R} = \dots$
- ◆ Entropie globale : $H_{global} = \dots$
- ◆ Score de maturité global : $\dots \%$

Verdict général : ☐ Satisfaisant ☐ Acceptable avec réserves ☐ Insuffisant ☐ Critique

Section 2 : Contexte et périmètre (1–2 pages)

1. Description de l'organisation (SOLTEC) : mission, effectifs, position dans l'écosystème TIC
2. Description de l'application auditée (GIDOCEP) : version, technologie, utilisateurs
3. Périmètre inclus :
4. Périmètre exclus :
5. Niveau d'audit retenu et justification :
6. Contraintes et limitations :

Section 3 : Méthodologie (1–2 pages)

1. Méthode appliquée : MUSA (Méthode Unifiée d'Audit de Sécurité Applicative)
2. Standards de référence : ISO 27001:2022, OWASP ASVS v4.0.3, NIST SP 800-115, ISO 19011:2018, normes IIA
3. Outils utilisés : (liste d'outils effectivement utilisés)

-
4. Composition de l'équipe d'audit : (noms, fonctions, rôles)
 5. Période et modalités des tests : (dates, horaires, environnement)
 6. Entropie de Shannon : description de son usage pour la reproductibilité

Section 4 : Synthèse des résultats (2–3 pages)

Tableau de bord complet :

- ◆ Distribution des constats : Conformes / NC / Zone grise / NA
- ◆ Distribution des vulnérabilités par niveau de risque (Critique / Élevé / Modéré / Faible)
- ◆ Répartition par catégorie OWASP ASVS (graphique radar)
- ◆ Score de maturité par domaine (graphique toile d'araignée)
- ◆ Comparaison avec le cycle d'audit précédent (si applicable)
- ◆ Valeur de H_{global} et interprétation

Section 5 : Détail des vulnérabilités (10–20 pages)

Pour chaque vulnérabilité identifiée, utiliser le modèle de fiche ci-dessous :

Table I.1. Fiche de vulnérabilité normalisée MUSA

Champ	Contenu
Identifiant	TECH-001 / ORG-001
Titre	Description courte (ex. : Mots de passe en clair en base)
Catégorie OWASP	V2.1 / V5.3 / etc.
Contrôle ISO 27001	8.5 / 5.17 / etc.
Description	Description technique détaillée du problème
Preuve	Référence à la capture d'écran / log en annexe
Impact	Description de l'impact métier et sécurité
Probabilité (P)	1 / 2 / 3 / 4
Impact (I)	1 / 2 / 3 / 4
Score de risque ($R = P \times I$)	1 / 4 / 9 / 16
Entropie (H_i)	Valeur + interprétation
Recommandation	Action corrective précise et actionnable
Priorité	Critique / Élevé / Modéré / Faible
Échéance	48h / 2 semaines / 1 mois / Planifié
Responsable	Nom + fonction

Section 6 : Plan d'action (2–3 pages)

Tableau de synthèse de toutes les recommandations :

- ◆ Action corrective (une par ligne)
- ◆ Priorité (Critique / Élevé / Modéré / Faible)
- ◆ Échéance (date précise)
- ◆ Responsable (nom, fonction)
- ◆ Indicateur de résolution (comment vérifier que c'est fait)
- ◆ Statut (Planifié / En cours / Réalisé / Reporté)

Section 7 : Annexes du rapport

Liste des pièces jointes au rapport :

- ◆ Papiers de travail PT01 à PT05 (ou extraits significatifs)
- ◆ Captures d'écran des vulnérabilités prouvées
- ◆ Exports bruts des outils (SonarQube, OWASP ZAP, OpenVAS)
- ◆ Grilles d'entretiens renseignées
- ◆ PV de la réunion de lancement
- ◆ PV de la réunion de clôture
- ◆ Déclarations d'indépendance signées

Modèle de charte d'audit MUSA

CHARTE D'AUDIT DE SÉCURITÉ APPLICATIVE : MUSA

Référence : MUSA-CHARTE-[AAAA] - [NN] Date :

Version : Statut : ☐ Provisoire ☐ Signée

Article 1 : Parties

Commanditaire (structure auditée) :

Raison sociale :

Représentant légal : Fonction :

Équipe d'audit :

Lead auditor :

Auditeur(s) :

Mandant (ANTIC ou interne) :

Article 2 : Périmètre et objectifs

Application auditée : Version :

Périmètre inclus :

Périmètre exclu :

Niveau d'audit : ☐ 1 Basique ☐ 2 Standard ☐ 3 Approfondi

Objectifs spécifiques :

Article 3 : Calendrier

Date de début des travaux : **Date de fin :**
Date de transmission du rapport provisoire :
Date prévue de réunion de clôture :

Article 4 : Engagements du commanditaire

Le commanditaire s'engage à :

1. Fournir les documents demandés dans les délais fixés
2. Mettre à disposition les interlocuteurs nécessaires
3. Fournir l'autorisation écrite de test avant tout test intrusif
4. Ne pas interférer avec le jugement indépendant de l'équipe d'audit
5. Respecter la procédure contradictoire (10 jours ouvrés)

Article 5 : Engagements de l'équipe d'audit

L'équipe d'audit s'engage à :

1. Respecter la confidentialité de toutes les informations collectées
2. Appliquer la méthode MUSA sans biais ni conflit d'intérêts
3. Transmettre le rapport provisoire dans les délais convenus
4. Préserver l'intégrité et la disponibilité des systèmes audités
5. Archiver le dossier d'audit pendant 5 ans minimum

Article 6 : Signatures

Pour le commanditaire :

Signature :

Nom :

Date :

Pour l'équipe d'audit :

Signature (lead auditor) :

Nom :

Date :

Formulaire de déclaration d'indépendance

DÉCLARATION D'INDÉPENDANCE ET D'OBJECTIVITÉ : MUSA (IIA 1100)

Mission :

Application audité :

Auditeur : Rôle :

Date :

Je soussigné(e),, déclare solennellement :

#	Déclaration	OUI	NON
1	Je n'ai aucun lien familial (jusqu'au 2 ^e degré) avec les dirigeants ou employés de la structure audité	☐	☐
2	Je n'ai aucun intérêt financier direct ou indirect dans la structure audité	☐	☐
3	Je n'ai pas participé au développement ou à la maintenance de l'application GIDOCEP au cours des 24 derniers mois	☐	☐
4	Je n'ai pas tenu de poste de décision au sein de la structure audité au cours des 12 derniers mois	☐	☐
5	Je n'ai aucune raison personnelle, professionnelle ou financière de biaiser les conclusions de cet audit	☐	☐
6	Je m'engage à signaler immédiatement tout conflit d'intérêts qui pourrait survenir en cours de mission	☐	☐

Si une réponse **OUI** a été cochée aux points 1 à 5, préciser :

.....

Signature de l'auditeur :

.....

Date :

Visa du lead auditor :

.....

Date :

Modèle de procès-verbal de réunion

MUSA

PROCÈS-VERBAL DE RÉUNION

Type de réunion : ☐ Lancement ☐ Ouverture terrain ☐ Pré-clôture ☐ Clôture ☐ Suivi

Mission : Réf. rapport :

Date : Heure début : Heure fin :

Lieu :

Participants

Nom	Fonction	Organisation	Signature
-----	----------	--------------	-----------

Points discutés

#	Point discuté	Décision / Résultat	Responsa
1			
2			
3			
4			
5			

Actions décidées

#	Action	Responsable	Échéance
1			
2			
3			

Lead auditor :

**Représentant commandi-
taire :**

Signature :

Signature :

Date :

Date :